

Daily Vulnerability Report - 2026-10-02

Window (UTC): 2026-10-01T08:04 to 2026-10-02T08:04 | Sources: NVD, CISA KEV, EPSS, Vulnrichment, GHSA, OSV | Generated 2026-10-02 08:05:17 UTC

Total	New	Updated	KEV added	KEV	Critical	High	Medium	Unscored	Watchlist
728	664	64	0	1	62	196	166	305	44

New today - published in this report window

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-104286	New	9.8	CRIT	Yes		fortinet:fortimail	An improper limitation of a pathname to a restricted directory ('path traversal') vulnerability in Fortinet FortiMail 8.0.0 through 8.0.1, FortiMail 7.6.0 through 7.6.6, FortiMail 7.4.0 through 7.4.8, FortiMail 7.2.0 through 7.2.9 may allow an unauthenticated attacker to write arbitrary files on the underlying system via crafted HTTP or HTTPS requests.
CVE-2026-55393	New	10.0	CRIT				Unvalidated pathnames in the web interface in Teledyne FLIR Aware2 versions through 6.9.0.2 (PackBot) and 1.7.9 (FirstLook) allows remote unauthenticated attackers to read configuration and security parameters on Teledyne FLIR PackBot and FirstLook robots running this software via path traversal.
CVE-2026-79901	New	9.9	CRIT				In deployments using BoKS keytab management, affected versions of boks_keytabmd generate Active Directory service-account passwords from a predictable pseudo-random sequence seeded with the current Unix timestamp. An attacker who knows the service principal and can estimate the password-change time can reproduce a limited candidate set and verify candidates offline.
CVE-2026-93698	New	9.9	CRIT				Insufficient validation allows arbitrary commands to be executed via the Multilang adminbin.
CVE-2026-96658	New	9.9	CRIT				A flaw was found in Foreman. An authenticated attacker with low-level permissions can achieve remote code execution (RCE) by bypassing the safemode sandbox within the templating engine. Due to improper handling of delegated methods, an attacker can append unauthorized functions to the allowed execution list, enabling them to run arbitrary commands on the hosting server.
CVE-2026-103752	New	9.8	CRIT				Unauthenticated Privilege Escalation in Authorizer <= 3.15.3 versions.
CVE-2026-103764	New	9.8	CRIT				Mooncake transfer engine before 0.3.13 contains an untrusted pointer dereference in ServerSession::readHeader that allows unauthenticated attackers to read and write arbitrary process memory via the TCP transport data port. Attackers can send a crafted SessionHeader with arbitrary addr and size values using READ or WRITE opcodes to disclose KV cache contents, prompts and sec...
CVE-2026-12627	New	9.8	CRIT				Fortra's Core Privileged Access Manager (BoKS) contains a stack-based buffer overflow vulnerability in boks_autoregisterd. A remote attacker with network access to the autoregistration service may be able to trigger memory corruption during client response processing.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-14378	New	9.8	CRIT				The DevKit Pro plugin for WordPress is vulnerable to Authentication Bypass Leading to Administrator Account Takeover in all versions up to, and including, 2.3.0 This is due to the `revert_switch` handler trusting the attacker-controlled `original_user_id` cookie as the privileged identity: `verify_nonce_and_capability()` incorrectly checks the `manage_options` capability on ...
CVE-2026-15989	New	9.8	CRIT				The Super Forms – Drag & Drop Form Builder plugin for WordPress is vulnerable to Privilege Escalation in all versions up to, and including, 6.3.316. This is due to the Register & Login add-on's before_email_success_msg() function whitelisting the client-submitted `role` key and copying it into the user-data array that is passed directly to wp_insert_user(), without validatin...
CVE-2026-19660	New	9.8	CRIT				The Divi Membership plugin for WordPress is vulnerable to Authentication Bypass in all versions up to, and including, 2.3.0. The `process_paypal_callback` function, hooked to the `init` action, accepts a base64-encoded `paypal_param` GET parameter with no IPN validation, no cryptographic signature check, no ownership verification, and no nonce, allowing it to trust an entire...
CVE-2026-56154	New	9.8	CRIT				Use After Free vulnerability in Apache HTTP Server's mod_rewrite when using lookahead (%{LA-U:HTTP:...}) This issue affects Apache HTTP Server: from 2.4.0 through 2.4.68.
CVE-2026-57941	New	9.8	CRIT				Use After Free vulnerability in Apache HTTP Server's mod_http2 via shared session->btmp re-entrancy This issue affects Apache HTTP Server: from 2.4.0 through 2.4.68.
CVE-2026-59797	New	9.8	CRIT				Improper Privilege Management vulnerability in Apache HTTP Server's mod_ssl via SSLRequire and file-related expressions. This issue affects Apache HTTP Server: from 2.4.0 through 2.4.68.
CVE-2026-75957	New	9.8	CRIT				The Ultimate Multisite – WordPress Multisite SaaS & WaaS Platform plugin for WordPress is vulnerable to Authentication Bypass in all versions up to, and including, 2.15.0 via the `checkout_form` parameter of the `login_customer_after_checkout` function. This is due to the publicly accessible `wu_ajax_nopriv_wu_validate_form` AJAX handler accepting a freely obtainable checkout...
CVE-2026-56662	New	9.6	CRIT				GetSimple CMS is a content management system (CMS), and GetSimple CMS CE is the community edition of that CMS. Prior to version 1.5, the UpdateCE update form contained no anti-CSRF token, and the POST handler performed no token or request-origin verification. A remote attacker can host a page that auto-submits a forged POST to the update endpoint; when an authenticated admin...
CVE-2026-103765	New	9.4	CRIT				Mooncake through 0.3.13.post1 contains a missing authentication vulnerability in the HTTP metadata server /metadata handler that allows unauthenticated attackers to read, overwrite, and delete transfer engine metadata keys. Attackers can poison segment descriptors such as tcp_data_port or re-create rpc_meta entries to redirect KV cache transfers to attacker-controlled listen...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-104480	New	9.4	CRIT				Discord libdave before 1.2.0 did not reject an MLS Welcome message when the resulting group roster contained an unrecognized participant. An attacker in control of the DAVE signaling path (the voice gateway, or an equivalent position able to add, alter, or withhold signaling messages to a client) could cause affected clients to accept an unauthorized member into the end-to-e...
CVE-2026-14984	New	9.4	CRIT				Cleartext transmission in the primary control endpoints of Teledyne FLIR Aware2 versions through 6.9.0.2 allows remote unauthenticated attackers to intercept, hijack, or modify session traffic against Teledyne FLIR PackBot robots running this software via sniffing or hijacking network traffic.
CVE-2026-18397	New	9.4	CRIT				This vulnerability enables unauthenticated remote code execution (RCE) on a victim's machine by exploiting a combination of cryptographic weaknesses and memory management issues in the SConnect native host component. The attack leverages an unrestricted messaging interface between an attacker-controlled web page and the native host, allowing malicious input to bypass securi...
CVE-2026-55395	New	9.4	CRIT				Hardcoded passwords in the access control in Teledyne FLIR Aware2 versions through 6.9.0.2 (PackBot) and 1.7.9 (FirstLook) allows remote unauthenticated attackers to access and reconfigure Teledyne FLIR PackBot and FirstLook robots running this software via reading the passwords from the firmware or documentation.
CVE-2026-94620	New	9.4	CRIT				Classroom 50 is a free and open-source tool for managing and grading programming assignments via GitHub. Prior to version 1.11.0, `gh teacher download` clones each student's assignment repository and then writes autograde artifacts (`result.json` and `results.json`) into the just-cloned working tree. The write followed symlinks, so a student who committed `result.json` or `r...
CVE-2026-103244	New	9.3	CRIT				ground-station versions before 0.8.0 contain an authentication bypass vulnerability in the setup.restore command that allows unauthenticated attackers to execute arbitrary SQL during first-run setup mode. Attackers can invoke setup.restore via Socket.IO to plant admin users and forged session tokens, then authenticate as administrator without credentials for complete applica...
CVE-2026-103264	New	9.3	CRIT				Fleet versions before 4.87.0 contain an authentication bypass vulnerability in the device API that accepts hostnames and hardware serials as authentication tokens in addition to device UUIDs. Unauthenticated attackers who know or guess these non-secret identifiers can authenticate as iOS/iPadOS hosts to read device data and trigger device-scoped actions including software in...
CVE-2026-103655	New	9.3	CRIT				MISP contains a vulnerability in its two-factor authentication (TOTP) verification process that permits a valid one-time code to be accepted more than once within its time-based validity window. The issue exists in the user login flow where a TOTP code is verified as a second authentication factor. Because the system did not record whether a given TOTP period had already be...
CVE-2026-103922	New	9.3	CRIT				Capacitor is a cross-platform native runtime for web applications. From 6.0.0 until 6.2.2, 7.6.9, 8.3.5, 8.4.3, and 8.5.1, the Android and iOS WebView navigation guard validates a target URL's host and scheme but not its path, allowing a victim who activates an untrusted link to navigate a frame to /_capacitor_http_interceptor_. The native proxy can fetch an attacker-selecte...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-13043	New	9.3	CRIT				A missing authentication vulnerability in the Kernel Memory Access Driver (PSKMAD) used by WatchGuard endpoint security products allows a local, authenticated attacker to bypass the driver's access-control handshake and issue arbitrary privileged commands to the driver, resulting in disclosure of kernel and process memory.
CVE-2026-62071	New	9.3	CRIT				Unauthenticated SQL Injection in WordPress File Upload <= 5.1.10 versions.
CVE-2026-71449	New	9.3	CRIT				: Use of Hard-coded Cryptographic Key vulnerability in Johnson Controls EasyIO FS32 allows : Retrieve Embedded Sensitive Data. This issue affects EasyIO FS32: before 3.0b63.
CVE-2026-102628	New	9.2	CRIT				The Cadmos LTI application hosted at cadmos.eummena.io had Laravel debug mode enabled (APP_DEBUG=true, APP_ENV=local) in a publicly accessible environment. An unauthenticated attacker could send a GET request and trigger an unhandled exception, causing Laravel to expose the entire server environment, including all .env configuration variables, in plaintext. Fixed on or befor...
CVE-2026-15896	New	9.1	CRIT				The Super Forms – Drag & Drop Form Builder plugin for WordPress is vulnerable to Directory Traversal in all versions up to, and including, 6.3.316 via the parse_request function. This makes it possible for unauthenticated attackers to read the contents of arbitrary files on the server, which can contain sensitive information. The optional 'file_upload_auth' setting defaults ...
CVE-2026-53953	New	9.1	CRIT				GetSimple CMS is a content management system (CMS), and GetSimple CMS CE is the community edition of that CMS. In version 3.3.22, the password reset endpoint can be accessed without authentication. When a reset request is submitted for an existing user, the application generates a new temporary password and immediately stores its hash as the user's new password. The temporar...
CVE-2026-55083	New	9.1	CRIT				DHIS2 is a flexible information system for data capture, management, validation, analytics and visualization. From versions 2.42.0 to before 2.42.5.1, and from versions 2.43.0 to before 2.43.0.1, DHIS2 is vulnerable to remote code execution (RCE) via unsafe Java deserialization. This issue has been patched in versions 2.42.5.1, 2.43.0.1, and 2.44.
CVE-2026-56660	New	9.1	CRIT				GetSimple CMS is a content management system (CMS), and GetSimple CMS CE is the community edition of that CMS. Prior to version 1.5, the update handler in UpdateCE.php downloads a ZIP archive and extracts its contents into the web root without validating file types or extraction paths. Because PHP files are written into a web-accessible directory, an attacker who can cause a...
CVE-2026-63569	New	9.1	CRIT				Improper input validation in DHAgreement.CalculateAgreement (MTI/A0 two-pass Diffie-Hellman) in Legion of the Bouncy Castle Inc. bc-csharp before 2.7.0 allows an on-path attacker to make the local party compute an agreed value the attacker already knows, defeating the key authentication MTI/A0 is meant to provide. It also allows a malicious peer to learn the local static pri...
CVE-2026-79898	New	9.1	CRIT				Fortra BoKS Manager contains a command injection vulnerability in crlserver. An authenticated user authorized to add CRL URLs through BCC, the WSI REST or SOAP API, or the cacrl command-line interface could cause shell command substitution to be processed by crlserver as root on the BoKS Master. BCC and WSI provide network-accessible administration paths and do not require a...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-96659	New	9.1	CRIT				A flaw was found in Foreman. This vulnerability allows an authenticated user with low-level Viewer permissions to cause unauthorized information disclosure by submitting requests to template preview endpoints. By exploiting this issue, the user can access sensitive data, such as host root passwords. Furthermore, under insecure system configurations where Safemode protections...
CVE-2026-102667	New	9.0	CRIT				Joyland AI app allows an attacker with shared network access to inject JavaScript into content loaded in WebView. Without user-granted permissions, an attacker could access the clipboard, make arbitrary HTTP requests via the Weex 'stream' module, or access app-internal storage. If the installed app has been granted permissions previously, the attacker can access the entire ...
CVE-2026-86345	New	9.0	CRIT				A flaw was found in 389-ds-base. The server does not discard plaintext bytes already buffered from a client connection when negotiating StartTLS, allowing an on-path attacker to inject a crafted LDAP message that is processed after the TLS upgrade and whose response is delivered to the client in place of the client's own pending operation's response, due to messageID collisi...
CVE-2026-93029	New	9.0	CRIT				There is a stored XSS vulnerability allowing arbitrary code execution in the WHM Manage SSL Hosts interface.
CVE-2026-93697	New	9.0	CRIT				There is a stored XSS vulnerability allowing arbitrary code execution in the WHM Mass Modify Accounts interface.
CVE-2026-103068	New	8.8	HIGH				Subscriber Privilege Escalation in ByteCoreStack – MCP Connector for AI Tools <= 1.2.2 versions.
CVE-2026-103484	New	8.8	HIGH				IVFFlat index build in pgvector before 0.8.7 allows a database user to write data out-of-bounds, which can lead to arbitrary code execution.
CVE-2026-104018	New	8.8	HIGH				An improper privilege management vulnerability (CWE-269) exists in the command shell of Wind River VxWorks 7 when configured to enforce per-user command privileges. Under certain shell operations, a command may be evaluated without the privilege check that is normally applied, allowing an authenticated user with limited privileges to execute commands they are not authorized ...
CVE-2026-12405	New	8.8	HIGH				A flaw was found in rubygem-foreman_remote_execution. A command injection vulnerability exists in the Red Hat Satellite API (/api/v2/job_invocations). When a job template has the effective_user property marked as overridable: true, the application fails to properly sanitize the effective_user input provided during the API request. The exploitation does not rely on the conten...
CVE-2026-15897	New	8.8	HIGH				The Super Forms – Drag & Drop Form Builder plugin for WordPress is vulnerable to Privilege Escalation in all versions up to, and including, 6.3.316. This is due to the Register & Login add-on's before_email_success_msg() function, in its register_login_action='update' flow, trusting an attacker-supplied user_id value and passing it to wp_update_user() without any ownership o...
CVE-2026-19807	New	8.8	HIGH				The ByteCoreStack – MCP Connector for AI Tools plugin for WordPress is vulnerable to Privilege Escalation in all versions up to, and including, 1.2.3 This is due to the `wp_update_user_meta` MCP tool in `execute_tool` gating writes solely with `current_user_can('edit_user', \$uid)` — a check that WordPress core's `map_meta_cap` resolves to the `read` primitive when the target...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-66246	New	8.8	HIGH				iControl is affected by a Broken Access Control vulnerability, which could allow an attacker to exploit missing authentication checks or insecure direct object references (IDOR), enabling privilege escalation and the unauthorized modification or deletion of sensitive application data.
CVE-2026-70650	New	8.8	HIGH				GetSimple CMS is a content management system (CMS), and GetSimple CMS CE is the community edition of that CMS. In versions 3.3.22 and prior, an authenticated stored Cross-Site Scripting (XSS) vulnerability exists in the page backup viewer (admin/backup-edit.php). Page fields are correctly HTML-encoded when a page is saved, but the backup viewer decodes them again (htmldecode...
CVE-2026-93546	New	8.8	HIGH				Integer overflow in mod_dav_fs in Apache HTTP Server through 2.4.68 allows an authenticated WebDAV client with write access to crash worker processes and persistently corrupt a directory's property database via PROPPATCH requests declaring many XML namespaces.
CVE-2026-95687	New	8.8	HIGH				The WPC Shop as a Customer for WooCommerce plugin for WordPress is vulnerable to privilege escalation via account takeover in all versions up to, and including, 2.0.0 This is due to the plugin not properly validating the target user's role prior to issuing a new authentication session, allowing an authenticated attacker to log in as any WordPress Administrator by directly su...
CVE-2026-97284	New	8.8	HIGH				Contributor PHP Object Injection in Icegram <= 3.1.31 versions.
CVE-2026-102369	New	8.7	HIGH				Tapo C120 v1 and C200 V5 do not adequately protect login challenge data or sanitize attacker-controlled input processed by the MacTool handler. An unauthenticated attacker on the same local network can replay login challenge data to obtain an administrative session, enable a privileged service that becomes accessible after a reboot, and submit crafted input to execute arbitr...
CVE-2026-103268	New	8.7	HIGH				Ghost versions before 6.62.0 contain an authentication bypass vulnerability that allows suspended staff users to reactivate their accounts through self-service password reset. Attackers with suspended staff credentials can perform password reset operations to regain active account access and restore their original privileges.
CVE-2026-103272	New	8.7	HIGH				Ghost versions from 2.10.0 before 6.63.0 contain a staff enumeration vulnerability in the content API that allows unauthenticated attackers to leak user data. Attackers can observe discrepancies in API metadata responses to enumerate staff members and extract sensitive information without authentication.
CVE-2026-104020	New	8.7	HIGH				Uncontrolled recursion in the Ion reader in Amazon Ion Python before 0.15.0 might allow a remote unauthenticated actor to crash the application using the library, resulting in a denial of service, via a crafted, deeply nested Ion value. To remediate this issue, users should upgrade to version 0.15.0 or later.
CVE-2026-104057	New	8.7	HIGH				Podgrab contains an unauthenticated denial-of-service vulnerability caused by unsynchronized concurrent access to shared maps (activePlayers and allConnections) in its WebSocket handler, where Wshandler and HandleWebSocketMessages goroutines read and write these maps without a mutex. A remote attacker can open multiple WebSocket connections to the /ws endpoint and send messa...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-16000	New	8.7	HIGH				Missing cryptographic step in the DSTU 7624 CCM mode implementation (KCcmBlockCipher) in Legion of the Bouncy Castle Inc. bc-csharp before 2.7.0 allows an attacker who can observe encrypted messages of known or chosen content to forge ciphertexts with valid authentication tags, via messages encrypted without associated data. The cause is that the G1 block, which binds the no...
CVE-2026-54049	New	8.7	HIGH				Sakai is a Collaboration and Learning Environment (CLE). From versions 23.0 to before 23.5, and versions 25.0 to before 25.3, the Sakai Conversations tool stores topic and post messages without HTML sanitization, and the frontend renders them using LitElement's unsafeHTML() directive, resulting in stored cross-site scripting (XSS). Any authenticated user with access to a sit...
CVE-2026-55230	New	8.7	HIGH				Vvweb is a powerful and easy to use CMS with page builder to build websites, blogs or ecommerce stores. Prior to version 1.0.8.6, Vvweb's HTML sanitizer fails to strip event-handler attributes when a tag carries a greater-than character inside a quoted attribute value. A low-privilege content author (default role author or contributor) can store a payload in post or product ...
CVE-2026-63566	New	8.7	HIGH				Memory allocation with excessive size value in the DTLS handshake reassembly (DtIsReliableHandshake, DtIsReassembler) in Legion of the Bouncy Castle Inc. bc-csharp before 2.7.0 allows a remote unauthenticated DTLS peer to cause a denial of service through memory exhaustion via crafted handshake message fragments, because the reassembly buffer for each incoming handshake mess...
CVE-2026-63568	New	8.7	HIGH				Allocation of resources without limits or throttling in the CMP/CRMF password-based MAC verifier (PKMacBuilder) in Legion of the Bouncy Castle Inc. bc-csharp before 2.7.0 allows a remote unauthenticated attacker to cause a denial of service through CPU exhaustion via a CMP message or CRMF certificate request whose PBMPParameter declares a very large iteration count, because P...
CVE-2026-71542	New	8.7	HIGH				GetSimple CMS is a content management system (CMS), and GetSimple CMS CE is the community edition of that CMS. In versions 3.3.22 and prior, GetSimpleCMS-CE is vulnerable to stored Cross-Site Scripting (XSS) in the "Theme to Components" functionality (admin/components.php) via the title parameter. The stored title is rendered inside a double-quoted HTML attribute in the admi...
CVE-2026-101888	New	8.6	HIGH				The Prime Mover plugin for WordPress before 2.2.1 contains a Zip Slip path traversal vulnerability that allows authenticated administrators to write arbitrary files outside the intended extraction directory during migration ZIP import. Attackers can craft ZIP entry names with traversal sequences processed by computeExtractionParameters() and resumableZipExtractor() in utilit...
CVE-2026-103277	New	8.6	HIGH				Ghost versions from 2.5.0 before 6.34.0 contain an untrusted script execution vulnerability in the oEmbed preview feature that fails to sandbox externally hosted scripts. Attackers can craft malicious oEmbed content to execute scripts in the context of a staff user's admin session, potentially compromising administrative access.
CVE-2026-103292	New	8.6	HIGH				Ghost versions from 0.5.3 through versions prior to 6.50.0 fail to sanitize the data placed in the JSON-LD HTML tag emitted by the {{ghost_head}} helper. An authenticated user with limited privileges can inject unescaped content that is rendered as script in the published page, potentially leading to compromise of a staff user's admin session when that user views the affecte...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-103758	New	8.6	HIGH				Obot 0.21.1 through 0.24.1 contains an authorization bypass vulnerability that allows authenticated users to reach MCP servers because the checkUI deny list omits the /mcp-connect-composite/ route. Basic-role users with a composite MCP ID can proxy requests through mcpGateway.Proxy to invoke tools on MCP servers restricted by Access Control Rules.
CVE-2026-64949	New	8.6	HIGH				Incomplete extension blacklist in the File Manager module allows authenticated upload and execution of arbitrary .phar files. Affects Pandora FMS from 777 onwards.
CVE-2026-88789	New	8.6	HIGH				Improper Restriction of XML External Entity Reference in the XSLT support extension (camel-quarkus-support-xalan) in Apache Camel Quarkus from 3.2.0 before 3.33.3 and from 3.34.0 before 3.40.0 on all platforms allows an attacker who supplies the XML document being transformed to read local files or issue requests to internal network locations via an external entity declarati...
CVE-2026-95588	New	8.6	HIGH				Unauthenticated Arbitrary File Deletion in AcyMailing SMTP Newsletter <= 11.0.5 versions.
CVE-2026-102294	New	8.5	HIGH				TP-Link TL-WR841N contains an authenticated OS command injection vulnerability in the IPv6 WAN configuration. A crafted IPv6 Gateway value is improperly incorporated into a system command, allowing an authenticated administrator to execute arbitrary operating system commands. Successful exploitation may allow unauthorized access to sensitive information, modification of de...
CVE-2026-102379	New	8.5	HIGH				Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection') vulnerability in VillaTheme BuildKit – Product Builder for WooCommerce – Custom PC Builder woo-product-builder allows Blind SQL Injection.This issue affects BuildKit – Product Builder for WooCommerce – Custom PC Builder: from n/a through 1.0.28.
CVE-2026-103259	New	8.5	HIGH				n8n versions before 2.39.6 and 2.40.0 before 2.40.1 contain a session token leakage vulnerability in the Dynamic Credentials authorize and revoke endpoints. Attackers with resolver registration capability can capture collaborators' session tokens by setting a fallback resolver to an attacker-controlled endpoint during the account connection flow, enabling unauthorized creden...
CVE-2026-103278	New	8.5	HIGH				Ghost versions 5.8.0 before 6.34.0 contain an input validation vulnerability in the admin iframe that allows attackers to take over staff user accounts. Attackers with content publishing privileges can craft malicious pages that, when visited by active staff users, enable account takeover through improper input validation.
CVE-2026-103286	New	8.5	HIGH				Ghost versions from 2.21.0 before 6.56.0 contain a privilege escalation vulnerability in the notifications system that allows low-privilege staff users to escalate to higher-privilege staff roles. Attackers with low-privilege staff access can exploit the notifications system to gain elevated privileges without proper authorization checks.
CVE-2026-103338	New	8.5	HIGH				Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection') vulnerability in Unlimited Elements Unlimited Elements For Elementor (Free Widgets, Addons, Templates) unlimited-elements-for-elementor allows Blind SQL Injection.This issue affects Unlimited Elements For Elementor (Free Widgets, Addons, Templates): from n/a through 2.0.20.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-55396	New	8.5	HIGH				Cleartext transmission without a cryptographic integrity check in operator control unit to robot UDP traffic in Teledyne FLIR Aware2 versions through 6.9.0.2 (PackBot) and 1.7.9 (FirstLook) allows adjacent unauthenticated attackers to intercept, hijack, or modify control traffic against Teledyne FLIR PackBot and FirstLook robots running this software via sniffing or hijackin...
CVE-2026-102514	New	8.4	HIGH				Out-of-bounds Write (CWE-787) in the PEA archive extraction routine (pea.pas, unpea_procedure) of the first-party pea component in PeaZip 11.2.0 and earlier allows an attacker who convinces a victim to open or extract a crafted .pea archive to execute arbitrary code as the user running PeaZip. While decompressing a PCOMPRESS1 stream, the 32-bit compressed-block-size field of...
CVE-2026-64950	New	8.4	HIGH				Missing input validation and output encoding on the directory name parameter in File Manager's Create Directory allows stored XSS, executing without user interaction. Affects Pandora FMS from 777 onwards.
CVE-2026-73975	New	8.4	HIGH				djehuty is a research data repository system developed by 4TU.ResearchData. Prior to version 26.3.2, an authenticated depositor can inject arbitrary SPARQL into a state-modifying (DELETE/INSERT) query by supplying a crafted session name, letting them write (and delete) arbitrary triples anywhere in the RDF store. Because the RDF store is shared across all accounts and datase...
CVE-2026-101322	New	8.3	HIGH				In Eclipse BaSyx AAS Web UI versions v2-241220 through releases before v2-260924, the shared request handler attached the selected infrastructure's `Authorization` header to outgoing requests without checking the destination origin. In deployments using authentication, an attacker could induce a user to open a crafted Web UI link whose `aas` or `path` query parameter points ...
CVE-2026-103757	New	8.3	HIGH				Budibase through 3.41.0 contains a server-side request forgery vulnerability in AI table generation because the uploadUrl function in packages/server/src/utilities/fileUtils.ts uses raw node-fetch instead of fetchWithBlacklist. Authenticated builder users can send a prompt to POST /api/ai/tables that places an internal URL in an attachment column, causing the server to fetch...
CVE-2026-103263	New	8.2	HIGH				Tornado before 6.5.9 contains a path traversal vulnerability in StaticFileHandler that follows symbolic links inside the static root without confirming the resolved target stays within it. When a symlink pointing outside the static directory exists inside it, unauthenticated attackers can request it to read files such as configuration files, private keys, and application sec...
CVE-2026-104051	New	8.2	HIGH				PictShare before 3.7.1 contains an information disclosure vulnerability that allows unauthenticated attackers to obtain the secret delete_code and uploader metadata by calling the API::info() endpoint which returns the complete raw metadata object without a field whitelist. Attackers can use the publicly visible file hash to retrieve the delete_code via the info API and then...
CVE-2026-12540	New	8.2	HIGH				A flaw was found in Foreman. A command injection vulnerability exists in the foreman-rake errors:fetch_log task. The request_id parameter is passed to an underlying system command (typically grep) without adequate shell neutralization. While the task is intended to fetch specific log entries, an attacker with sudo permissions to execute this rake task can inject shell metach...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-12541	New	8.2	HIGH				A flaw was found in Foreman. OS command injection vulnerabilities exist in the foreman-rake db:dump and db:import_dump tasks. The application fails to properly sanitize user-supplied input in the destination parameter (during backups) and the file parameter (during imports) before passing them to a Ruby system() call for execution. An attacker with permissions to execute for...
CVE-2026-15999	New	8.2	HIGH				Improper validation of integrity check value in the AES-CCM implementation (CcmParameters and CcmBlockCipher) in Legion of the Bouncy Castle Inc. bc-csharp before 2.7.0 allows an on-path attacker to modify CCM-encrypted content without detection via an AlgorithmIdentifier whose CCMPParameters declare an authentication tag (aes-ICVlen) of zero or another length outside the RFC...
CVE-2026-16001	New	8.2	HIGH				Exposure of the message authentication key through the encryption keystream in the stream mode of IesEngine (an IesEngine constructed without a block cipher) in Legion of the Bouncy Castle Inc. bc-csharp before 2.7.0 allows a remote attacker who has observed one encrypted message with known plaintext to forge shorter messages of their choosing that the recipient accepts as a...
CVE-2026-63567	New	8.2	HIGH				Observable discrepancy in IesEngine.DecryptBlock in Legion of the Bouncy Castle Inc. bc-csharp before 2.7.0 allows a remote attacker who has captured an IES or ECIES ciphertext, and who can submit modified ciphertexts for decryption under the same key pair, to recover its plaintext via a CBC padding-oracle attack, because in block-cipher mode the engine decrypts the cipherte...
CVE-2026-94250	New	8.2	HIGH				Allocation of resources without limits or throttling vulnerability in batch-requests plugin in Apache APISIX. An unauthenticated caller can drive a gateway worker into OOM via a route where the batch-requests plugin is used and the batch endpoint is publicly exposed. This issue affects Apache APISIX: from 1.3.0 through 3.18.0. Users are recommended to upgrade to versio...
CVE-2026-96780	New	8.2	HIGH				figlet.js is a FIG driver written in JavaScript that aims to implement the FIGfont specification. Prior to 1.11.3, text() and textSync() can enter an unbounded loop when whitespaceBreak is enabled and width is smaller than the rendered width of a single FIGlet character. Under these conditions, breakWord() cannot find a valid break point and returns without consuming a chara...
CVE-2026-103250	New	8.1	HIGH				n8n versions before 1.123.80, from 2.0.0 before 2.39.6, and from 2.40.0 before 2.40.1 contain a NoSQL injection vulnerability in the MongoDB Chat Memory node that fails to validate the sessionId parameter. Unauthenticated attackers can supply MongoDB query operators in the sessionId field to access conversation histories from other users and perform unauthorized write and de...
CVE-2026-103257	New	8.1	HIGH				n8n versions before 1.123.80, from 2.0.0 before 2.39.6, and from 2.40.0 before 2.40.1 contain a path traversal vulnerability in the n8n node that fails to validate resource identifiers. Attackers can craft malicious resource IDs to redirect API calls to unintended resources, allowing unauthorized access to workflows, executions, and credential secrets within the API key's sc...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-103283	New	8.1	HIGH				Ghost versions 6.20.0 before 6.57.1 contain a session handling vulnerability that allows authenticated staff users to log in as any other staff user with only the password, bypassing two-factor authentication. Attackers with valid staff credentials can exploit improper session management to impersonate other staff members and gain unauthorized access to administrative functi...
CVE-2026-103493	New	8.1	HIGH			jetbrains:youtrack	In JetBrains YouTrack before 2026.2.19422 stored XSS via Mermaid and LaTeX content was possible
CVE-2026-104059	New	8.1	HIGH				Lektor 3.3.14 and 3.4.0b15 contains a cross-site request forgery vulnerability in the admin API blueprint that allows unauthenticated attackers to perform state-changing actions by sending cross-origin requests without CSRF tokens, Origin/Referer validation, CORS configuration, or Host allowlisting. Attackers can exploit the newattachment, deleterecord, build, clean, and pub...
CVE-2026-14316	New	8.1	HIGH				The revoked-key error path builds a human-readable failure reason using sprintf() into a heap buffer. The allocated buffer is too small for the final formatted message. When sprintf() writes the full message, it can write past the end of the heap allocation.
CVE-2026-15983	New	8.1	HIGH				The Super Forms – Drag & Drop Form Builder plugin for WordPress is vulnerable to Arbitrary File/Directory Deletion in all versions up to, and including, 6.3.316. This is due to the `super_save_form` AJAX handler performing no capability check — allowing Subscriber-level authenticated users to create or modify Super Forms and enable the `file_upload_submission_delete` setting...
CVE-2026-73636	New	8.1	HIGH				Authentication bypass by capture-replay in mod_auth_digest in Apache Software Foundation Apache HTTP Server 2.4.x on all platforms allows a man-in-the-middle (MITM) attacker to replay captured digest authentication credentials via crafted requests that trigger garbage collection of the client's shared memory entry when AuthDigestNonceLifetime is set to 0. Users are recommen...
CVE-2026-92820	New	8.1	HIGH				The Ninja Forms - File Uploads plugin for WordPress is vulnerable to arbitrary file operations in all versions up to, and including, 3.3.34 via the external (Amazon S3) upload flow. The plugin trusts an attacker-supplied file path from the form submission and stores it as the upload's file_path, which is then used without validation to attach a file to the form's notificatio...
CVE-2026-103067	New	8.0	HIGH				Cross-Site Request Forgery (CSRF) vulnerability in Memberful Memberful - Membership Plugin memberful-wp allows Cross Site Request Forgery.This issue affects Memberful - Membership Plugin: from n/a through 1.81.0.
CVE-2026-79899	New	7.9	HIGH				Fortra BoKS Manager contains an insecure temporary file vulnerability in bccgethostcert. The utility creates predictable temporary files without first setting a restrictive umask. A local user on the BoKS Master who can read files under BOKS_tmp may be able to obtain CA secret or host private-key material while the utility runs, or obtain CA secret material left behind after...
CVE-2026-103246	New	7.7	HIGH				n8n versions before 2.39.6 and 2.40.0 before 2.40.1 fail to validate credential ownership during inline agent node-tool introspection. Attackers can reference arbitrary credential IDs to decrypt and exfiltrate plaintext secrets to attacker-controlled hosts without ownership verification.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-103431	New	7.7	HIGH				colmux in collectl before 4.3.20.2 does not sanitize ANSI/VT100 terminal escape sequences in data received from remote collectl instances before displaying it, allowing a local user on a monitored host to inject escape sequences into the terminal of an operator running colmux, via a crafted process name (argv[0]).
CVE-2026-12544	New	7.7	HIGH				A flaw was found in Foreman. The foreman-rake initialization logic in /usr/share/foreman/config/settings.rb contains a vulnerable code pattern where configuration data is processed through two distinct executable layers. This creates a multi-stage execution chain that allows for both Server-Side Template Injection (SSTI) and insecure deserialization. This vulnerability can l...
CVE-2026-84682	New	7.7	HIGH				A command injection vulnerability exists in the TDDPv2 service (/usr/bin/tddp) on Archer AX90 V1. An unauthenticated adjacent-network attacker can exploit the setProductVer command handler to execute arbitrary operating system commands as root during device boot. Successful exploitation may result in complete device compromise through arbitrary command execution with root ...
CVE-2026-8618	New	7.7	HIGH				A stack-based buffer overflow vulnerability exists in the TDDPv2 service (/usr/bin/tddp) on Deco M9 Plus due to insufficient validation of decrypted request data length before it is copied into a fixed-size stack buffer in the subtype 0x91 handler. Successful exploitation may allow an adjacent, unauthenticated attacker to cause a denial of service or achieve arbitrary code e...
CVE-2026-103651	New	7.6	HIGH				MISP contains a vulnerability in its one-time password (OTP) authentication flow that allows replay of a consumed HOTP (paper) token and rewinding of the token counter. The HOTP verification logic compared the submitted token against a counter value that was cached in the user's session at the time the password was entered, rather than against the authoritative counter stor...
CVE-2026-55232	New	7.6	HIGH				Vvweb is a powerful and easy to use CMS with page builder to build websites, blogs or ecommerce stores. Prior to version 1.0.8.6, Vvweb's SSRF guard resolves a host with an IPv4-only function and never inspects IPv6, so any host that lacks an A record passes a private-range check. Editor oEmbed proxy fetches an attacker-supplied URL server side and reflects a response body, ...
CVE-2026-62059	New	7.6	HIGH				Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection') vulnerability in Ultimate Member Ultimate Member ultimate-member allows Blind SQL Injection.This issue affects Ultimate Member: from n/a through 2.13.1.
CVE-2026-62060	New	7.6	HIGH				Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection') vulnerability in captivateaudio Captivate Sync captivatesync-trade allows Blind SQL Injection.This issue affects Captivate Sync: from n/a through 3.3.2.
CVE-2026-97277	New	7.6	HIGH				Subscriber Broken Access Control in Social Boost <= 3.6.2 versions.
CVE-2026-97297	New	7.6	HIGH				Subscriber Broken Access Control in Gratification <= 4.6.3 versions.
CVE-2023-54404	New	7.5	HIGH				Zod schema-validation library through 4.6.5 contains an uncontrolled resource consumption vulnerability that allows attackers to exhaust memory by submitting a large array to an application using an array schema without a length constraint. Attackers can exploit the handleArrayResult parse logic in \$ZodArray, which accumulates every validation issue for each failing element ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2024-58388	New	7.5	HIGH				Sharp (and Toshiba Tec rebranded) multifunction printers contain an unauthenticated local file inclusion vulnerability that allows remote attackers to read arbitrary files by manipulating the path parameter in the installed_emanual_down.html endpoint. Attackers can supply directory traversal sequences such as path=/manual/../../../../<path> to access files outside the intended ...
CVE-2026-100514	New	7.5	HIGH				Unauthenticated Insecure Direct Object References (IDOR) in REST API Log <= 1.7.2 versions.
CVE-2026-100517	New	7.5	HIGH				Unauthenticated Insecure Direct Object References (IDOR) in Photo Reviews for WooCommerce <= 1.2.30 versions.
CVE-2026-102504	New	7.5	HIGH				Imager versions before 1.037 for Perl exit the process reading a raw image with an out-of-range raw_datachannels value in i_readraw_wiol. Nothing range-checks raw_datachannels. The line buffer is sized as the image width times the channel count with no overflow check, so a negative or very large count requests an excessive allocation. When it fails, Imager's allocator calls...
CVE-2026-103096	New	7.5	HIGH				API key is hardcoded and retrievable from the application package. Since Android applications can be reverse engineered, embedding sensitive API credentials directly in the client application may allow unauthorized users to extract and misuse the key.
CVE-2026-103097	New	7.5	HIGH				An API key is hardcoded and retrievable from the application package. Since Android applications can be reverse engineered, embedding sensitive API credentials directly in the client application may allow unauthorized users to extract and misuse the key.
CVE-2026-103098	New	7.5	HIGH				Transmission of a sensitive key in the URL over an unencrypted HTTP connection. The request is sent over HTTP rather than HTTPS, meaning the key is transmitted in plaintext across the network. An attacker with the ability to monitor network traffic could intercept the request and obtain the key
CVE-2026-103251	New	7.5	HIGH				n8n versions before 1.123.80, from 2.0.0 before 2.39.6, and from 2.40.0 before 2.40.1 contain a validation bypass vulnerability in the community package installation handler for queue mode deployments. Attackers with Redis write access can bypass name validation, permission checks, checksum verification, and npm safety checks to install arbitrary npm packages across all clus...
CVE-2026-103262	New	7.5	HIGH				Tornado versions before 6.5.9 contain an unbounded memory accumulation vulnerability in CurlAsyncHttpClient that allows remote attackers to cause denial of service by sending a compressed response. Attackers can send a gzip-encoded decompression bomb that accumulates in memory without size limits, causing the application process to be killed by out-of-memory conditions.
CVE-2026-103271	New	7.5	HIGH				Ghost versions from 4.0.0 before 6.63.0 contain a content API vulnerability that allows unauthenticated visitors to access gated post content. Attackers can bypass content restrictions by directly querying the content API to retrieve restricted posts without authentication.
CVE-2026-103761	New	7.5	HIGH				Mooncake transfer engine through 0.3.13.post1 contains a memory exhaustion vulnerability in TransferMetadata::receivePeerNotify that allows unauthenticated attackers to grow process memory without limit. Attackers can repeatedly send notify frames up to 1 MB to the handshake RPC port, filling the uncapped notifiys vector until the out-of-memory killer terminates the engine.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-12423	New	7.5	HIGH				A flaw was found in Foreman. The Red Hat Satellite /unattended/provision API endpoint is vulnerable to an authentication bypass due to a semantic logic flaw in host_verifier.rb. The application verifies the database state of a provisioning token rather than its actual presence in the incoming HTTP request. Because a host actively undergoing provisioning has an unexpired toke...
CVE-2026-46729	New	7.5	HIGH				NULL Pointer Dereference vulnerability in Apache HTTP Servers mod_heartmonitor over unicast listener. This issue affects Apache HTTP Server: from 2.4.0 through 2.4.68.
CVE-2026-47360	New	7.5	HIGH				Exposure of Sensitive Information to an Unauthorized Actor vulnerability in Apache HTTP Server's mod_session_cookie module. When SessionCookieRemove changes across internal redirects, the session cookie may still be passed to a backend server. This issue affects Apache HTTP Server: from 2.4.0 through 2.4.68.
CVE-2026-48005	New	7.5	HIGH				Missing authentication checks in mod_auth_digest in Apache Software Foundation Apache HTTP Server before 2.4.69 on all platforms allows an unauthenticated remote client to cause a denial of service (forced re-authentication) via forged Authorization headers when Digest authentication is enabled with AuthDigestNcCheck . Users are recommended to upgrade to version 2.4.69, whi...
CVE-2026-56153	New	7.5	HIGH				Out-of-bounds Write vulnerability in Apache HTTP Server's mod_charset_lite. This issue affects Apache HTTP Server: from 2.4.0 through 2.4.68.
CVE-2026-56449	New	7.5	HIGH				Out-of-bounds Write vulnerability in Apache HTTP Server's mod_proxy_html with crafted HTTP response bodies. This issue affects Apache HTTP Server: from 2.4.0 through 2.4.68.
CVE-2026-56661	New	7.5	HIGH				GetSimple CMS is a content management system (CMS), and GetSimple CMS CE is the community edition of that CMS. Prior to version 1.5, the update handler fetches a user-supplied URL with file_get_contents() after only format validation (FILTER_VALIDATE_URL) — there is no validation of the request destination. An attacker who can submit the form can make the server issue reques...
CVE-2026-59685	New	7.5	HIGH				Out-of-bounds Write vulnerability in Apache HTTP Server on Windows while processing paths with 8.3 names that may grow when expanded. This issue affects Apache HTTP Server: from 2.4.0 through 2.4.68.
CVE-2026-62073	New	7.5	HIGH				Unauthenticated Broken Access Control in WP Full Stripe Free <= 8.5.6 versions.
CVE-2026-63045	New	7.5	HIGH				Improper validation of FTP PASV reply address in mod_proxy_ftp in Apache Software Foundation Apache HTTP Server through 2.4.68 on all platforms allows, in forward proxy configurations, an untrusted FTP server to cause the proxy to open a data connection to an arbitrary third-party host via a crafted PASV response. Users are recommended to upgrade to version 2.4.69, which fi...
CVE-2026-63292	New	7.5	HIGH				Stack-based buffer overflow in mod_vhost_alias in Apache Software Foundation Apache HTTP Server through 2.4.68 on all platforms allows a remote client to cause a denial of service or potentially execute arbitrary code via an HTTP request with a Host header exceeding 8192 bytes when VirtualDocumentRoot uses a hostname format specifier and LimitRequestFieldSize is raised above...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-63686	New	7.5	HIGH				A NULL pointer dereference in mod_xml2enc in Apache Software Foundation Apache HTTP Server before 2.4.69 on all platforms allows an untrusted backend server to cause a denial of service via a proxied response with a charset whose conversion partially succeeds then fails. Users are recommended to upgrade to version 2.4.69, which fixes this issue.
CVE-2026-63718	New	7.5	HIGH				Inconsistent Interpretation of HTTP Requests ('HTTP Request/Response Smuggling') response smuggling vulnerability in Apache HTTP Server via mod_proxy_uwsgi and a crafted uwsgi response with Transfer-Encoding. This issue affects Apache HTTP Server: from 2.4.30 through 2.4.68.
CVE-2026-64947	New	7.5	HIGH				A chained CSRF bypass and unrestricted file upload vulnerability in the Plugin File Manager allows an attacker to upload and execute arbitrary PHP code, resulting in Remote Code Execution. This issue affects Pandora FMS: from 777 onwards.
CVE-2026-68495	New	7.5	HIGH				The CBOR parser in FasterXML jackson-dataformats-binary never invokes StreamReadConstraints.validateNameLength() when decoding JSON object property names, so the maxNameLength limit is not enforced for this format. CBORParser._decodeLongerName() decodes a definite-length property name with no length check, and CBORParser._decodeChunkedName() delegates to the value-oriented _...
CVE-2026-68496	New	7.5	HIGH				The Smile parser in FasterXML jackson-dataformats-binary never invokes StreamReadConstraints.validateNameLength() when decoding JSON object property names, so the maxNameLength limit is not enforced for this format. SmileParser._handleLongFieldName() grows its internal name buffer through an unconstrained _growArrayTo() call and performs no length validation. An attacker who...
CVE-2026-79896	New	7.5	HIGH				Fortra BoKS Manager contains an out-of-bounds read vulnerability in the custom TLS ClientHello parser used by boks_portmux. A remote unauthenticated attacker can submit a malformed ClientHello and terminate boks_portmux. Although the daemon is normally restarted automatically, repeated requests can sustain the service interruption.
CVE-2026-86344	New	7.5	HIGH				A flaw was found in 389-ds-base. An unauthenticated remote attacker can send a complete LDAP operation followed by the first bytes of an incomplete LDAPMessage on the same connection, causing the server to hand that connection to a second worker thread before the first worker's result is flushed. The second worker blocks until nsslapd-ioblocktimeout while holding the connect...
CVE-2026-92174	New	7.5	HIGH				The SiteOrigin Widgets Bundle plugin for WordPress is vulnerable to Local File Inclusion in all versions up to, and including, 1.73.2 via the 'theme' parameter parameter. This makes it possible for authenticated attackers, with contributor-level access and above, to include and execute arbitrary .php files on the server, allowing the execution of any PHP code in those files....
CVE-2026-93882	New	7.5	HIGH				The LearnPress – WordPress LMS Plugin for Create and Sell Online Courses plugin for WordPress is vulnerable to Insecure Direct Object Reference in versions up to, and including, 4.4.8 via the CourseMaterialTemplate::render_material_items() callback exposed on the public lp-ajax-handle (load_content_via_ajax) endpoint. The endpoint is explicitly listed in the AbstractAjax no-...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-103921	New	7.4	HIGH				GraphQL Tools provides utilities for building, stitching, and mocking GraphQL schemas. Prior to 1.1.35, the <code>executor-legacy-ws buildWSLegacyExecutor()</code> function hardcodes TLS certificate rejection off for Node.js connections to <code>wss://</code> endpoints. Applications using the executor directly, or <code>url-loader</code> with <code>SubscriptionProtocol.LEGACY_WS</code> , can therefore accept an attacker-contro...
CVE-2026-15911	New	7.4	HIGH				Confluent Kafka Python client's HashiCorp Vault KMS integration could allow a remote attacker to obtain sensitive information due to improper TLS certificate validation.
CVE-2026-64946	New	7.4	HIGH				A chained CSRF and unrestricted SVG file upload vulnerability in the File Manager module allows stored Cross-Site Scripting, enabling session cookie exfiltration and administrator account takeover. This issue affects Pandora FMS: from 777 onwards.
CVE-2026-67105	New	7.4	HIGH				HCL BigFix Service Management is affected by an Insecure Communication vulnerability, which could allow an attacker with internal network access to intercept unencrypted HTTP traffic between backend services, enabling the extraction of sensitive data and potential man-in-the-middle (MitM) attacks.
CVE-2026-104120	New	7.3	HIGH				A security vulnerability has been detected in <code>modelcontextprotocol mcp-server-fetch</code> and <code>mcp-server-everything</code> up to 2026.6.4. Affected is the function <code>fetch_url</code> of the file <code>mcp_server_fetch/server.py</code> of the component Fetch Tool. The manipulation of the argument <code>url/path</code> leads to server-side request forgery. The attack may be initiated remotely. The exploit has been disclosed...
CVE-2026-104123	New	7.3	HIGH				A vulnerability was detected in SourceCodester Online Reviewer Management System 1.0. Affected by this vulnerability is an unknown functionality of the file <code>/reviewer_0/admins/assessments/activities/btn_functions.php?action=activity</code> . The manipulation of the argument <code>Title</code> results in sql injection. The attack may be launched remotely. The exploit is now public and may be used.
CVE-2026-64893	New	7.3	HIGH				- Cleartext Transmission of Sensitive Information vulnerability in Johnson Controls EasyIO NEO allows - Man In the Middle Attack. This issue affects EasyIO NEO: before 3.3b25.
CVE-2026-73637	New	7.3	HIGH				Use after free in <code>mod_auth_digest</code> in Apache Software Foundation Apache HTTP Server before 2.4.69 on all platforms allows an unauthenticated remote client to cause authentication state corruption via concurrent Digest authentication requests when <code>AuthDigestNcCheck</code> is enabled or <code>AuthDigestNonceLifetime</code> is set to 0. Users are recommended to upgrade to version 2.4.69, which fix...
CVE-2026-10026	New	7.2	HIGH				The CTX Feed Pro plugin for WordPress is vulnerable to Code Injection in all versions up to, and including, 7.6.12. This is due to insufficient input validation on the 'Feed Config' field which is passed directly to the <code>eval()</code> function. This makes it possible for authenticated attackers, with Administrator-level access and above, to execute arbitrary PHP code on the server.
CVE-2026-102565	New	7.2	HIGH				The BA Book Everything plugin for WordPress is vulnerable to Stored Cross-Site Scripting via the <code>'booking_service_qty'</code> parameter in all versions up to, and including, 1.8.28 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts in pages that will execute whenever a user accesses an inj...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-103082	New	7.2	HIGH				Server-Side Request Forgery (SSRF) vulnerability in LA-Studio LA-Studio Element Kit for Elementor lastudio-element-kit allows Server Side Request Forgery.This issue affects LA-Studio Element Kit for Elementor: from n/a through 1.6.2.
CVE-2026-103490	New	7.2	HIGH				In JetBrains YouTrack before 2026.2.19422 privilege escalation was possible via user group links
CVE-2026-103766	New	7.2	HIGH				ClipBucket v5 through 5.5.3-#197 contains an sql injection vulnerability that allows authenticated users with ad_manager_access permission to inject SQL via the delete parameter in admin_area/ads_manager.php. Attackers can supply time-based blind payloads concatenated into AdsManager::DeleteAd queries to extract user credentials and emails or modify and delete arbitrary reco...
CVE-2026-14995	New	7.2	HIGH				The Autooptimize plugin for WordPress is vulnerable to Stored Cross-Site Scripting via REQUEST_URI Path in all versions up to, and including, 3.1.15.1 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts in pages that will execute whenever a user accesses an injected page. Exploitation...
CVE-2026-34493	New	7.2	HIGH				- On-Chip Debug Interface vulnerability in Johnson Controls EasyIO FS32 allows Collect Data from Common Resource Locations. This issue affects EasyIO FS32: before 3.3b63.
CVE-2026-34494	New	7.2	HIGH				- On-Chip Debug Interface vulnerability in Johnson Controls Neo Series MVP2 allows Collect Data from Common Resource Locations. This issue affects Neo Series MVP2: before 3.3b63.
CVE-2026-53964	New	7.2	HIGH				Document Merge Service is a document template merge service providing an API to manage templates and merge them with given data. Prior to version 9.1.0, a remote code execution (RCE) via server-side template injection (SSTI) allows for user supplied code to be executed in the server's context where it is executed as the document-merge-server user with the UID 901 thus giving...
CVE-2026-55231	New	7.2	HIGH				Vvweb is a powerful and easy to use CMS with page builder to build websites, blogs or ecommerce stores. Prior to version 1.0.8.6, a flawed central path sanitizer lets an authenticated admin-panel user who holds backup access (default role site_admin or higher) read and delete arbitrary files on a server. An attacker can recover database credentials from config/db.php, read h...
CVE-2026-56589	New	7.2	HIGH				HCL BigFix Service Management is affected by a Stored Cross-Site Scripting (XSS) vulnerability, which could allow an attacker to inject and store malicious scripts within the application that execute when a victim views the affected page, enabling session hijacking and the theft of sensitive data.
CVE-2026-71452	New	7.2	HIGH				- OS Command Injection vulnerability in Johnson Controls EasyIO FS32 allows OS Command Injection. This issue affects EasyIO FS32: before 3.0b63.
CVE-2026-75786	New	7.2	HIGH				Unsanitized concatenation of the module parameter in the Grafana datasource endpoint allows authenticated blind SQL injection. Affects Pandora FMS from 777 onwards.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-85235	New	7.2	HIGH				The Forminator Forms – Contact Form, Payment Form & Custom Form Builder plugin for WordPress is vulnerable to Stored Cross-Site Scripting via Rich-Text Textarea Field in all versions up to, and including, 1.57.2 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts in pages that will e...
CVE-2026-90438	New	7.2	HIGH				The Ninja Forms – The Contact Form Builder That Grows With You plugin for WordPress is vulnerable to Stored Cross-Site Scripting via Paragraph Text (RTE) Field Submission in all versions up to, and including, 3.15.4 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts in pages that wi...
CVE-2026-92144	New	7.2	HIGH				The Forminator Forms – Contact Form, Payment Form & Custom Form Builder plugin for WordPress is vulnerable to Stored Cross-Site Scripting via 'postdata-1[post-custom]' Parameter in all versions up to, and including, 1.57.2 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts in pages ...
CVE-2026-92244	New	7.2	HIGH				The PDF Invoices & Packing Slips for WooCommerce plugin for WordPress is vulnerable to Stored Cross-Site Scripting via Billing First Name / Last Name / Company Fields in all versions up to, and including, 5.16.1 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts in pages that will e...
CVE-2026-93367	New	7.2	HIGH				The Visitors Traffic Real Time Statistics Pro plugin for WordPress is vulnerable to unauthenticated stored Cross-Site Scripting in all versions up to, and including, 11.22 via the page_title parameter of the ahcpro_track_visitor AJAX action. The action is registered for logged-out callers (wp_ajax_nopriv_ahcpro_track_visitor) and stores \$_POST['page_title'] with NO sanitizat...
CVE-2026-94390	New	7.2	HIGH				Editor PHP Object Injection in Hide Shipping Method For WooCommerce <= 1.5.4 versions.
CVE-2026-96573	New	7.2	HIGH				The Appointment Hour Booking – Booking Calendar plugin for WordPress is vulnerable to Stored DOM-Based Cross-Site Scripting via Booking Form Single-Line Field via Schedule Calendar List Renderer in all versions up to, and including, 1.5.97 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web ...
CVE-2026-96813	New	7.2	HIGH				The Form Maker by 10Web – Mobile-Friendly Drag & Drop Contact Form Builder plugin for WordPress is vulnerable to Stored Cross-Site Scripting via Mark on Map Longitude/Latitude Fields in all versions up to, and including, 1.15.47 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts in ...
CVE-2026-97661	New	7.2	HIGH				The Business Essentials for Contact Form 7 plugin for WordPress is vulnerable to Stored Cross-Site Scripting via 'gateway' Form Field in all versions up to, and including, 1.2.1 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts in pages that will execute whenever a user accesses an...
CVE-2026-102378	New	7.1	HIGH				Unauthenticated Cross Site Scripting (XSS) in Parallax Section block <= 2.0.4 versions.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-103248	New	7.1	HIGH				n8n versions before 1.123.80, from 2.0.0 before 2.39.6, and from 2.40.0 before 2.40.1 contain a filter injection vulnerability in the Supabase node's Filters (String) mode that fails to escape field values. Attackers can inject filter expressions from untrusted input to read all table rows, update all records, or delete entire tables in a single request.
CVE-2026-103252	New	7.1	HIGH				n8n versions before 1.123.80, from 2.0.0 before 2.39.6, and from 2.40.0 before 2.40.1 contain an authorization bypass vulnerability in the credential test endpoint that resolves project-scoped variables without validating caller access. Attackers can specify an arbitrary project ID in the request body to interpolate sensitive variables into credential test requests sent to a...
CVE-2026-103255	New	7.1	HIGH				n8n versions before 1.123.80, from 2.0.0 before 2.39.6, and from 2.40.0 before 2.40.1 contain a path traversal vulnerability in the Supabase node where the tableId parameter is inserted into request paths without validation. Attackers can exploit workflows binding tableId to untrusted input to traverse to Auth and Storage APIs using the administrative serviceRole key, bypass...
CVE-2026-103256	New	7.1	HIGH				n8n versions before 2.39.6 and 2.40.0 before 2.40.1 contain a credentials leak vulnerability in the Wekan and Baserow username-and-password credentials that sends unencrypted passwords to unvalidated hosts. Attackers with credential update permissions can modify the host field to receive account passwords at arbitrary hosts, bypassing domain validation controls.
CVE-2026-103266	New	7.1	HIGH				Ghost versions 5.2.0 through versions prior to 6.62.0 allow a remote attacker, without authentication, to abuse the Stripe Checkout flow to attach a paid subscription to an existing member, modify that member's name, and inject content into newsletters sent to the member. Depending on the recipient's email client, the injected content may be rendered, resulting in HTML injec...
CVE-2026-103288	New	7.1	HIGH				Ghost, an open-source publishing platform, contains an input validation flaw in its comment like feature in versions from 5.9.0 before 6.44.1. An authenticated member can delete comment likes or dislikes belonging to other users that they are not authorized to delete, resulting in an authorization bypass and unauthorized modification of comment engagement data.
CVE-2026-103289	New	7.1	HIGH				Ghost from 5.9.0 before 6.44.1 contains an input validation issue in the comments feature that allows authenticated members to access comments they are not authorized to view, resulting in disclosure of restricted comment data.
CVE-2026-103488	New	7.1	HIGH				In JetBrains YouTrack before 2026.2.19422 missing authorisation allowed authenticated users to add themselves to project teams and access restricted issues
CVE-2026-103659	New	7.1	HIGH				MISP contains an authorization bypass in the event flattening feature. When a user requests an event with the flatten option enabled, the application removes the Object containment from the query and returns object attributes as top-level event attributes. In doing so, the object-level distribution and sharing-group access control check was not re-applied to those attributes...
CVE-2026-14983	New	7.1	HIGH				Missing authentication in the web interface in Teledyne FLIR Aware2 versions through 6.9.0.2 allows remote unauthenticated attackers to achieve denial of service against Teledyne FLIR PackBot robots running this software via misuse of the reboot endpoint.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-64948	New	7.1	HIGH				Missing authorization in module data retrieval allows unauthorized cross-group access to module history. Affects Pandora FMS from 777 onwards.
CVE-2026-71426	New	7.1	HIGH				GetSimple CMS is a content management system (CMS), and GetSimple CMS CE is the community edition of that CMS. In versions 3.3.22 and prior, an authenticated user with page-editing rights can store an arbitrary filesystem path in a page's template attribute. On the public front-end, this value is passed unsanitized to a PHP include() when the page is rendered. Because the in...
CVE-2026-73976	New	7.1	HIGH				djehuty is a research data repository system developed by 4TU.ResearchData. Prior to version 26.3.2, An unauthenticated attacker can inject SPARQL into the search/listing queries through three separate parameters. Because the affected queries are read (SELECT) queries, this does not write to the store, but it allows: Cross-graph data exfiltration — e.g. UNION-ing in triples ...
CVE-2026-78578	New	7.1	HIGH				Tapo C120 v1 and C200 v5 do not enforce authentication for do method HTTPS onboarding connect actions after initial setup. An unauthenticated adjacent attacker can submit unauthorized wireless configuration parameters, causing the camera to attempt connection to a different network. Successful exploitation disconnects the camera from its intended wireless network, maki...
CVE-2026-82357	New	7.1	HIGH				RT-Labs AB C-Open CANopen contains a NULL pointer dereference if the LSS protocol is used to configure the device. An object defined by the user application may not have all required subindexes for object 0x1018. An unauthenticated, remote attacker with access to the CAN bus, through a compromised node for instance, can initiate the LSS protocol on a device with a misconfigu...
CVE-2026-82358	New	7.1	HIGH				RT-Labs AB C-Open CANopen contains a write protection bypass in the SDO (Service Data Object) server implementation 'src/co_sdo_server.c' that fails to properly validate write permissions when processing download-segment frames. An unauthenticated attacker on the CAN bus can initiate an SDO upload for a read-only Object Dictionary (OD) entry, which sets a data pointer to the...
CVE-2026-9032	New	7.1	HIGH				Tapo C120 v1 and C200 v5 contain a NULL pointer dereference in the HTTPS onboarding connect request parser. The interface is reachable without authentication after initial setup and does not validate that a password field is present for certain authentication and encryption parameter combinations, allowing a malformed request from the same local network to crash the HTTPS s...
CVE-2026-96577	New	7.1	HIGH				A flaw was found in oc-mirror. During mirroring operations, the embedded local cache registry binds to all network interfaces without authentication or encryption instead of restricting access to the local system. An unauthenticated attacker on an adjacent network can connect to the exposed service to push tampered container images, delete cached images, or access mirrored c...
CVE-2026-97260	New	7.1	HIGH				Unauthenticated Cross Site Scripting (XSS) in MaxGalleria <= 6.5.3 versions.
CVE-2026-97268	New	7.1	HIGH				Unauthenticated Cross Site Scripting (XSS) in Premmerce Wishlist for WooCommerce <= 1.1.13 versions.
CVE-2026-97273	New	7.1	HIGH				Unauthenticated Cross Site Scripting (XSS) in Premmerce Wishlist for WooCommerce <= 1.1.13 versions.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-103253	New	7.0	HIGH				n8n versions before 1.123.80, from 2.0.0 before 2.39.6, and from 2.40.0 before 2.40.1 contain an SQL injection vulnerability in the Oracle Database node's Delete Table Drop operation. Attackers can inject single quotes in the table or schema fields to append arbitrary SQL statements and execute DDL or DML commands against the connected database with the credential's privileges.
CVE-2026-100251	New	6.9	MEDI				Wormhole.app as deployed before 2026-08-22 misconfigures the coturn TURN server and does not properly restrict TCP relay peers, allowing an unauthenticated attacker to access instance metadata or to source TCP connections from the Wormhole relay's IP.
CVE-2026-102666	New	6.9	MEDI				The Joyland AI app contains hard-coded credentials for the GeTui push notification service, allowing an attacker to access the GeTui REST API and send push notifications containing arbitrary content to any user, group of users, or all users of the app at once.
CVE-2026-102668	New	6.9	MEDI				The Joyland AI app accepts any TLS certificates from any server without validation.
CVE-2026-102669	New	6.9	MEDI				Joyland AI app does not verify hostnames, allowing a malicious host to connect or intercept chat messages.
CVE-2026-102671	New	6.9	MEDI				The Joyland AI app accepts invalid SSL certificates in the invisible advertisement WebView by default.
CVE-2026-103245	New	6.9	MEDI				n8n versions before 1.123.80, from 2.0.0 before 2.39.6, and from 2.40.0 before 2.40.1 fail to verify the x-webflow-signature HMAC in the Webflow Trigger node webhook handler. Unauthenticated attackers can send forged webhook requests with attacker-controlled payloads to trigger workflows and manipulate downstream actions like record creation or API calls.
CVE-2026-103249	New	6.9	MEDI				n8n versions before 1.123.80, from 2.0.0 before 2.39.6, and from 2.40.0 before 2.40.1 contain a stored DOM cross-site scripting vulnerability in Resource Locator parameter dropdown link handling. Workflow authors can inject malicious script URLs that execute arbitrary JavaScript in the editor origin when other users open the node dropdown and click the external-link icon, wi...
CVE-2026-103261	New	6.9	MEDI				Tornado before 6.5.9 fails to limit the number of query string fields in HTTPServerRequest.__init__, allowing remote attackers to cause event-loop stalling by sending requests with thousands of query parameters. Attackers can send unauthenticated GET requests with unbounded query-string field counts to degrade response times for all clients sharing the same IOLoop.
CVE-2026-103269	New	6.9	MEDI				Ghost versions 5.3.0 before 6.62.0 contain a missing authorization vulnerability that allows an authenticated site member to read the excerpts of posts they do not have access to (gated content).
CVE-2026-103274	New	6.9	MEDI				Ghost versions 5.3.0 before 6.58.0 fail to properly enforce access controls on comments in private mode. Unauthenticated visitors can read comments that should be restricted, bypassing privacy settings.
CVE-2026-103276	New	6.9	MEDI				Ghost versions before 6.20.0 contain a file extension filtering bypass vulnerability that allows unauthenticated attackers to read theme templates and metadata. Attackers can use URL encoding to bypass extension validation and access sensitive theme files.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-103280	New	6.9	MEDI				Ghost from version 0.8.0 before 6.23.0 contains an information disclosure vulnerability in its setup endpoint: the endpoint responds to unauthenticated requests with the site owner's email address, allowing any remote visitor to obtain it.
CVE-2026-103505	New	6.9	MEDI				Improper neutralization of argument delimiters in the volume handling component in AWS EFS CSI Driver (aws-efs-csi-driver) v3.1.0 through v3.4.2 might allow remote authenticated users with PersistentVolume creation permissions to inject arbitrary mount options via comma-separated values in the mounttargetipmap volumeAttribute. To remediate this issue, users should upgrade...
CVE-2026-21140	New	6.9	MEDI				Improper access control in ManagedProvisioning prior to SMR Sep-2026 Release 1 allows local attackers to install arbitrary applications.
CVE-2026-97662	New	6.9	MEDI				An argument injection issue in the diff scan operation in AWS security-agent-mcp-server before version 0.2.0 might allow context-dependent threat actors to create, overwrite, or truncate arbitrary files on the host outside the intended workspace directory via a crafted reference value supplied to the diff scan operation. To remediate this issue, users should upgrade to ve...
CVE-2025-71427	New	6.8	MEDI				Office-PowerPoint-MCP-Server through 2.0.7 contains a path traversal vulnerability that allows MCP callers to write and read files outside the working directory by supplying absolute paths or ../ sequences. Attackers can steer an AI agent via prompt injection to abuse save_presentation, open_presentation, or manage_image output_path to overwrite any server-writable file or l...
CVE-2026-103258	New	6.8	MEDI				n8n versions before 2.39.6 and 2.40.0 before 2.40.1 contain an unescaped parameter interpolation vulnerability in SendGrid, Freshservice, and ServiceNow nodes that allows attackers to bypass filters by breaking out of query literals. Attackers can exploit this by binding vulnerable node parameters to untrusted external input to widen single-record lookups into match-all quer...
CVE-2026-103279	New	6.8	MEDI				Ghost versions from 3.10.0 before 6.34.0 fail to fully invalidate all sessions after a password change. Attackers with a stolen session cookie can maintain access to user accounts even after the associated user changes their password.
CVE-2026-78249	New	6.8	MEDI				A path traversal vulnerability exists in the web management interface of multiple Multifunction Devices and Printers, including Apeos C4571 1.1.3 and earlier, Apeos C3567 1.1.3, or other products listed, specifically in the handling of externally supplied parameters. If the device receives a specially crafted, malicious request, it may trigger unintended processing.
CVE-2026-12545	New	6.7	MEDI				A flaw was found in rubygem-hammer_cli. A command injection vulnerability exists in Hammer CLI and the Railties (Ruby on Rails) component distributed with Satellite due to the insecure interpolation of the \$EDITOR environment variable into the Ruby system() method. By passing a single interpolated string to system(), the application invokes a system shell (/bin/sh) that inte...
CVE-2026-103494	New	6.6	MEDI			jetbrains:youtrack	In JetBrains YouTrack before 2026.2.19422 privilege escalation was possible via user group membership changes

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-101889	New	6.5	MEDI				The Prime Mover plugin for WordPress before 2.2.1 contains a path traversal vulnerability that allows authenticated administrators to delete arbitrary directories by importing a crafted WPRIME/TAR package with manipulated tar_root_folder values in wprime-config.json. Attackers can exploit insufficient path validation in computeExtractVariables() and validateImportedSiteVsPac...
CVE-2026-102394	New	6.5	MEDI				Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting') vulnerability in WPDeveloper Essential Addons for Elementor essential-addons-for-elementor-lite allows Stored XSS.This issue affects Essential Addons for Elementor: from n/a through 6.8.4.
CVE-2026-103063	New	6.5	MEDI				Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting') vulnerability in Wpmet ElementsKit Elementor addons Lite elementskit-lite allows Stored XSS.This issue affects ElementsKit Elementor addons Lite: from n/a through 4.0.6.
CVE-2026-103064	New	6.5	MEDI				Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting') vulnerability in Wpmet ElementsKit Elementor addons Lite elementskit-lite allows Stored XSS.This issue affects ElementsKit Elementor addons Lite: from n/a through 4.0.6.
CVE-2026-103339	New	6.5	MEDI				Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting') vulnerability in Wpmet Metform metform allows Stored XSS.This issue affects Metform: from n/a through 4.3.0.
CVE-2026-103343	New	6.5	MEDI				Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting') vulnerability in WP ManageNinja LLC FluentForm fluentform allows Stored XSS.This issue affects FluentForm: from n/a through 6.2.14.
CVE-2026-103491	New	6.5	MEDI			jetbrains:youtrack	In JetBrains YouTrack before 2026.2.19422 iDOR in the issue activities API allowed reading restricted issues
CVE-2026-103492	New	6.5	MEDI			jetbrains:youtrack	In JetBrains YouTrack before 2026.2.19422 doS attack was possible via crafted PSD attachments
CVE-2026-103679	New	6.5	MEDI				A flaw was found in tnef. A remote attacker could exploit this vulnerability by providing a specially crafted Transport Neutral Encapsulation Format (TNEF) file containing multiple message bodies. During extraction, improper memory management triggers a use-after-free and double-free condition, causing the application to crash and resulting in a Denial of Service (DoS).
CVE-2026-103884	New	6.5	MEDI				A flaw was found in the X.509 client certificate authenticator of Keycloak. When CRL Distribution Point checking is enabled, the server fails to properly validate the file paths provided in a client certificate. An attacker can provide a specially crafted certificate that causes the server to attempt to read sensitive files from the local system or exhaust memory by loading ...
CVE-2026-55251	New	6.5	MEDI				NetBox Device Type Library is a collection of community-sourced device type definitions for import into NetBox. Prior to commit f41fc1e, the CI workflow .github/workflows/validation.yml runs on pull_request and executes code supplied by the pull request before any maintainer review. Three PR-editable files drive this: "requirements.txt", ".pre-commit-hooks-config.yaml" / ".p...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-56097	New	6.5	MEDI				A flaw was found in rubygem-katello. An SQL injection vulnerability exists in the Red Hat Satellite Katello Registry Proxy. The application fails to sanitize input parameters used in database queries within the RegistryProxiesController. The methods check_blob_push_org_label and get_matching_products_from_org take user-supplied labels directly from the request path and inter...
CVE-2026-79900	New	6.5	MEDI				boks_ksllgsd accepts a checksum algorithm name in the MD field of an authenticated KSL start message. Affected releases verify that OpenSSL recognizes the digest name but do not verify that the value fits in a fixed 16-byte checksum context field before copying it. An authenticated KSL client can supply an oversized, OpenSSL-recognized digest name and write beyond the end o...
CVE-2026-84740	New	6.5	MEDI				The Events Calendar WordPress plugin before 6.17.5.1 does not validate or sanitise data submitted to an unauthenticated AJAX action before merging it into its rendering context, allowing unauthenticated users to execute arbitrary shortcodes registered on the site.
CVE-2026-97251	New	6.5	MEDI				Unauthenticated Insecure Direct Object References (IDOR) in Bus Ticket Booking with Seat Reservation <= 5.9.3 versions.
CVE-2026-97258	New	6.5	MEDI				Subscriber Broken Access Control in Aruba Migration Tool <= 1.0.4 versions.
CVE-2026-97269	New	6.5	MEDI				Unauthenticated Insecure Direct Object References (IDOR) in WPFunnels <= 3.13.1 versions.
CVE-2026-97280	New	6.5	MEDI				Missing Authorization vulnerability in Mamunur Rashid Review Schema review-schema allows Exploiting Incorrectly Configured Access Control Security Levels. This issue affects Review Schema: 3.1.0.
CVE-2026-101925	New	6.4	MEDI				The bbp style pack plugin for WordPress is vulnerable to Stored Cross-Site Scripting via the 'display_name (via /wp-admin/profile.php) + bbp_reply_content (via bbPress reply form)' parameter in all versions up to, and including, 6.4.8 due to insufficient input sanitization and output escaping. This makes it possible for authenticated attackers, with subscriber-level access a...
CVE-2026-103291	New	6.4	MEDI				Ghost versions from 3.20.2 before 6.51.0 contain a server-side request forgery vulnerability in image dimension refetching that allows authenticated staff users to trigger outbound HTTP requests to arbitrary URLs. Attackers can point image cards at attacker-controlled hosts or internal network endpoints to access metadata services and internal resources unavailable from the ...
CVE-2026-89424	New	6.4	MEDI				The Duplicate Post plugin for WordPress is vulnerable to Stored Cross-Site Scripting via the 'noti_token' parameter in all versions up to, and including, 1.5.6 due to insufficient input sanitization and output escaping. This makes it possible for authenticated attackers, with subscriber-level access and above, to inject arbitrary web scripts in pages that will execute whenever...
CVE-2026-90992	New	6.4	MEDI				The Redux Framework plugin for WordPress is vulnerable to Stored Cross-Site Scripting via User Meta Merge via 'user-mediaurl' Media Field in all versions up to, and including, 4.5.14 due to insufficient input sanitization and output escaping. This makes it possible for authenticated attackers, with Subscriber-level access and above, to inject arbitrary web scripts in pages t...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-94212	New	6.4	MEDI				Improper verification of cryptographic signature vulnerability in Apache APISIX. Any unauthenticated attacker could impersonate any user on every route protected by the saml-auth plugin under default configuration. This issue affects Apache APISIX: from 3.17.0 through 3.18.0. Users are recommended to upgrade to version 3.19.0, which fixes the issue.
CVE-2026-96256	New	6.4	MEDI				The Gutenberg Essential Blocks – Page Builder for Gutenberg Blocks & Patterns plugin for WordPress is vulnerable to Stored Cross-Site Scripting via the Google Map block's 'marker' attribute in versions up to, and including, 6.4.5 This is due to insufficient input sanitization and output escaping on marker title/content values, which are stored as JSON and then decoded and co...
CVE-2026-96268	New	6.4	MEDI				The Awesome Support – WordPress HelpDesk & Support Plugin plugin for WordPress is vulnerable to Stored Cross-Site Scripting via the 'gdpr-data' parameter in all versions up to, and including, 6.4.0 due to insufficient input sanitization and output escaping. This makes it possible for authenticated attackers, with subscriber-level access and above, to inject arbitrary web scr...
CVE-2026-102505	New	6.3	MEDI				Imager versions before 1.037 for Perl overflow a heap buffer fetching float samples from a paletted image in i_gsampf_fp. For a paletted image, getsamples() with type "float" allocates a buffer of one sample per pixel and fetches every requested channel of each pixel into it. Requesting more than one channel writes past its end. An attacker-supplied image controls the over...
CVE-2026-103004	New	6.3	MEDI				Next.js versions from 16.3.0 to 16.3.7 warm `use cache` handlers using `next/root-params` and can leak their return value to pages with different root params. With Cache Components enabled (cacheComponents: true), a 'use cache' function that calls another 'use cache' function that reads a root param can be keyed incorrectly when the inner call is served from an existing entr...
CVE-2026-103254	New	6.3	MEDI				n8n versions before 1.123.80, from 2.0.0 before 2.39.6, and from 2.40.0 before 2.40.1 contain a path traversal vulnerability in signed resume URL generation for Send-and-Wait approvals. Attackers with workflow creation permissions can mint valid approval URLs for gates in projects they cannot access by exploiting unresolved traversal sequences in caller-controlled node IDs, ...
CVE-2026-103260	New	6.3	MEDI				n8n versions before 2.39.6 and 2.40.0 before 2.40.1 contain an approval bypass vulnerability in the Send and Wait node's Approve Within Chat mode. Attackers can submit resume requests without verification of the requester's identity or approval permissions, allowing unauthenticated users to advance waiting executions and trigger guarded actions.
CVE-2026-104052	New	6.3	MEDI				A vulnerability was determined in itsourcecode Pet Shop Management System 1.0. The affected element is an unknown function of the file admin_reject_completed.php. This manipulation of the argument ID causes sql injection. It is possible to initiate the attack remotely. The exploit has been publicly disclosed and may be utilized.
CVE-2026-104053	New	6.3	MEDI				A vulnerability was identified in itsourcecode Pet Shop Management System 1.0. The impacted element is an unknown function of the file admin_reservefilter.php. Such manipulation of the argument filter leads to sql injection. It is possible to launch the attack remotely. The exploit is publicly available and might be used.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-104054	New	6.3	MEDI				A security flaw has been discovered in calcom cal.diy up to 6.2.0. This affects the function doesUserIdHaveAccessToBooking of the file BookingAccessService.ts of the component PBAC Permission Engine. Performing a manipulation results in missing authorization. The attack can be initiated remotely. The exploit has been released to the public and may be used for attacks. The pu...
CVE-2026-64892	New	6.3	MEDI				- Exposure of Sensitive Information vulnerability in Johnson Controls Easy IO Neo allows Collect Data from Common Resource Locations. This issue affects Easy IO Neo: before 3.3b63.
CVE-2026-94269	New	6.3	MEDI				Use of Non-Canonical URL paths for authorization decisions vulnerability in Apache APISIX. In some configurations where a permissive route overlaps a protected one, a crafted encoded path can reach an upstream endpoint that the matched route's policies were never meant to cover. A request that should have been rejected is served instead, giving unauthenticated access to a...
CVE-2026-97281	New	6.3	MEDI				Subscriber Broken Access Control in WP Project Manager <= 4.0.7 versions.
CVE-2026-104182	New	6.2	MEDI				stream-json is a micro-library of stream components for processing JSON and JSONC with a minimal memory footprint. Prior to 3.6.0, the JSONC parser at stream-json/jsonc/parser.js and verifier at stream-json/jsonc/verifier.js restart comment-terminator scanning from the opening slash whenever a block or line comment spans an input chunk, while retaining the accumulated commen...
CVE-2026-100179	New	6.1	MEDI				The Calculated Fields Form – AI Form Builder for WordPress – Contact, Payment, Quote, Quiz & More plugin for WordPress is vulnerable to Reflected DOM-Based Cross-Site Scripting via the 'x (any URL parameter consumed by the form's calculated equation)' parameter in all versions up to, and including, 5.5.1.3 due to insufficient input sanitization and output escaping. This make...
CVE-2026-19902	New	6.1	MEDI				The Ad Inserter – Ad Manager & AdSense Ads plugin for WordPress is vulnerable to Reflected Cross-Site Scripting via the Referer header in all versions up to, and including, 2.8.18 due to insufficient input sanitization and output escaping on the '{search-query}' dynamic tag. When an ad block's code contains that tag, replace_ai_tags() reads \$_SERVER['HTTP_REFERER'] and tests...
CVE-2026-83589	New	6.1	MEDI				A flaw was found in oauth-proxy. The application fails to properly validate the destination redirect parameter ('rd') during post-login redirection. A remote attacker can exploit this vulnerability by enticing a user to follow a specially crafted link, resulting in the user being redirected to an arbitrary external website after authenticating. This open redirect can be leve...
CVE-2026-84925	New	6.1	MEDI				The Avada Website Builder For WordPress & WooCommerce theme for WordPress is vulnerable to Reflected Cross-Site Scripting via the 'lang' parameter in all versions up to, and including, 7.16.1 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts in pages that execute if they can succ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-89047	New	6.1	MEDI				The Social Media Share Buttons & Social Sharing Icons plugin for WordPress is vulnerable to Reflected Cross-Site Scripting via URL in all versions up to, and including, 3.0.1 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts in pages that will execute whenever a user accesses an in...
CVE-2026-89427	New	6.1	MEDI				The Ad Inserter – Ad Manager & AdSense Ads plugin for WordPress is vulnerable to Reflected Cross-Site Scripting via 's' Search Parameter in all versions up to, and including, 2.8.18 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts in pages that execute if they can successfully tri...
CVE-2026-104002	New	6.0	MEDI				A fail-open error handling issue within the data masking utility of Powertools for AWS Lambda (Python) might allow actors to read sensitive field values that the application intended to mask. To remediate this issue, users should upgrade to version 3.35.0.
CVE-2026-103754	New	5.9	MEDI				A flaw was found in ansible-runner. The unstream_dir() function, which receives and extracts a streamed zip archive on the worker side of the ansible-runner transmit/worker protocol, re-creates symbolic links from archive content without validating the link target and applies chmod() and utime() to an unsanitized filesystem path derived from the archive member name. A crafte...
CVE-2026-103760	New	5.9	MEDI				Mooncake transfer engine through 0.3.13.post1 contains a denial of service vulnerability that allows unauthenticated remote attackers to block the handshake daemon by never reading replies. Attackers can send a Metadata request to the handshake RPC port and stall SocketHandShakePlugin's single listener thread in writeFully(), breaking all subsequent handshakes, metadata fetc...
CVE-2026-104356	New	5.9	MEDI				PictShare before version 3.7.1 contains a weak randomness vulnerability where the getRandomString() function uses the non-cryptographic rand() PRNG to generate the delete_code authorization token in src/inc/core.php. Attackers can predict or infer the PRNG state to guess valid delete_code values and perform unauthorized deletion of hosted files without needing to read the co...
CVE-2026-34189	New	5.9	MEDI				Cross-Site Request Forgery (CSRF) vulnerability allows unauthorized deletion of event responses via a forged GET request when an authenticated administrator visits a malicious page. This issue affects Pandora FMS: from 777 onwards.
CVE-2026-34190	New	5.9	MEDI				Cross-Site Request Forgery (CSRF) vulnerability allows unauthorized deletion of alert commands via sequential, unvalidated GET requests when an authenticated administrator visits a malicious page. This issue affects Pandora FMS: from 777 onwards.
CVE-2026-103247	New	5.8	MEDI				n8n versions before 1.123.80 contain a credential tampering vulnerability where duplicate node IDs bypass the workflow credential tamper guard. Attackers with editor access to shared workflows can exploit mismatched node ID and name matching to retain victim credentials and redirect secrets to attacker-controlled hosts.
CVE-2026-71454	New	5.8	MEDI				Improper neutralization of input during web page generation ('cross-site scripting') vulnerability in CWE-79 - Cross-site Scripting CAPEC-63 allows Cross-Site Scripting (XSS). This issue affects CAPEC-63: before 3.0b63.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-78242	New	5.7	MEDI				Insertion of sensitive information into log file vulnerability in Apache APISIX. This vulnerability can cause the unmasked header value to be written to the log sink under a certain response structure. This issue affects Apache APISIX: 3.17.0. Users are recommended to upgrade to version 3.18.0, which fixes the issue.
CVE-2026-27872	New	5.6	MEDI				- Improper Privilege Management vulnerability in Johnson Controls Easy IO FG allows (Brute Force). This issue affects Easy IO FG: before 2.0b52.
CVE-2026-27873	New	5.6	MEDI				- Use of Hard-coded Credentials vulnerability in Johnson Controls EasyIO FG allows - Pasword Spraying. This issue affects EasyIO FG: before 2.0b52.
CVE-2026-71448	New	5.6	MEDI				: Insecure Default Initialization of Resource vulnerability in Johnson Controls EasyIO FS32 allows : Authentication Abuse. This issue affects EasyIO FS32: before 3.0b63.
CVE-2026-71451	New	5.6	MEDI				- OS Command Injection vulnerability in Johnson Controls EasyIO FS32 allows - Command Injection. This issue affects EasyIO FS32: before 3.0b63.
CVE-2026-71453	New	5.6	MEDI				- External Control of File Name or Path vulnerability in Johnson Controls EasyIO FS32 allows - traversal attack. This issue affects EasyIO FS32: before 3.0b63.
CVE-2026-103497	New	5.5	MEDI			jetbrains:youtrack	In JetBrains YouTrack before 2026.2.19422 sSRF was possible via the GitHub VCS integration
CVE-2026-103687	New	5.5	MEDI				A vulnerability has been found in rhukster dom-sanitizer up to 1.0.15. The affected element is the function url of the file src/DOMSanitizer.php of the component SVG Sanitization. Such manipulation leads to incomplete blacklist. It is possible to launch the attack remotely. The exploit has been disclosed to the public and may be used. Upgrading to version 1.0.16 is sufficien...
CVE-2026-102370	New	5.4	MEDI				Kasa EC70 v4 and EC71 v4 do not logically disable the production debug interface at the firmware or chip level and do not lock the bootloader. Although the debug traces are physically severed during manufacturing, an attacker with physical access can restore the connection, interrupt the boot process, and manipulate boot parameters to enter a non-standard initialization pat...
CVE-2026-103496	New	5.4	MEDI			jetbrains:youtrack	In JetBrains YouTrack before 2026.2.19422 iDOR in inbox threads allowed reading other users' notifications
CVE-2026-103678	New	5.4	MEDI				A flaw was found in tnrf. An attacker can exploit this vulnerability by providing a specially crafted file containing uncompressed Rich Text Format (RTF) data. Because the application fails to properly validate input buffer boundaries before copying data in get_rtf_data_from_buf(), reading beyond the allocated memory occurs. This flaw can cause the application to crash, lead...
CVE-2026-104181	New	5.4	MEDI				Filament is a collection of full-stack components for accelerated Laravel development. From 4.0.0 until 4.13.3 and 5.8.3, app-based multi-factor authentication management actions do not consistently require confirmation of the current password. An attacker with access to an authenticated user session can set up app-based MFA and obtain recovery codes, or disable app-based MF...
CVE-2026-62063	New	5.4	MEDI				Missing Authorization vulnerability in Magepeople inc. WpTravelly tour-booking-manager allows Exploiting Incorrectly Configured Access Control Security Levels.This issue affects WpTravelly: from n/a through 2.3.1.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-78471	New	5.4	MEDI				The Autoptimize plugin for WordPress is vulnerable to Stored Cross-Site Scripting via Comment Author Name in all versions up to, and including, 3.1.15.1 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts in pages that will execute whenever a user accesses an injected page. Exploitat...
CVE-2026-85005	New	5.4	MEDI				The Popup Maker WP WordPress plugin through 1.4.5 does not perform authorization checks on several of its actions and exposes its management page to any logged-in user, allowing users with a low-privileged role such as Subscriber to store display-targeting values that are later invoked as zero-argument PHP callables on public page loads, leading to sensitive information disc...
CVE-2026-92924	New	5.4	MEDI				The Unlimited Elements for Elementor WordPress plugin before 2.0.21 does not check that a request to render widget output comes from a user allowed to make it, allowing users with a role as low as subscriber to have arbitrary WordPress shortcodes executed on the site. Version 2.0.18 removed the subscriber-level access, so from 2.0.18 onward the issue requires a Contributor r...
CVE-2026-102381	New	5.3	MEDI				Missing Authorization vulnerability in Ahmad Majestic Support majestic-support allows Exploiting Incorrectly Configured Access Control Security Levels.This issue affects Majestic Support: from n/a through 1.2.0.
CVE-2026-102390	New	5.3	MEDI				Missing Authorization vulnerability in VillaTheme AFFI – Affiliate Marketing for WooCommerce affi-affiliate-marketing-for-woo allows Exploiting Incorrectly Configured Access Control Security Levels.This issue affects AFFI – Affiliate Marketing for WooCommerce: from n/a through 1.0.9.
CVE-2026-102670	New	5.3	MEDI				Joyland AI app explicitly permits cleartext HTTP traffic on Android 9+ where the default is to block it.
CVE-2026-103265	New	5.3	MEDI				Fleet versions before 4.89.0 fail to properly filter MDM command results by team authorization in the commands/results endpoint. Team-scoped users can read MDM command results for hosts on other teams when a shared command UUID targets hosts across multiple teams, exposing host UUIDs, command payloads, and device responses.
CVE-2026-103267	New	5.3	MEDI				Ghost versions before 6.62.0 contain an authentication bypass vulnerability in staff invite acceptance that allows users to specify any email address when creating their account. Attackers can accept leaked invite tokens with attacker-controlled email addresses, or legitimate recipients can register with unintended email providers.
CVE-2026-103273	New	5.3	MEDI				Ghost versions 4.3.0 before 6.58.0 contain an authentication bypass vulnerability where lower-privilege staff users can use staff tokens to bypass post editing restrictions. Attackers with staff credentials can leverage tokens to edit posts beyond their assigned privilege level.
CVE-2026-103281	New	5.3	MEDI				Ghost (npm package 'ghost') versions from 3.23.0 up to, but not including, 6.23.0 expose API keys to users with low-privilege staff accounts. An authenticated low-privilege staff user can read API keys returned by the Admin API, which are intended to be available only to higher-privileged users.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-103282	New	5.3	MEDI				Ghost versions 0.5.0 before 6.23.0 contain a concurrency issue in the staff invitation acceptance mechanism that allows multiple accounts to be created from a single invite token. Attackers can exploit this race condition by submitting concurrent requests with the same invitation token to create duplicate user accounts.
CVE-2026-103284	New	5.3	MEDI				Ghost versions from 5.125.1 before 6.57.1 contain an information disclosure vulnerability in the Admin Feedback endpoint that allows unauthorized staff users to access member data. Attackers with staff privileges can query the feedback endpoint to retrieve sensitive member information without proper authorization checks.
CVE-2026-103285	New	5.3	MEDI				Ghost versions from 5.19.0 before 6.57.1 contain a cross-site request forgery vulnerability in the post feedback functionality that allows attackers to submit feedback on behalf of logged-in users. Attackers can craft a malicious link to the feedback page that automatically submits feedback when visited by authenticated members without their knowledge or consent.
CVE-2026-103336	New	5.3	MEDI				Insertion of Sensitive Information Into Sent Data vulnerability in Smackcoders Inc. WP Ultimate CSV Importer wp-ultimate-csv-importer allows Retrieve Embedded Sensitive Data.This issue affects WP Ultimate CSV Importer: from n/a through 9.1.
CVE-2026-103340	New	5.3	MEDI				Missing Authorization vulnerability in Gemini Labs Site Reviews site-reviews allows Exploiting Incorrectly Configured Access Control Security Levels.This issue affects Site Reviews: from n/a through 8.3.2.
CVE-2026-103341	New	5.3	MEDI				Missing Authorization vulnerability in Unlimited Elements Unlimited Elements For Elementor (Free Widgets, Addons, Templates) unlimited-elements-for-elementor allows Exploiting Incorrectly Configured Access Control Security Levels.This issue affects Unlimited Elements For Elementor (Free Widgets, Addons, Templates): from n/a through 2.0.20.
CVE-2026-103345	New	5.3	MEDI				Insertion of Sensitive Information Into Sent Data vulnerability in Shamim Rajani Pie Register pie-register allows Retrieve Embedded Sensitive Data.This issue affects Pie Register: from n/a through 3.8.4.13.
CVE-2026-103347	New	5.3	MEDI				Unauthenticated Bypass Vulnerability in hCaptcha for WP <= 5.3.0 versions.
CVE-2026-103353	New	5.3	MEDI				Incorrect Behavior Order vulnerability in WP ManageNinja LLC FluentForm fluentform allows Removing Important Client Functionality.This issue affects FluentForm: from n/a through 6.2.14.
CVE-2026-103858	New	5.3	MEDI				MISP contains an incomplete authorization check in the discussion posting functionality. When a user submits a post to a thread or replies to an existing post, the application only verified whether the target thread was restricted to a single organization (org-only distribution). It did not enforce the full thread access control list, including sharing-group membership and e...
CVE-2026-104058	New	5.3	MEDI				Podgrab contains a missing authentication vulnerability in which the /ws WebSocket route is registered on the root gin engine instead of the BasicAuth-protected router group, allowing unauthenticated network clients to connect even when PASSWORD is configured. Attackers can join the allConnections set, capture PlayerExists broadcasts containing client-supplied player identif...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-12542	New	5.3	MEDI				A flaw was found in Foreman. The foreman-tail utility is vulnerable to OS command injection due to the unsafe use of the eval command. The script takes user-supplied arguments and incorporates them directly into a string that is then executed by eval to expand file paths. Because the input is not sanitized or quoted, a local attacker can inject shell metacharacters (e.g., ;,...
CVE-2026-13413	New	5.3	MEDI				The CMP – Coming Soon & Maintenance WordPress plugin before 4.1.20 does not correctly restrict access to the site while maintenance/coming-soon mode is enabled, allowing unauthenticated visitors to bypass the coming-soon page and reach the otherwise hidden site, including hidden published pages, by shaping the request so it is mistaken for a login request.
CVE-2026-55394	New	5.3	MEDI				Unencrypted traffic in the 802.11 network of Teledyne FLIR Aware2 versions through 6.9.0.2 allows adjacent unauthenticated attackers to intercept, hijack, or modify session traffic against Teledyne FLIR PackBot robots running this software via sniffing or hijacking network traffic.
CVE-2026-58415	New	5.3	MEDI				Internal state files accessible to external parties in mod_dav_fs in Apache Software Foundation Apache HTTP Server before 2.4.69 on all platforms allows a remote client to read WebDAV dead properties of resources it cannot author via a GET request for the .DAV state directory This issue affects Apache HTTP Server: from 2.4.0 through 2.4.68.
CVE-2026-62058	New	5.3	MEDI				Insertion of Sensitive Information Into Sent Data vulnerability in WPExperts CF7 Apps contact-form-7-honeypot allows Retrieve Embedded Sensitive Data.This issue affects CF7 Apps: from n/a through 3.7.2.
CVE-2026-62061	New	5.3	MEDI				Authorization Bypass Through User-Controlled Key vulnerability in Metagauss ProfileGrid profilegrid-user-profiles-groups-and-communities allows Exploiting Incorrectly Configured Access Control Security Levels.This issue affects ProfileGrid: from n/a through 6.0.0.2.
CVE-2026-67104	New	5.3	MEDI				HCL BigFix Service Management is affected by an Information Disclosure vulnerability, which could allow an unauthenticated attacker to analyze publicly accessible JavaScript files, enabling the discovery of hidden administrative API endpoints for further targeted exploitation.
CVE-2026-67106	New	5.3	MEDI				HCL BigFix Service Management is affected by an Information Disclosure vulnerability because two exposed API endpoints return sensitive data. This information could enable an attacker to launch further, more serious attacks.
CVE-2026-67171	New	5.3	MEDI				HCL BigFix Service Management is affected by an Information Disclosure vulnerability because an exposed API endpoint exposes sensitive internal database information. This information could enable an attacker to facilitate targeted database attacks.
CVE-2026-78577	New	5.3	MEDI				Tapo C120 v1 and C200 V5 contain a vulnerability in the HTTPS onboarding scan function due to missing authentication. After initial setup, an unauthenticated attacker on the same local network can invoke the scan action and retrieve nearby wireless access-point metadata, including SSIDs, BSSIDs, authentication and encryption modes, and signal-strength information. S...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-79768	New	5.3	MEDI				Path equivalence: './.' (single dot directory) vulnerability in Apache HTTP Server's mod_userdir module when configured with absolute non-wildcard UserDir directive (the 2nd form in https://httpd.apache.org/docs/2.4/mod/mod_userdir.html#userdir) This issue affects Apache HTTP Server: from 2.4.0 through 2.4.68.
CVE-2026-82806	New	5.3	MEDI				Exposure of data element to wrong session vulnerability in Apache APISIX. This issue affects Apache APISIX: from 2.3.0 before 3.7.0. Under a supported authz-keycloak configuration, a request's authorization scope could persist into later requests on the same route, leading to unintended authorization expansion and inconsistent access-control decisions. Users are rec...
CVE-2026-90952	New	5.3	MEDI				The WP Edit Password Protected WordPress plugin before 2.0.7 does not enforce its site-wide access restriction on the WordPress REST API, allowing unauthenticated users to read the content of published posts and pages that the site's access mode was configured to hide.
CVE-2026-90987	New	5.3	MEDI				The Easy PayPal & Stripe Buy Now Button WordPress plugin before 2.0.6 does not derive the payment amount on the server, taking it from a client-supplied field, so an unauthenticated attacker sets an arbitrary lower price for a purchase.
CVE-2026-91020	New	5.3	MEDI				The WebToffee Gift Cards for WooCommerce WordPress plugin before 1.3.1 does not validate a user-supplied gift card amount server-side before using it as the cart-item price and store-credit coupon value, allowing unauthenticated users to submit an arbitrary or negative amount, bypassing the configured denominations and manipulating the order total to obtain products without ...
CVE-2026-101890	New	5.1	MEDI				The Prime Mover plugin for WordPress before 2.2.1 contains a stored cross-site scripting vulnerability that allows attackers to execute arbitrary JavaScript by injecting an unescaped site_title value in a package's footprint.json file. Attackers can place a crafted package under the prime-mover-export-files directory so that the malicious value renders unescaped in the colum...
CVE-2026-103290	New	5.1	MEDI				Ghost versions 6.14.0 through versions prior to 6.27.0 contain a path traversal vulnerability in the ImageSize service. Insufficient input validation of user-supplied file paths may allow authenticated staff users to access local files outside the intended data storage directories on the server.
CVE-2026-103662	New	5.1	MEDI				MISP contains a reflected cross-site scripting (XSS) vulnerability in the legacy taxonomy tag management confirmation forms (add tag and disable tag). The affected forms echoed a user-supplied tag name value from the request unescaped into the rendered HTML output. An attacker who can induce a site administrator to visit a crafted URL containing a malicious tag name paramet...
CVE-2026-104183	New	5.1	MEDI				stream-json is a micro-library of stream components for processing JSON and JSONC with a minimal memory footprint. Prior to 3.6.0, Assembler materializes object properties with plain assignment, so an input key named __proto__ invokes the inherited setter and causes parsed object prototype replacement instead of creating an own data property. Applications that make authoriza...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-55252	New	5.1	MEDI				OpenRun is an open-source, self-hosted GitOps platform for deploying web apps and internal tools to Docker or Kubernetes. Prior to version 0.17.7, the restrictions on redirect URLs in openrun can be bypassed by attackers, leading to open redirect attacks. This issue has been patched in version 0.17.7.
CVE-2026-94276	New	5.1	MEDI				Improper Authentication vulnerability in Apache APISIX. On a route using openid-connect plugin with remote introspection against an authorization server that serves multiple issuers, a token that introspects as active for one issuer may get accepted on a route restricted to another. This issue affects Apache APISIX: from 3.12.0 through 3.18.0. Users are recommended to upgr...
CVE-2026-27874	New	5.0	MEDI				: Use of Hard-coded Credentials vulnerability in Johnson Controls EasyIO FS32 allows : Exploitation of Default or Hard-coded Credentials. This issue affects EasyIO FS32: before 3.0b63.
CVE-2026-103664	New	4.8	MEDI				MISP contains a reflected cross-site scripting (XSS) vulnerability in the analyst data notes panel. The seed path parameter, supplied by the user via the URL, was passed directly into inline JavaScript within the rendered HTML response without any sanitization or type enforcement. An attacker who can convince an authenticated MISP user to navigate to a crafted URL (for exam...
CVE-2026-7173	New	4.8	MEDI				CVE-2026-7173: Cross-Site Scripting vulnerability in Entradium, by Crocantickets. Exploitation of this vulnerability could allow a remote attacker to send a specially crafted URL to the victim and steal their session data. * (Stored XSS) The City parameter in the endpoint /events/<event_name>/edit_general during the process of creating or editing events assigned to a pro...
CVE-2026-7174	New	4.8	MEDI				CVE-2026-7174: Stored Cross-Site Scripting vulnerability in Entradium, by Crocantickets. Specifically, in the Name and Field parameters of the endpoint /tools/discount_wizard/discount_config during the process of creating discounts assigned to an event. This vulnerability allows JavaScript code to be injected into the affected parameters, which executes when an event's disco...
CVE-2026-7175	New	4.8	MEDI				CVE-2026-7175: the Business Name parameter in the /promoters/edit endpoint of the My Profile section of a promoter's profile, which allows the injection of JavaScript code that will execute on the promoter's public page;
CVE-2026-7176	New	4.8	MEDI				CVE-2026-7176: the Help text and Title parameters in the endpoint /events/<event_name>-<event_city>/custom_form/edit during the process of creating or modifying forms associated with ticket sales for an event, which allows for the injection of JavaScript that will execute on the public ticket purchase page for the event.
CVE-2026-9864	New	4.8	MEDI				Fortra BoKS Server Agent contains a predictable password generation vulnerability in the adjoin utility. Machine-account passwords generated during Active Directory join or password renewal operations may have significantly less entropy than intended, making them more susceptible to prediction by an attacker who can estimate when the password was generated.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-100184	New	4.7	MEDI				The Calculated Fields Form – AI Form Builder for WordPress – Contact, Payment, Quote, Quiz & More plugin for WordPress is vulnerable to Reflected DOM-Based Cross-Site Scripting via the 'x (attacker-chosen name matching the form's url.<name> predefined value)' parameter in all versions up to, and including, 5.5.1.3 due to insufficient input sanitization and output escaping. T...
CVE-2026-17053	New	4.4	MEDI				The SMBus driver API exposed smbus_smbalert_remove_cb() and smbus_host_notify_remove_cb() as Zephyr syscalls. Their verifiers in drivers/smbus/smbus_handlers.c validated only the dev argument with K_SYSCALL_OBJ(dev, K_OBJ_DRIVER_SMBUS) and forwarded the caller-supplied struct smbus_callback *cb pointer into kernel-mode driver code without any K_SYSCALL_MEMORY_READ/K_SYSCALL_...
CVE-2026-93832	New	4.4	MEDI				A component of one of the Motorola system applications was exported without permission, allowing for the revocation of runtime permissions from other apps.
CVE-2025-31980	New	4.3	MEDI				HCL BigFix Service Management is affected by an Improper Input Validation vulnerability, which could allow an attacker to inject unvalidated, malformed data into the application, enabling potential injection attacks or errors in downstream processing systems.
CVE-2026-102382	New	4.3	MEDI				Authorization Bypass Through User-Controlled Key vulnerability in Ahmad Majestic Support majestic-support allows Exploiting Incorrectly Configured Access Control Security Levels.This issue affects Majestic Support: from n/a through 1.2.0.
CVE-2026-103275	New	4.3	MEDI				Ghost 5.42.2 before 6.58.0 contains an information disclosure vulnerability in the Admin API bulk post and page edit and delete endpoints, which accept filters on restricted fields such as authors.password, because of an incomplete fix for CVE-2026-70590. Staff-level attackers can infer other staff users' password hashes from which filters match and perform offline password-...
CVE-2026-103495	New	4.3	MEDI			jetbrains:youtrack	In JetBrains YouTrack before 2026.2.19422 missing authorisation allowed reloading of translation catalogs
CVE-2026-1661	New	4.3	MEDI				The WP Mail Logging WordPress plugin before 1.17.0 does not properly restrict the HTML and CSS of logged emails before rendering them in its admin log screens, allowing unauthenticated users to inject styled content and links, for example through a public contact form, that can deceive an administrator viewing the log and send their browser to an attacker-controlled page.
CVE-2026-42528	New	4.3	MEDI				A memory calculation bug in mod_dav in Apache httpd 2.4.67 and earlier allows an attacker with permission to create WebDAV locks to crash server child processes. Users are recommended to upgrade to version 2.4.69, which fixes this issue
CVE-2026-56098	New	4.3	MEDI				A flaw was found in rubygem-katello. The RegistryProxiesController in Katello contains an authorization bypass vulnerability due to an execution fall-through in the registry_authorize filter. While the application identifies unauthorized requests and triggers an error response via the unauthorized method, it fails to halt the execution of the current code path (missing retur...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-66247	New	4.3	MEDI				iControl is affected by an insecure Cross-Origin Resource Sharing (CORS) policy vulnerability, which could allow a malicious website to execute cross-origin requests with included credentials, enabling an attacker to access and exfiltrate sensitive data within the context of the victim's active session.
CVE-2026-79618	New	4.3	MEDI				The WP User Frontend WordPress plugin before 4.3.12 does not enforce its subscription-purchase requirement in one of its post-creation handlers, allowing authenticated users with subscriber-level access and above to create and, depending on the form's configuration, immediately publish posts through forms restricted to paying subscribers.
CVE-2026-97219	New	4.3	MEDI				The MStore API WordPress plugin before 4.22.1 does not restrict which fields of an order a customer may update, allowing any authenticated user with a self-registerable account to change the status of their own unpaid order to a paid or fulfilled state and receive the goods without paying.
CVE-2026-77387	New	4.0	MEDI				geopy is a geocoding library for Python. Prior to 2.5.0, geopy.Point and Point.from_string() can spend excessive CPU time due to inefficient regular-expression behavior when an application passes a long malformed coordinate string without the 256-character input limit used by the fix. Geocoder reverse methods also reach the vulnerable parsing path when called with string inp...
CVE-2026-21833	New	3.7	LOW				HCL AION is affected by a vulnerability in which the Content-Security-Policy (CSP) HTTP response header is not configured. CSP helps prevent attacks such as Cross-Site Scripting (XSS) by restricting the sources from which scripts, styles, and other resources can be loaded. The absence of this header may reduce the effectiveness of browser-based security controls, potentially...
CVE-2026-42356	New	3.7	LOW				Deployment of wrong handler vulnerability in Apache HTTP Server allows the target of some internal redirects from CGI programs to also be treated as CGI and executed. The target must already be in a directory enabled for CGI and have no other extension understood by mod_mime. This issue affects Apache HTTP Server: from 2.4.60 through 2.4.68.
CVE-2026-67172	New	3.7	LOW				HCL BigFix Service Management is affected by an Information Disclosure vulnerability the application returns sensitive information in error messages when invalid inputs are sent to certain API endpoints . This information could enable an attacker to facilitate further attacks.
CVE-2026-103686	New	3.5	LOW				A flaw has been found in rhukster dom-sanitizer up to 1.0.15. Impacted is the function DOMSanitizer::isDangerousUrl of the file src/DOMSanitizer.php of the component URL Validation. This manipulation causes cross site scripting. It is possible to initiate the attack remotely. The exploit has been published and may be used. Upgrading to version 1.0.16 is recommended to address...
CVE-2026-103680	New	3.1	LOW				A flaw was found in tnef. A heap-based buffer overflow can occur in the find_free_number() function when generating numbered backup suffixes for duplicate filenames. When numbered backups are enabled and file overwriting is disabled, an attacker can supply a specially crafted Transport Neutral Encapsulation Format (TNEF) file with an excessive number of colliding attachment ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-66248	New	3.1	LOW				iControl is affected by an Improper Error Handling vulnerability, which could allow an unauthenticated attacker to trigger verbose database and system errors, enabling the disclosure of sensitive internal infrastructure details used to plan advanced targeted attacks.
CVE-2026-66249	New	3.1	LOW				iControl is affected by a Missing Secure Attribute vulnerability, which could allow an attacker to intercept cookies transmitted over unencrypted HTTP connections, enabling the unauthorized extraction of sensitive information such as session identifiers.
CVE-2026-66253	New	3.1	LOW				iControl is affected by a Session Timeout vulnerability, which could allow an attacker to exploit an unattended or abandoned active session, enabling unauthorized access to the application and the ability to perform actions on behalf of the victim.
CVE-2026-103287	New	2.7	LOW				Ghost versions 1.18.0 before 6.27.0 contain a server-side request forgery vulnerability in the webhooks feature that allows staff users to probe internal hosts. Attackers with staff privileges can craft webhook requests to access internal network resources from the Ghost server.
CVE-2026-56599	New	2.2	LOW				HCL BigFix Service Management is affected by an Insecure Cookie Attribute Configuration vulnerability, which could allow an attacker to exploit missing security attributes such as SameSite, HttpOnly, Secure, and restrictive Paths, enabling Cross-Site Request Forgery (CSRF), session hijacking via Cross-Site Scripting (XSS), and unauthorized access.
CVE-2026-103690	New	2.1	LOW				A flaw has been found in itsourcecode Leave Management System 1.0. This vulnerability affects unknown code of the file /module/leave/controller.php. Executing a manipulation of the argument LEAVEID can lead to sql injection. The attack may be performed from remote. The exploit has been published and may be used.
CVE-2026-103923	New	2.1	LOW				KaTeX is a fast, easy-to-use JavaScript library for TeX math rendering on the web. From 0.11.0 until 0.18.2, KaTeX uses ordinary JavaScript property access for the renderer options object, the trust setting, default and processor setting metadata, and namespace lookup and group restoration, allowing inherited properties to be treated as explicitly supplied values. When Objec...
CVE-2026-94220	New	2.1	LOW				Cross-Site request forgery (CSRF) vulnerability in feishu-auth and dingtalk-auth plugins in Apache APISIX. An attacker who can get a user to click a crafted link may cause that user's browser session on a protected route to be established under the attacker's identity instead of their own. Any work the user then performs in that session, including uploads, form submission...
CVE-2026-103489	New	2.0	LOW				In JetBrains YouTrack before 2026.2.19422 HTML injection in VCS command failure notifications was possible
CVE-2024-29296	New				0.013	Go:github.com/portainer/portainer	Portainer CE allows username enumeration through authentication response timing in github.com/portainer/portainer
CVE-2025-59953	New				0.008	PyPI:lmdeploy	### Description The LMdeploy implements an rpc server (AsyncRPCServer in zmq_rpc.py) for supporting the RPC communications. In its core functionality call_and_response(), I found it will directly use the pickles.loads() to deserialize the received messages without any sanitization, hence resulting in a remote code execution vulnerability by this RPC server. ### Proof of Co...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2025-66336	New				0.006	PyPI:doris-mcp-server	Apache Doris MCP Server contains a SQL injection vulnerability in a metadata query path. A user-controlled database name is directly interpolated into a SQL query, and the query is executed without passing the caller's authorization context. This may allow an authenticated attacker, or an anonymous attacker if authentication is disabled, to bypass SQL security validation and...
CVE-2025-66455	New				0.007	PyPI:lmdeploy	## Summary LMDeploy's PyTorch DistServe/PD-disaggregation control plane used `recv_pyobj()` to deserialize messages received through a ZeroMQ PULL socket. PyZMQ implements `recv_pyobj()` using Python pickle deserialization, which can execute arbitrary code while reconstructing an object. The peer address used by the receiver was supplied through the `POST /distserve/p2p_co...
CVE-2025-71341	New				0.006	PyPI:picklescan	#### Summary Using profile.Profile.runcctx, which is a built-in python library function to execute remote pickle file. #### Details The attack payload executes in the following steps: First, the attacker craft the payload by calling to profile.Profile.runcctx function in reduce method Then when the victim after checking whether the pickle file is safe by using Picklescan lib...
CVE-2025-71351	New				0.007	PyPI:picklescan	#### Summary Using timeit.timeit() function, which is a built-in python library function to execute remote pickle file. #### Details Pickle's deserialization process is known to allow execution of function via reduce method. While Picklescan is meant to detect such exploits, this attack evades detection by calling built-in python library function like <code>**timeit.timeit()</code> . And...
CVE-2025-71365	New				0.004	PyPI:picklescan	#### Summary Picklescan uses numpy.f2py.crackfortran.myeval, which is a function in numpy to execute remote pickle files. #### Details The attack payload executes in the following steps: - First, the attacker crafts the payload by calling the numpy.f2py.crackfortran.myeval function in its reduce method - Then, when the victim checks whether the pickle file is safe by using t...
CVE-2025-71370	New				0.005	PyPI:picklescan	#### Summary Using torch.jit.unsupported_tensor_ops.execWrapper function, which is a pytorch library function to execute remote pickle file. #### Details The attack payload executes in the following steps: First, the attacker craft the payload by calling to torch.jit.unsupported_tensor_ops.execWrapper function in reduce method Then when the victim after checking whether th...
CVE-2025-71376	New				0.004	PyPI:picklescan	#### Summary Using idlelib.autocomplete.AutoComplete.fetch_completions, which is a built-in python library function to execute remote pickle file. #### Details The attack payload executes in the following steps: First, the attacker craft the payload by calling to idlelib.autocomplete.AutoComplete.fetch_completions function in reduce method Then when the victim after checki...
CVE-2026-101917	New				0.004	PyPI:pyjwt	Summary CVE-2026-48524 (GHSA-fhv5-28vv-h8m8, "PyJWKClient unbounded JWKS endpoint requests via attacker-controlled kid values (DoS)") was fixed in 2.13.0 by stopping fetch_data() from clearing the cache on a fetch error. That closed one amplification path but did not add the mitigation the advisory's title implies: there is still no rate-limit, negative-cache, or minimum-ref...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-101918	New				0.003	PyPI:pyjwt	## Summary `PyJWKClient.get_signing_key_from_jwt(token)` — the first step of the JWKS verification flow documented in `docs/usage.rst` — must decode a token's payload before its signature can be checked, via `jwt.api_jwt.decode_complete(token, options={"verify_signature": False})`. That call parses the payload with `json.loads` in `PyJWT._decode_payload` (`jwt/api_jwt.py:29...
CVE-2026-102265	New				0.003	PyPI:pyjwt	## Package pyjwt (PyPI) ## Affected versions tested & verified on: 2.13.0. Every version whose `PyJWS._load()` translates only `ValueError` is affected ## Description `PyJWS._load()` (`jwt/api_jws.py:337`) splits the compact token, base64url decodes the header segment and hands it to `json.loads()` before `_verify_signature()` runs. The parse is wrapped in `except Valu...
CVE-2026-102266	New				0.002	PyPI:pyjwt	#### Summary A service that verifies HS256 tokens using an empty oct JWK through PyJWK, including a PyJWK obtained from PyJWKSet, can therefore accept attacker-generated tokens as authenticated. PyJWT 2.13.0 rejects an empty HMAC key when it is supplied through the raw `str`/`bytes` key path, but accepts the same zero-length key when it is supplied as a symmetric `PyJWK`. ...
CVE-2026-102267	New				0.002	PyPI:pyjwt	#### Summary PyJWT 2.13.0 `PyJWKClient` followed HTTP redirects while fetching a JWKS, without validating the redirect destination. A configured trusted endpoint could therefore redirect the client to a different host. #### Impact When an application uses `PyJWKClient` with caller-supplied request headers and an attacker can influence the configured endpoint's response, the...
CVE-2026-102268	New				0.002	PyPI:pyjwt	**Prerequisites** (both conditions must hold; both are deployment properties, not attacker-controlled at request time): - The `jwt.decode` allow-list mixes an HMAC algorithm with an asymmetric one, e.g. `algorithms=["ES256", "HS256"]` (the RFC 8725 footgun the guard exists to backstop). - The verification key is passed as raw PEM text/bytes on the non-`PyJWK` path, in a byt...
CVE-2026-102269	New				0.002	PyPI:pyjwt	## Summary PyJWT 2.13.0 accepts compact JWS signature segments containing characters that are not in the Base64URL alphabet. Appending `!!!!` to a valid signature does not change the decoded signature bytes or authenticated claims, but it changes the serialized token and its SHA-256 hash. An application that indexes logout or revocation state by the raw token therefore reje...
CVE-2026-102270	New				0.002	PyPI:pyjwt	#### Summary There is a Re-DoS vulnerability in the `is_pem_format` function which results in a intensive CPU usage if an attacker is been able to provide a custom certificate. #### Details The problem is that the lazy quantifier `.+?` will always first try to match as little as possible until it finds a `----- END`. Normally this means the complexity of this should be O(N). H...
CVE-2026-102271	New				0.002	PyPI:pyjwt	#### Summary `HMACAlgorithm.prepare_key` blocks asymmetric keys from being used as HMAC secrets by searching for text markers only. It looks for `-----BEGIN` and for an `ssh-` prefix. The same key in DER form is binary ASN.1 and has neither marker, so it passes the check and is used as an HMAC secret. An application that verifies tokens with an RSA or EC public key, and als...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-102272	New				0.002	PyPI:pyjwt	## Affected Package - **Package**: PyJWT (`pyjwt` on PyPI) - **Repository**: https://www.google.com/url?q=https://github.com/jpadilla/pyjwt&source=gmail&ust=1781794518474000&sa=E - **Affected version**: 2.13.0 - **Vulnerability class**: Algorithm confusion / patch bypass --- ## Root Cause PyJWT 2.13.0 introduced a guard in `HMACAlgorithm.prepare_key()` (file `jwt/algorit...
CVE-2026-102273	New				0.002	PyPI:pyjwt	### Summary PyJWT 2.13.0 contains an incomplete defense against algorithm confusion when an application mixes symmetric and asymmetric algorithms in one verification path. A public RSA, EC, or OKP JWK can be accepted as an HMAC secret when it is wrapped in a JWKS object, nested in an array, or represented in another container form that does not expose a top-level `kty` memb...
CVE-2026-102274	New				0.004	PyPI:pyjwt	## Summary A malformed RSA JWK inside a JWK Set aborts parsing of the entire set instead of being skipped, because `RSAAlgorithm.from_jwk` can raise a plain `ValueError` that isn't caught by `PyJWKSet`'s per-key error-skipping logic. ## Affected component / version - Package: `PyJWT` (PyPI, ecosystem `pip`) - Files: `jwt/api_jwk.py` (`PyJWK.__init__`, `PyJWKSet.__init__`)...
CVE-2026-102830	New		MODE		0.003	PyPI:jupyterlab, PyPI:jupyterlite-core	## Description A language pack ships a `Plural-Forms` header saying how the language counts, for example `nplurals=2; plural=(n != 1);`. JupyterLab turns that string into a function with `new Function`, so the header gets executed. The check that meant to keep it safe was a regular expression. The regex was anchored at the start but not at the end, so it accepted any string...
CVE-2026-102831	New		HIGH		0.002	PyPI:jupyterlab, PyPI:jupyterlite, PyPI:jupyterlite-core, PyPI:notebook	## Description JupyterLab 4.5.0 enabled copying and pasting cells through the system clipboard. The paste path parses clipboard text as cell JSON and inserts the cells without clearing `metadata.trusted`, so a payload can declare its own output as trusted. JupyterLab does not sanitize a trusted output and evaluates the ` <script>` elements it contains, so pasting the cell run...</td></tr> <tr> <td>CVE-2026-102904</td><td>New</td><td></td><td>MODE</td><td></td><td>0.002</td><td>PyPI:jupyterlab</td><td>JupyterLab's PyPI extension manager runs `python -m pip uninstall` with the extension name taken from the request body. `ExtensionHandler.post` validates the name for `cmd=install` but not for `cmd=uninstall`, so a name that begins with `-` reaches the command line and pip reads it as an option rather than as a package. ``python cmdline = [sys.executable, "-m", ...</td></tr> <tr> <td>CVE-2026-102925</td><td>New</td><td></td><td>HIGH</td><td></td><td>0.002</td><td>PyPI:virtualenv</td><td>### Impact The generated `activate` (bash/zsh) and `activate.fish` scripts interpolate a `shlex.quote`-ed value into a position that quotes it a second time. The extra quotes terminate the quoted run early and leave part of the value parsed as shell code, so a path containing shell metacharacters runs commands when a user sources the activation script. `activate` is affect...</td></tr> <tr> <td>CVE-2026-102937</td><td>New</td><td></td><td>HIGH</td><td></td><td>0.001</td><td>PyPI:virtualenv</td><td>`BatchActivator.quote()` returned its input unchanged, the only activator with no escaping at all. `--prompt`, the `VIRTUAL_ENV_PROMPT` environment variable, and the config file all set the prompt, and `activate.bat` writes it straight into `@set "VAR=value"`. A prompt containing a double quote closes that string early, and whatever follows runs as live cmd.exe syntax: ``co...</td></tr> </table> </div></script>

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-103001	New				0.004	PyPI:pyjwt	### Summary `PyJWT.decode()`/`decode_complete()` mutates a caller-supplied `options` dict in place whenever `verify_signature` is falsy, adding `verify_exp`/`verify_nbf`/`verify_iat`/`verify_aud`/`verify_iss`/`verify_sub`/`verify_jti` keys directly onto that object. If application code reuses the same `options` dict across calls (a config object, a module-level constant, a ...
CVE-2026-103656	New						Rejected reason: this is rejected
CVE-2026-104056	New						Authlib version 1.7.2 and below contains a vulnerability where discovery JSON metadata is cached without validation or issuer-origin binding. This allows a poisoned discovery response to replace all endpoint values with attacker-controlled values rather than endpoint URLs that share the origin of the configured server metadata URL.
CVE-2026-10609	New				0.004	Go:github.com/openshift/cluster-logging-operator	OpenShift Cluster Logging Operator missing authorization flaw in github.com/openshift/cluster-logging-operator. NOTE: The source advisory for this report contains additional versions that could not be automatically mapped to standard Go module versions. (If this is causing false-positive reports from vulnerability scanners, please suggest an edit to the report.) The addit...
CVE-2026-12770	New				0.006	PyPI:litellm	A vulnerability was determined in BerriAI litellm up to 1.63.1. The impacted element is an unknown function of the file litellm/proxy/management_endpoints/key_management_endpoints.py of the component Admin Key Handler. This manipulation causes improper authorization. The attack can be initiated remotely. The exploit has been publicly disclosed and may be utilized. The vendor...
CVE-2026-12771	New				0.004	PyPI:litellm	A vulnerability was identified in BerriAI litellm up to 1.82.2. This affects an unknown function of the file litellm/proxy/auth/user_api_key_auth.py of the component M2M JWT Handler. Such manipulation leads to improper authorization. The attack can be launched remotely. A high complexity level is associated with this attack. The exploitability is reported as difficult. The e...
CVE-2026-12772	New				0.004	PyPI:litellm	A security flaw has been discovered in BerriAI litellm up to 1.82.2. This impacts the function authenticate_user of the file litellm/proxy/auth/login_utils.py of the component PROXY_ADMIN database API Key Generator. Performing a manipulation results in session expiration. The attack may be initiated remotely. The exploit has been released to the public and may be used for at...
CVE-2026-12773	New				0.01	PyPI:litellm	A weakness has been identified in BerriAI litellm up to 1.59.8. Affected is the function UserAPIKeyAuth of the file litellm/proxy/_experimental/mcp_server/auth/user_api_key_auth_mcp.py of the component MCP Proxy. Executing a manipulation can lead to improper authentication. The attack may be launched remotely. The exploit has been made available to the public and could be us...
CVE-2026-12795	New				0.008	PyPI:litellm	A vulnerability was determined in BerriAI litellm up to 1.82.2. This affects the function json.dumps of the file litellm/proxy/management_endpoints/ui_sso.py of the component SSO Debug Flow. Executing a manipulation can lead to missing authentication. The attack can be executed remotely. The exploit has been publicly disclosed and may be utilized. The vendor was contacted ea...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-12796	New				0.006	PyPI:litellm	A vulnerability was identified in BerriAI litellm up to 1.82.2. This impacts the function <code>get_redirect_response_from_openid</code> of the file <code>litellm/proxy/management_endpoints/ui_sso.py</code> of the component SSO Authentication Flow. The manipulation leads to session expiration. The attack is possible to be carried out remotely. The exploit is publicly available and might be used. The ...
CVE-2026-12797	New				0.004	PyPI:litellm	A security flaw has been discovered in BerriAI litellm up to 1.82.5. Affected is the function <code>async_pre_call_hook</code> of the file <code>enterprise/enterprise_hooks/banned_keywords.py</code> of the component Completions Interface. The manipulation of the argument <code>prompt</code> results in incorrect authorization. The attack may be performed from remote. The exploit has been released to the public and...
CVE-2026-12798	New				0.004	PyPI:litellm	A weakness has been identified in BerriAI litellm up to 1.82.2. Affected by this vulnerability is the function <code>load_openapi_spec_async</code> of the file <code>litellm/proxy/_experimental/mcp_server/openapi_to_mcp_generator.py</code> of the component MCP OpenAPI Spec Loader. This manipulation of the argument <code>spec_path</code> causes server-side request forgery. It is possible to initiate the attack rem...
CVE-2026-12799	New				0.004	PyPI:litellm	A security vulnerability has been detected in BerriAI litellm up to 1.82.2. Affected by this issue is the function <code>ui_view_users</code> of the file <code>litellm/proxy/management_endpoints/internal_user_endpoints.py</code> of the component Incomplete Fix CVE-2025-0628. Such manipulation leads to improper authorization. It is possible to launch the attack remotely. The exploit has been disclosed...
CVE-2026-13718	New						The Tabs Responsive WordPress plugin through 2.5 does not sanitize the content of WooCommerce product tabs before storing and rendering it, allowing a shop manager to store JavaScript that executes when any user, including an administrator, views the product page.
CVE-2026-15307	New				0.011	PyPI:django	An issue was discovered in Django 5.2 before 5.2.17 and 6.0 before 6.0.8. GeoDjango spatial lookups optimistically parse the right-hand-side value as a raster by passing it to the <code>`django.contrib.gis.gdal.GDALRaster`</code> constructor. Any value used in a spatial lookup against a <code>`GeometryField`</code> or <code>`RasterField`</code> reaches this constructor, including untrusted input, for example a sp...
CVE-2026-18734	New						Rejected reason: ** REJECT ** DO NOT USE THIS CANDIDATE NUMBER. Reason: This candidate was issued in error. Notes: All references and descriptions in this candidate have been removed to prevent accidental usage.
CVE-2026-19730	New				0.002	Go:github.com/containers/podman, Go:github.com/containers/podman/v2, Go:github.com/containers/podman/v3, Go:github.com/c	podman quadlet install --replace does not fully replace the old file in <code>github.com/containers/podman</code>
CVE-2026-33625	New				0.004	PyPI:lmdeploy	### Summary lmdeploy <= latest contains a code injection vulnerability in <code>`lmdeploy/pytorch/config.py`</code> line 620 that allows an attacker to execute arbitrary Python code by publishing a malicious HuggingFace model with a crafted <code>`quantization_config.quant_dtype`</code> value. When a user loads the model with lmdeploy, the <code>`quant_dtype`</code> is passed to <code>`eval(f'torch.{quant_dtype}')`</code> wi...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-49264	New					PyPI:oauthlib	### Summary When `enable_jsonp=True`, oauthlib's `RevocationEndpoint` reflects the user-supplied `callback` parameter directly into JavaScript response bodies on both success and error paths without validating that it is a legal JSONP callback name. This allows arbitrary JavaScript response generation instead of a restricted function call, making the documented JSONP revoca...
CVE-2026-49265	New					PyPI:oauthlib	## Summary A timing side-channel vulnerability exists in the PKCE (RFC 7636) implementation of the Authorization Code Grant flow. The `code_challenge_method_plain` function uses Python's standard `==` operator for string comparison instead of a constant-time comparison function, potentially allowing timing-based attacks. ## Affected Component - File: `oauthlib/oauth2/r...
CVE-2026-50221	New				0.002	PyPI:swift	In OpenStack Swift before 2.37.2, proxy-server does not strip internal update headers (X-Container-Host, X-Container-Device, X-Delete-At-Host, X-Delete-At-Device) from client requests before forwarding them to object-servers. An authenticated user with write access can inject these headers to redirect container update requests to an attacker-controlled server, enabling serve...
CVE-2026-51873	New						Devika v1.0 is vulnerable to Directory Traversal in the <code>Coder.save_code_to_project</code> function, which allows attackers to write files outside the intended project workspace.
CVE-2026-51874	New						In Devika v1.0, the Patcher Agent <code>save_code_to_project</code> function contains a path traversal vulnerability that allows attackers to write files outside the intended project workspace.
CVE-2026-51875	New						In Devika v1.0, the Feature Agent <code>save_code_to_project</code> function contains a path traversal vulnerability that allows attackers to write files outside the intended project workspace, potentially compromising the entire server.
CVE-2026-51876	New						DeepTutor 1.4.0 contains an authorization bypass vulnerability in the book confirmation flow. An unauthenticated or unauthorized caller can reuse a publicly exposed <code>book_id</code> to submit a confirm-proposal request for an existing book, causing unauthorized overwrites of persisted metadata and spine content.
CVE-2026-51878	New						deeptutor 1.4.0 contains an authorization bypass through a user-controlled object identifier in <code>TurnRuntimeManager.regenerate_last_turn</code> . A remote caller can enumerate or obtain a <code>session_id</code> and trigger regenerate on another user's session.
CVE-2026-51879	New						deeptutor 1.4.0 contains an authorization bypass through a user-controlled object identifier in <code>TutorBotManager.write_bot_file</code> . A remote caller can enumerate bot IDs and overwrite another bot's whitelisted control files through the HTTP tutorbot file route.
CVE-2026-51880	New						deeptutor 1.4.0 contains a path traversal issue in <code>EditFileTool.execute</code> . Through the live tutorbot WebSocket interface, a remote caller can induce the tool layer to write or edit absolute paths outside the intended bot workspace.
CVE-2026-51881	New						deeptutor 1.4.0 contains code injection in <code>ExecTool.execute</code> . Through the live tutorbot WebSocket interface, a remote caller can induce the tool layer to execute reviewer-chosen shell commands in the service environment.
CVE-2026-51882	New						The OpenAI-compatible file upload endpoint <code>/v1/files`</code> in Langchain-Chatchat 0.3.0 is vulnerable to path traversal. An attacker can write files to arbitrary locations outside the <code>`openai_files`</code> directory by crafting malicious filenames.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-51883	New						The knowledge base creation and document upload interfaces in Langchain-Chatchat 0.3.0;0.3.1 is vulnerable to path traversal. An attacker can inject path traversal sequences (such as `..\`) into the `knowledge_base_name` parameter to write knowledge base content to arbitrary locations outside the configured knowledge base root directory.
CVE-2026-51884	New						The /knowledge_base/upload_temp_docs temporary document upload endpoint in Langchain Chatchat 0.3.1 is vulnerable to path traversal. By crafting malicious filenames, an attacker can write files to arbitrary locations on the server, bypassing the intended restrictions on the temporary directory.
CVE-2026-51886	New						langflow-ai langflow v1.9.3 is affected by: Code Injection. The impact is: execute arbitrary code (remote). The component is: src/backend/base/langflow/api/v1/validate.py:validate_post_validate_code-a-real-authenticated-http-post-to-api-v1. The attack vector is: Attack surface: HTTP or browser-backed service path. A public-facing route accepts raw Python source and forwards ...
CVE-2026-51888	New						langflow-ai langflow v1.8.4 is affected by: Directory Traversal. The impact is: Arbitrary file write outside the intended workspace or storage boundary.. The component is: src/backend/base/langflow/api/v1/knowledge_bases.py:knowledge_bases-create_knowledge_base-a-live-http-post-to-create-knowledge-base. The attack vector is: Attack surface: HTTP or browser-backed service pat...
CVE-2026-51892	New						infiniflow ragflow 0.24.0 is vulnerable to Incorrect Access Control via /v1/document/get/<doc_id>.
CVE-2026-51893	New						infiniflow ragflow 0.24.0 is vulnerable to Incorrect Access Control via trace_mindmap. An externally reachable path accepts a caller-selected object or tenant identifier and reaches a data-access operation without a visible owner, tenant, workspace, or membership binding on that object.
CVE-2026-51894	New						infiniflow ragflow 0.24.0 is vulnerable to Incorrect Access Control via run_mindmap. A reachable path accepts a caller-selected object or tenant identifier and reaches a data-access operation without a visible owner, tenant, workspace, or membership binding on that object.
CVE-2026-51895	New						Ragflow 0.24.0 and prior contains improper access control in update_metadata_setting (api/apps/kb_app.py). Depending on the exposed entry, an attacker can perform unauthorized cross-session or privilege-crossing operations.
CVE-2026-51896	New						infiniflow ragflow 0.25.3 contains improper access control in resume (api/apps/connector_app.py). Depending on the exposed entry, an attacker can perform unauthorized cross-session or privilege-crossing operations.
CVE-2026-51897	New						RAGFlow 0.24.0 contains improper access control in get_dataset (api/apps/evaluation_app). Depending on the exposed entry, an attacker can trigger attacker-controlled code or command execution
CVE-2026-53433	New				0.004	Go:github.com/junegunn/fzf	fzf vulnerable to denial of service through quadratic HTTP request-body accumulation in github.com/junegunn/fzf

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-53493	New				0.004	Go:github.com/containerd/containerd, Go:github.com/containerd/containerd/v2	Containerd has image-pull DoS via crafted OCI index graph amplification in github.com/containerd/containerd
CVE-2026-56104	New				0.004	PyPI:chainlit	Chainlit before 2.10.1 contains a session hijacking vulnerability that allows unauthenticated attackers to restore and inherit authenticated user sessions by presenting a valid sessionId during WebSocket session restoration without ownership verification. Attackers can exploit the restore_existing_session path to assume a victim's permissions and roles, enabling unauthorized...
CVE-2026-56315	New				0.011	PyPI:picklescan	## Summary picklescan v1.0.3 (latest) does not block at least 7 Python standard library modules that provide direct arbitrary command execution or code evaluation. A malicious pickle file importing these modules is reported as having 0 issues (CLEAN scan). This enables remote code execution that bypasses picklecan entirely. ## Severity Critical (CVSS 9.8) — Direct RC...
CVE-2026-56742	New				0.002	Go:github.com/cilium/cilium	Cilium: Namespaced HTTPRoutes can redirect traffic to other namespaces in github.com/cilium/cilium. NOTE: The source advisory for this report contains additional versions that could not be automatically mapped to standard Go module versions. (If this is causing false-positive reports from vulnerability scanners, please suggest an edit to the report.) The additional affect...
CVE-2026-57149	New				0.006	PyPI:plone-app-portlets	### Impact The Classic portlet (plone.app.portlets.portlets.classic) used its user-supplied template/macro fields to build a TALES path expression that was then evaluated by the TAL path() helper. Because the value was interpreted as a full TALES expression, a user able to add or edit a Classic portlet could supply a crafted value that escapes simple path traversal and is ev...
CVE-2026-57170	New				0.002	PyPI:compliance-trestle	Reporter: Cavan Loughran, Celvex Group Inc. Summary ----- The fix for CVE-2026-46439 (3.12.2 / 4.0.3) removed the recursive re-render loop in trestle/core/commands/author/jinja.py render_template, but the custom include tags in trestle/core/jinja/tags.py (MDSectionInclude, MDCleanInclude) still re-parse the CONTENT of an included markdown file as a Jinja2 template via Par...
CVE-2026-57171	New				0.002	PyPI:compliance-trestle	At a glance - Actor: attacker who controls the -o/--output argument to trestle author {catalog,profile,ssp}-generate (e.g. via a CI pipeline that derives the output directory from repository-controlled data) - Primitive: attacker-controlled --output value reaches trestle_root / args.output write sink with only is_directory_name_allowed() (parts[0]-only task-nam...
CVE-2026-57173	New				0.007	PyPI:vllm	### Summary The audio decode-duration guard (max_duration_s, env VLLM_MAX_AUDIO_DECODE_DURATION_S, default 600s) that protects against audio decompression-bomb DoS is wired into only the speech-to-text path (/v1/audio/transcriptions). The chat audio path (/v1/chat/completions, input_audio content parts) calls the same decoder with no limit, so an unau...
CVE-2026-57175	New				0.002	PyPI:social-auth-core	### Impact The SAML backend accepted SAML responses on the Assertion Consumer Service endpoint without verifying that they matched a previously issued AuthnRequest. Applications using SAML account association could allow an attacker with a valid account on a trusted IdP to link the attacker's SAML identity to a logged-in victim's local account. The attacker could then au...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-57176	New				0.002	PyPI:social-auth-core	### Impact The Vend OAuth2 backend used only the numeric Vend `user_id` as the social-auth UID. When multiple Vend shops authenticate through the same application, users from different shops with the same internal Vend user ID could collide in the social-auth association table. A user from one shop could then be authenticated as the local account previously associated with...
CVE-2026-57177	New				0.001	PyPI:social-auth-core	### Impact The LoginRadius backend did not validate OAuth state during the authentication flow. Applications using this backend were vulnerable to login CSRF. An attacker could cause a victim's browser session to complete authentication using an attacker-controlled LoginRadius token, making the victim authenticated as the attacker's LoginRadius identity. The issue affects...
CVE-2026-57178	New				0.002	PyPI:social-auth-core	### Impact The `vk-app` backend accepted VK application callback data without verifying the callback signature when the `auth_key` parameter was omitted. Applications using this backend could treat unsigned attacker-controlled data as a verified VK identity. An attacker could choose callback fields such as `viewer_id`, `access_token`, `api_id`, and `api_result`, potential...
CVE-2026-57179	New				0.002	PyPI:social-auth-core	### Impact The partial-pipeline resume mechanism accepted `partial_token` as a bearer credential without binding it to the browser session that created it. Applications using resumable partial pipeline steps could allow an attacker to start an authentication flow, obtain a valid partial token and verification data, and cause a victim's browser to resume that attacker-contr...
CVE-2026-57231	New				0.004	Go:github.com/containers/libpod, Go:github.com/containers/podman, Go:github.com/containers/podman/v2, Go:github.com/cont	Podman: Malformed Image can trick podman run into leaking host environment variables into the container in github.com/containers/libpod
CVE-2026-57443	New				0.006	PyPI:scbe-aethermoore	### Summary The AetherBrowser API server (`scripts/aetherbrowser/api_server.py`) exposes the `POST /api/ops/check-email` endpoint without any authentication. Any remote attacker can call this endpoint and trigger execution of the `email_reader.py` subprocess, which connects to configured ProtonMail or Gmail accounts via IMAP and returns email metadata (sender, subject, body...
CVE-2026-57576	New				0.008	PyPI:plone-app-dexterity	### Impact When creating content with a very large title or description field, Plone can become unresponsive. Even if the content loads, it can be hard to edit or delete, because the UI is unwieldy. ### Patches The problem has been patched in `plone.app.dexterity`. * On Plone 6.2, upgrade to `plone.app.dexterity` 5.0.1. * On Plone 6.1, upgrade to `plone.app.dexterity` 4.1....
CVE-2026-58268	New				0.006	Go:github.com/emiago/sipgo	SIPGO: DoS via unvalidated Content-Length in the stream parser in github.com/emiago/sipgo
CVE-2026-59163	New				0.003	PyPI:mnmemosyne-memory	### Summary The Mnemosyne sync server's authentication check decoded JWT bearer tokens but never verified their HMAC-SHA256 signatures. Any well-formed token was accepted, allowing an unauthenticated attacker to impersonate any user and read or modify their sync data. **Severity: Critical** CVSS 3.1: AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N = 9.1 Assumes the sync server endpo...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-59168	New				0.001	Go:github.com/tomwright/dasel, Go:github.com/tomwright/dasel/v2, Go:github.com/tomwright/dasel/v3	Dasel: Unbounded recursion in JSON and XML readers causes unrecoverable stack-overflow DoS in github.com/tomwright/dasel
CVE-2026-59178	New				0.008	PyPI:esphome-device-builder	## Summary The dashboard reads its authentication credentials from <code>`\$ESPHOME_USERNAME`</code> and <code>`\$ESPHOME_PASSWORD`</code> . Earlier versions, and the legacy <code>`esphome`</code> dashboard, read the bare <code>`\$USERNAME`</code> and <code>`\$PASSWORD`</code> instead. When the env vars were renamed the bare names were dropped with no fallback, so an operator who had protected their dashboard with <code>`USERNAME`</code> / <code>`PASSWORD`</code> (as ...
CVE-2026-59823	New				0.004	PyPI:litellm	### Summary A server-side request forgery in LiteLLM Proxy lets an authenticated caller redirect the proxy's outbound request to a host of their choosing by smuggling an <code>`api_base`</code> inside the <code>`user_config`</code> request body, bypassing the existing parameter guard. ### Details LiteLLM Proxy validates request bodies with <code>`is_request_body_safe`</code> , which blocks the <code>`api_base`</code> and <code>`bas...</code>
CVE-2026-59971	New				0.004	PyPI:mysql-mcp-server	## Summary In SSE/HTTP transport mode, <code>`mysql_mcp_server`</code> constructs <code>`SseServerTransport`</code> without passing <code>`security_settings`</code> . As a result, the MCP Python SDK's DNS-rebinding protection (Origin/Host header validation) is disabled; the Starlette application has no CORS or TrustedHost middleware; and the service binds to <code>`0.0.0.0`</code> by default with no authentication on any rout...
CVE-2026-59980	New				0.003	PyPI:hpack	### Impact Users of the python-hyper/hpack library, most commonly used as downstream dependency of the python-hyper/h2 library (an HTTP/2 client and server implementation). Unbounded variable integer decoding can cause run-away computation on malformed input leading to $O(n^2)$ runtime, effectively blocking further processing with large enough unsanitized input. ### Patches ...
CVE-2026-59991	New				0.005	PyPI:psd-tools	### Summary <code>`PSDImage.composite()`</code> (and <code>`numpy()`</code>) allocate the output image buffer from the PSD's header geometry (width × height × channels × depth, and per-layer rectangles) before validating those values against the actual file contents. A tiny crafted PSD declaring huge dimensions causes a multi-gigabyte allocation. Critically, <code>`composite()`</code> then returns a (black) imag...
CVE-2026-61541	New				0.004	PyPI:zapros	### Impact **Who is impacted** : - Any application using Zapros to make HTTP requests to untrusted servers - Applications that follow redirects to attacker-controlled hosts **Attack vector** : - A malicious HTTP server returns a response with many chained content encodings. When the client attempts to decode, it creates a deeply nested decompression chain consuming exc...
CVE-2026-61570	New				0.003	PyPI:mpxj	### Impact MPXJ used the default configuration when creating a DocumentBuilder instance, which leaves doctype declarations enabled, when parsing the XML content of the ZTIMEINTERVALS column from a Merlin project SQLite file. This would allow a carefully crafted XML payload to read an arbitrary file. However, although an arbitrary file can be read, the way the resulting parse...
CVE-2026-61588	New				0.004	PyPI:djust	### Impact When a Django <code>`Model`</code> instance is assigned to a **public** view attribute, <code>`djust`</code> serialized it to the client with **no sensitive-field denylist** — sending fields such as <code>`password`</code> (the hash), privilege flags (e.g. <code>`is_staff`</code> / <code>`is_superuser`</code>), tokens, and other PII to the browser. Because exposing model objects to templates is a normal <code>`djust`</code> pattern, this could ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-61589	New				0.002	PyPI:djust	### Impact The WebSocket `handle_mount` and `ViewRuntime._build_request` rebuild an `HttpRequest` via `RequestFactory().get(...)` with no `HTTP_HOST`, so `request.get_host()` defaulted to "testserver" on the live path. Host/subdomain/domain `TenantResolver`s then misresolved the tenant — `None` on the live path while the HTTP path resolved correctly. With `STRICT_MODE=False`...
CVE-2026-61590	New				0.004	PyPI:djust	### Impact djst's observability endpoints expose live view/session state and a remote method-invocation surface (`eval_handler`). The localhost restriction was an **opt-in** middleware that the documented setup omits**, the views themselves enforced only `DEBUG`. In the misconfigured-but-documented scenario (DEBUG on, middleware not installed) a non-localhost client could rea...
CVE-2026-61591	New				0.002	PyPI:djust	### Impact For views that opt into state snapshots, the snapshot `state_json` embedded in the client page was restored on reconnect as **trusted** view state with no integrity check. A client could edit the unsigned `state_json` in their page and return it in the reconnect mount frame to **inject arbitrary view attributes** — e.g. flip `is_admin` to `True`, or change `account`...
CVE-2026-61592	New				0.004	PyPI:djust	### Impact SSE sessions were keyed solely by a **client-chosen** `session_id` with no binding to the authenticated user — a control the WebSocket transport has but that was dropped on SSE. An attacker who learns (or a victim who leaks) a `session_id` could connect to the message endpoint and dispatch event handlers that execute with the **victim's identity and state**. ### ...
CVE-2026-61593	New				0.002	PyPI:djust	### Impact The SSE client→server POST endpoints are `@csrf_exempt` and the SSE GET stream endpoint had no Origin check, so a cross-origin page could drive a victim-cookie-authenticated SSE session: force the victim's browser to GET the stream URL (which **creates and mounts** a LiveView as the victim) and POST to the message endpoint with `credentials: include` to **fire sta...
CVE-2026-61594	New				0.005	PyPI:djust	### Impact The live (WebSocket) transport authorizes a mount via `check_view_auth`, not Django's `View.dispatch()` chain. As a result, standard Django authorization — `LoginRequiredMixin`, `PermissionRequiredMixin`, `UserPassesTestMixin`, `@method_decorator(login_required, name="dispatch")`, and custom `dispatch()` guards — **and** the djst admin extension's staff gate (app...
CVE-2026-61595	New				0.004	PyPI:djust	### Impact `djust.tenants` isolation was enforced only on the HTTP path. The current tenant was stored in `threading.local()` and set exclusively by the HTTP-only `TenantMiddleware`, so on the live (WebSocket/SSE) path `get_current_tenant()` was always `None` during mount and every event handler — and the tenant-aware `QuerySet` manager failed **OPEN** (returned the unfilter...
CVE-2026-61596	New				0.003	PyPI:djust	### Impact djst's per-object authorization (`get_object` + `has_object_permission`, ADR-017) was enforced on the WebSocket **mount** and **event** paths but **not** on three other render entry points: (a) the initial **HTTP GET** render, (b) **SPA `url_change`** navigation, and (c) `{% live_render %}` **embedded child** views. An authenticated user could therefore view (and...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-61597	New				0.004	PyPI:djust	### Impact Many djst built-in component template tags (<code>djust.components.templatetags.*</code>) render a developer/user-supplied URL into an <code>`href`</code> / <code>`action`</code> attribute, HTML-escaping it with <code>`conditional_escape`</code> but **never validating the URL scheme** . HTML escaping prevents attribute breakout but does not neutralize a <code>`javascript:`</code> URI (which needs no escapable characters), so ...
CVE-2026-61598	New				0.004	PyPI:djust	### Impact <code>`djust.mixins.model_binding.ModelBindingMixin`</code> provides a default <code>`update_model`</code> event handler and is part of the **LiveView base MRO** , so every LiveView exposes it. It <code>`setattr`</code> s a view attribute whose **name is client-supplied** (<code>`field`</code>), gated only by: reject <code>`_`</code> -prefixed names; reject a **14-entry denylist** of framework internals (<code>`FORBIDDEN_MODEL_FIELDS`</code>);...
CVE-2026-61599	New				0.006	PyPI:djust	### Impact The djst live transport resolves the LiveView to mount from a **client-supplied dotted path** by calling <code>`__import__(module_path, ...)`</code> . The module is imported — running its **top-level code (import side effects)** — *before* the framework checks that the resolved object is a <code>`LiveView`</code> subclass and *before* any per-view authentication. The <code>`LIVEVIEW_ALLOWED_MODU...</code>
CVE-2026-61604	New				0.003	Go:github.com/ixofoundation/ixo-blockchain, Go:github.com/ixofoundation/ixo-blockchain/v3, Go:github.com/ixofoundation/i	ixo Blockchain x/bonds DID-resolved payer drain + x/entity ICA authorization bypass in github.com/ixofoundation/ixo-blockchain
CVE-2026-61652	New				0.004	PyPI:zapros	### Impact Denial of service via memory exhaustion. Affects all callers who streamed compressed responses relying on the chunk size — explicit (<code>`iter_bytes(chunk_size=...)`</code>) or the default — to bound memory. The decoder ignored that bound, so a chunk could be far larger than requested and a single compressed response could overflow memory. <code>`python import gzip, zapros # ...`</code>
CVE-2026-61681	New				0.003	Go:github.com/hatchet-dev/hatchet	Hatchet: SSRF via Unsigned UnsubscribeURL in SNS UnsubscribeConfirmation Handler in hatchet-dev/hatchet. NOTE: The source advisory for this report contains additional versions that could not be automatically mapped to standard Go module versions. (If this is causing false-positive reports from vulnerability scanners, please suggest an edit to the report.) The additional a...
CVE-2026-61732	New				0.012	PyPI:decepticon	## Summary Decepticon wraps web crawl results — the output of agent reconnaissance against target services — into LLM messages without neutralizing ChatML special-token literals. Under the BYOK (Bring Your Own Key) deployment model, users configure their own LLM credentials to any OpenAI-compatible endpoint. Most open-source and self-deployed model providers (vLLM, SGLang, ...
CVE-2026-62182	New				0.005	Go:github.com/kubeedge/kubeedge	KubeEdge: ConfigUpdateJob updateFields enables remote shell injection and code execution on edge nodes in github.com/kubeedge/kubeedge
CVE-2026-62282	New				0.004	PyPI:opencve	### Impact OpenCVE contains a Server-Side Request Forgery (SSRF) vulnerability in the notification testing functionality for both Webhook and Slack integrations. An authenticated user with permission to configure notification channels can trigger test requests to arbitrary HTTP(S) endpoints. Insufficient validation of target destinations allows requests to be sent to hosts...
CVE-2026-62286	New				0.003	Go:github.com/amir20/dozzle	Dozzle label filters do not restrict container event and statistics streams in github.com/amir20/dozzle

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-62364	New				0.001	PyPI:wlc	### Impact wlc could send an unscoped API token to an unintended server when run inside a directory tree containing attacker-controlled project configuration. If <code>.weblate</code> , <code>.weblate.ini</code> , or <code>weblate.ini</code> defines an API url, and the user supplies a token with <code>WLC_KEY</code> or <code>--key</code> without also pinning the URL, wlc would send the token to the project-configured URL. Impac...
CVE-2026-62369	New				0.006	Go:github.com/kubeedge/kubeedge	KubeEdge: keadm DecompressTarGz path traversal enables arbitrary file write on Windows during edge node join in github.com/kubeedge/kubeedge
CVE-2026-62370	New				0.005	Go:github.com/kubeedge/kubeedge	KubeEdge: Unbounded allocation in viaduct packer enables authenticated remote DoS against CloudHub in github.com/kubeedge/kubeedge
CVE-2026-62371	New				0.005	Go:github.com/kubeedge/kubeedge	KubeEdge: Command Injection in NodeUpgradeJob - RCE on edge nodes via v1alpha2 API in github.com/kubeedge/kubeedge
CVE-2026-62866	New				0.002	Go:github.com/tomwright/dasel, Go:github.com/tomwright/dasel/v2, Go:github.com/tomwright/dasel/v3	Dasel: Selector lexer panics on trailing whitespace in <code>parseCurRune</code> in github.com/tomwright/dasel
CVE-2026-62949	New				0.004	PyPI:asyncssh	## Summary A malicious SSH server can wedge an AsyncSSH <code>**client**</code> , and an authenticated client can wedge an AsyncSSH <code>**server**</code> , by sending a channel <code>maximum packet size</code> of <code>0</code> in <code>SSH_MSG_CHANNEL_OPEN_CONFIRMATION</code> (server→client) or <code>SSH_MSG_CHANNEL_OPEN</code> (client→server). AsyncSSH stores the peer-supplied value verbatim with no lower-bound check; the first time channel...
CVE-2026-62987	New				0.002	Go:github.com/fabiolb/fabio	Fabio - Incomplete fix for CVE-2025-48865: operator-configured trust headers (clientip/tls/requestid) still strippable via the Connection header in github.com/fabiolb/fabio
CVE-2026-63131	New				0.004	Go:github.com/openbao/openbao	OpenBao Skips Stricter Deny Policy for LIST operations in github.com/openbao/openbao
CVE-2026-63132	New				0.005	Go:github.com/openbao/openbao	OpenBao's Recovery Mode Vulnerable To Token Leakage via Timing Attack in github.com/openbao/openbao
CVE-2026-63342	New				0.003	Go:github.com/hatchet-dev/hatchet	Hatchet: Cross-Tenant Durable Task Event Log Disclosure via Missing Authorization Check in github.com/hatchet-dev/hatchet
CVE-2026-63349	New				0.001	PyPI:anyio	AnyIO 4.14.0 accepts the POSIX <code>extra_groups</code> argument on <code>anyio.run_process()</code> and <code>anyio.open_process()</code> , but <code>open_process()</code> forwards the wrong variable to the backend: when <code>extra_groups</code> is not <code>None</code> , it assigns <code>kwargs["extra_groups"] = group</code> instead of <code>extra_groups</code> . As a result, callers cannot reliably clear or set supplementary groups for child processes. In a disposable Linux ...
CVE-2026-63374	New				0.003	PyPI:anyio	### Impact Services using internationalized (non-ASCII) domain names are potentially vulnerable to TLS connections made from AnyIO's <code>connect_tcp()</code> or directly via <code>TLSSStream.wrap()</code> where the connection has (through other means) been hijacked and redirected to a malicious server. The attacker would obtain a legitimate certificate using the IDNA 2003 encoded version of the ...
CVE-2026-63721	New						Rejected reason: This CVE ID has been rejected or withdrawn by its CVE Numbering Authority.
CVE-2026-63724	New						Rejected reason: This CVE ID has been rejected or withdrawn by its CVE Numbering Authority.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-64847	New				0.002	PyPI:anyio	### Impact AnyIO starts process-pool workers with stderr connected to a pipe but never drains that pipe. The worker redirects stdin and stdout to /dev/null to protect its protocol, but does not redirect stderr even though the documentation says all three standard streams are redirected. Worker code that writes enough attacker-influenced data to stderr can fill the pipe, bloc...
CVE-2026-65829	New				0.003	PyPI:mpxj	### Impact When reading a suitably crafted PRX or STX file, MPXJ can be made to write files to arbitrary locations in the file system. ### Patches This issue is addressed in MPXJ version 16.5.0. ### Workarounds Do not read PRX or STX files from untrusted sources.
CVE-2026-68770	New				0.009	PyPI:sentence-transformers	sentence-transformers contains a security control bypass vulnerability that allows attackers to achieve arbitrary code execution by exploiting a logic flaw in the import_module_class helper within sentence_transformers/util/misc.py, where the guard condition includes an 'or os.path.exists(model_name_or_path)' clause that satisfies the trust gate whenever the supplied path ex...
CVE-2026-69085	New		CRIT		0.015	Go:github.com/siyuan-note/siyuan/kernel	### Summary The `/api/filetree/searchDocs` endpoint concatenates the caller-supplied search keyword directly into a SQL statement with no escaping and no parameter binding. The endpoint is gated by `CheckAuth` only reachable by the publish RoleReader token, and by the anonymous account when `Publish.Auth.Enable` is `false`. The resulting statement runs on a read-write SQLite...
CVE-2026-69147	New				0.005	PyPI:vllm	## Summary Current vLLM `main` lets an inference request choose the PyNvVideoCodec GPU video decoder through `media_io_kwargs.video.video_backend`, but engine GPU memory reservation is computed only from static startup configuration and `VLLM_VIDEO_LOADER_BACKEND`. If the server starts with the default OpenCV/software backend and no `--mm-ipc-gpu-memory-gb` budget, a client...
CVE-2026-71543	New				0.004	Go:github.com/openbao/openbao	OpenBao's Templated Policies Allow Privilege Escalation via Wildcard Characters in github.com/openbao/openbao
CVE-2026-72788	New		MODE		0.004	Go:github.com/siyuan-note/siyuan/kernel	### Summary `/api/system/getConf` serves `Conf.UILayout` to publish readers after passing it through `FilterConfByPublishIgnore`, whose only function is to filter that layout. The layout is written exclusively by `setUILayout`, which is administrator-gated, so what readers receive is the administrator's own live workspace state, re-saved on every tab open, close and focus c...
CVE-2026-73605	New		MODE		0.003	Go:github.com/siyuan-note/siyuan/kernel	### Summary `/api/file/getUniqueFilename` takes a path from the request body and passes it to a filesystem existence check with no validation, confinement or authorization. The response distinguishes paths that exist from paths that do not, so an anonymous reader in publish mode can probe arbitrary locations on the host, one request per probe. Files and directories both wor...
CVE-2026-73606	New		MODE		0.003	Go:github.com/siyuan-note/siyuan/kernel	### Summary `/api/block/getRefIDs` filters its results for reader roles through a helper that checks only the visibility tiers. The password tier is not checked, because the helper does not receive the request context and therefore cannot evaluate the publish auth cookie. A reader who has not entered a document's publish password learns that the document references a given ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-73607	New		MODE		0.003	Go:github.com/siyuan-note/siyuan/kernel	### Summary `/api/storage/getOutlineStorage` is registered with `CheckAuth` only and performs no authorization of any kind. Given a document identifier it returns that document's stored outline state, regardless of the document's publish tier. The two write endpoints for the same data, `setOutlineStorage` and `removeOutlineStorage`, both carry `CheckAdminRole` and `CheckRe...
CVE-2026-73609	New		MODE		0.003	Go:github.com/siyuan-note/siyuan/kernel	### Summary `/api/attr/getBookmarkLabels` is registered with `CheckAuth` only and applies no filtering of any kind. It runs a scan of the entire `blocks` table and returns the distinct set of every bookmark label in the workspace. An anonymous reader in publish mode receives the author's complete bookmark vocabulary, regardless of whether the bookmarked blocks live in publi...
CVE-2026-76802	New				0.002	Go:github.com/projectdiscovery/nuclei, Go:github.com/projectdiscovery/nuclei/v2, Go:github.com/projectdiscovery/nuclei/v	Nuclei: Arbitrary Command Execution via DAST Code Signature Bypass in github.com/projectdiscovery/nuclei
CVE-2026-76803	New				0.004	Go:github.com/projectdiscovery/nuclei, Go:github.com/projectdiscovery/nuclei/v2, Go:github.com/projectdiscovery/nuclei/v	Nuclei: Local File Read via MySQL Client Sandbox Bypass in github.com/projectdiscovery/nuclei
CVE-2026-76804	New				0.002	Go:github.com/projectdiscovery/nuclei, Go:github.com/projectdiscovery/nuclei/v2, Go:github.com/projectdiscovery/nuclei/v	Nuclei: Local File Read via Workflow File-Protocol Gate Bypass in github.com/projectdiscovery/nuclei
CVE-2026-76805	New				0.004	Go:github.com/projectdiscovery/nuclei, Go:github.com/projectdiscovery/nuclei/v2, Go:github.com/projectdiscovery/nuclei/v	Nuclei: Environment Variable Disclosure via Response-Derived Data in DAST/Fuzz Mode in github.com/projectdiscovery/nuclei
CVE-2026-76819	New					Go:github.com/projectdiscovery/nuclei, Go:github.com/projectdiscovery/nuclei/v2, Go:github.com/projectdiscovery/nuclei/v	Nuclei: Arbitrary Code Execution via Goja JavaScript Engine Vulnerability in github.com/projectdiscovery/nuclei
CVE-2026-76825	New				0.006	PyPI:restrictedpython	### Impact RestrictedPython could allow a sandbox escape when a policy exposes the standard library `string` module, or otherwise exposes `string.Formatter`, to restricted code. `string.Formatter` field resolution methods such as `get_field` can perform attribute and item traversal internally and return live object references. This can bypass RestrictedPython's normal attri...
CVE-2026-77243	New				0.003	PyPI:mcp-atlassian	### Summary `ENABLED_TOOLS` and `TOOLSETS` filters are enforced at `tools/list` time only. `tools/call` dispatches from the full unfiltered tool registry (73 tools). Any user with access to the server endpoint that knows a tool name can invoke it directly. Tool names are not secret since mcp-atlassian is open source. Any direct JSON-RPC call bypasses the restriction entirel...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-77244	New				0.003	PyPI:mcp-atlassian	**Description** mcp-atlassian deploys in two common patterns: Pattern A (single-user, server-side credentials): operator sets JIRA_USERNAME + JIRA_API_TOKEN (or CONFLUENCE_USERNAME + CONFLUENCE_API_TOKEN) in environment variables. Server uses these to call Jira/Confluence. This is the documented quickstart pattern. Pattern B (multi-user, OAuth or per-reque...
CVE-2026-77246	New				0.004	PyPI:mcp-atlassian	### Summary The `mcp-atlassian` server exposes an MCP tool (`confluence_upload_attachment` and the Jira attachment variant) that accepts an arbitrary server-side file path and opens it for upload without any path validation. When the server is deployed in HTTP transport mode (`streamable-http` or `sse`), a remote, unauthenticated attacker can supply attacker-controlled Atla...
CVE-2026-77247	New				0.004	PyPI:mcp-atlassian	## Summary The Jira and Confluence attachment upload tools accept caller-controlled file path parameters and read those paths from the MCP server's local filesystem before uploading the file as an Atlassian attachment. In local `stdio` deployments, this can expose files readable by the user's MCP process. In documented HTTP/SSE or `streamable-http` deployments, the impact ...
CVE-2026-77248	New				0.004	PyPI:mcp-atlassian	### Summary In the documented multi-user HTTP deployment (`--transport streamable-http` with global operator Atlassian credentials), sooper/mcp-atlassian exposes all tools to **unauthenticated network clients** , and the `upload_attachment` tool reads an attacker-supplied `file_path` with **no path validation** . Chained, an unauthenticated network attacker reads arbitrary ...
CVE-2026-77249	New				0.003	PyPI:mcp-atlassian	Summary The fix for the SSRF vulnerability tracked as GHSA-7r3d-79r5-rcc9 / CVE-2026-27826 is incomplete. That fix added two defenses: `validate_url_for_ssrf()` on the per-request X-Atlassian-Jira-Url / X-Atlassian-Confluence-Url headers (blocking a directly-internal base URL), and a redirect-validation hook (`_make_ssrf_safe_hook`) attached to the fetcher's HTTP session so tha...
CVE-2026-77250	New				0.001	PyPI:mcp-atlassian	### Summary When OAuth tokens are saved, MCP Atlassian always writes a plaintext fallback copy under `~/.mcp-atlassian/oauth-<client_id>.json`. The fallback file is created with the process default umask rather than restrictive permissions. In this environment the file was created as mode `0664`, exposing access and refresh tokens to same-group local users and any process t...
CVE-2026-77251	New				0.002	PyPI:mcp-atlassian	### Summary `mcp-atlassian` is a popular community MCP server wrapper exposing Jira / Confluence to MCP clients. Operators commonly restrict the surface to a small allowlist of projects/spaces via the `JIRA_PROJECTS_FILTER` and `CONFLUENCE_SPACES_FILTER` environment variables, which the README documents as the principal mechanism for limiting attacker-controlled MCP clients...
CVE-2026-77253	New				0.004	PyPI:mcp-atlassian	### Summary MCP Atlassian exposes Jira and Confluence attachment upload tools that accept arbitrary local filesystem paths and upload those file contents to Atlassian. In HTTP or multi-user deployments, an MCP caller who can invoke write tools can cause the server to read any file accessible to the MCP process and send it to Jira/Confluence as an attachment. ### Details T...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-77255	New				0.004	PyPI:mcp-atlassian	### Summary A critical Confused Deputy (Arbitrary File Read & Exfiltration) vulnerability in the Atlassian MCP server (Python) allows an AI agent to exfiltrate sensitive host files and environment secrets. By providing absolute system paths to the attachments parameter of the update_issue tool, an agent can force the privileged MCP process to read and upload any file it has ...
CVE-2026-77257	New				0.004	PyPI:mcp-atlassian	# sooperset/mcp-atlassian: HTTP upload tools can attach arbitrary server-local files Date: 2026-05-05 Target: `sooperset/mcp-atlassian` Commit: `d8bc78698a63cb6b321c7ca796d6329d448f7f6d` ## Summary `mcp-atlassian` supports HTTP/SSE deployment for persistent, remote, and multi-user use. In that mode, write-capable Jira and Confluence attachment flows accept caller-controll...
CVE-2026-77258	New				0.003	PyPI:mcp-atlassian	## Summary The `upload_attachment` method in `confluence/attachments.py` reads and uploads arbitrary local files to Confluence without calling `validate_safe_path()`. Both download methods (`download_attachment` at line 223, `download_content_attachments` at line 272) correctly call `validate_safe_path()` before writing files, but the upload path at lines 35-79 skips this c...
CVE-2026-77259	New				0.004	PyPI:mcp-atlassian	### Summary Missing path validation in `confluence_upload_attachment` allows any authenticated MCP client to read arbitrary files from the server filesystem and exfiltrate their contents to Confluence. On Linux deployments, `/proc/self/environ` yields all runtime secrets in a single call. --- ### Details `AttachmentsMixin.upload_attachment()` in `src/mcp_atlassian/conflue...
CVE-2026-77260	New				0.003	PyPI:mcp-atlassian	## Summary This is an arbitrary local file READ vulnerability on the Confluence and Jira `upload_attachment` tool paths. It's the symmetric counterpart of the file-write vulnerability you patched as CVE-2026-27825. The write direction was fixed; the read direction was left open. **Reporter:** Sean Valentine **Severity:** High (Critical in LLM-driven / prompt-injection depl...
CVE-2026-77261	New				0.003	PyPI:mcp-atlassian	### Summary `_make_ssrf_safe_hook()` blocks HTTP redirects to private/internal IPs by validating the `Location` header before the client follows a `3xx` response. The problem is that this hook is only attached in one of three authentication branches — the header-PAT path. Basic auth and OAuth branches skip it entirely, so if the connected Atlassian server returns a redirect...
CVE-2026-77262	New				0.005	PyPI:mcp-atlassian	## Summary `mcp-atlassian` exposes an MCP tool `confluence_upload_attachment` whose `file_path` argument is passed directly to `open(file_path, "rb")` without any path validation. An attacker able to invoke the tool can read arbitrary files readable by the server process and exfiltrate them into a multipart upload directed at an attacker-controlled Confluence host. In the d...
CVE-2026-77265	New				0.003	PyPI:mcp-atlassian	## Summary The SSRF protection for header-based authentication uses a validate-then-use pattern vulnerable to DNS rebinding. `validate_url_for_ssrf` resolves the hostname via DNS and checks that the resolved IP is globally routable. However, the actual HTTP request happens later, during which the DNS record may have changed to point to an internal IP (127.0.0.1, 169.254.169.2...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-77266	New				0.004	PyPI:mcp-atlassian	### Summary The `upload_attachment` functions in both the Jira and Confluence modules accept a user-controlled `file_path` parameter and open the specified file for reading without calling `validate_safe_path()` . An authenticated MCP client can supply an arbitrary path such as `/etc/passwd` or `/proc/self/environ`, causing the server process to read and transmit the fil...
CVE-2026-77267	New				0.003	PyPI:mcp-atlassian	### Summary The `UserTokenMiddleware` extracts URLs from `X-Atlassian-Jira-Url` and `X-Atlassian-Confluence-Url` HTTP headers and passes them directly to API client constructors without any SSRF validation. ### Affected Package - Ecosystem: PyPI - Package: mcp-atlassian - Affected versions: all versions before fix commit 5cd697dfce91 - Patched versions: >=...
CVE-2026-77268	New				0.001	PyPI:mcp-atlassian	## Summary The OAuth token fallback file storage in `OAuthConfig._save_tokens_to_file()` creates token files containing access tokens, refresh tokens, and cloud IDs with default filesystem permissions (typically `0644` on Linux, world-readable). Any local user on a shared system can read these files to obtain full Atlassian API credentials, enabling unauthorized access to t...
CVE-2026-77269	New				0.004	PyPI:mcp-atlassian	### Summary The `confluence_upload_attachment` and `confluence_upload_attachments` MCP tools accept a `file_path` parameter and do not validate that the path is confined to an allowed directory before opening the file. An attacker who can call these tools can read any file accessible to the MCP server process (SSH keys, .env files, API credentials) and exfiltrate it by uplo...
CVE-2026-77270	New				0.004	PyPI:mcp-atlassian	## Summary The upload attachment tools in both Confluence and Jira accept arbitrary file paths without path traversal validation. The upload_attachment methods read any file accessible to the server process and upload it to a Confluence page or Jira issue. Despite the existence of a validate_safe_path utility function (used correctly in download operations), the upload path...
CVE-2026-77271	New				0.005	PyPI:mcp-atlassian	### Summary The path traversal fix introduced in v0.17.0 (GHSA-xjgw-4www-rgm4) is incomplete. `validate_safe_path()` is called without an explicit `base_dir`, defaulting to `os.getcwd()`. In standard container deployments the process CWD is the application directory (e.g. `/app`), so paths within that directory, including the application's own Python source modules, pass va...
CVE-2026-77272	New				0.002	PyPI:mcp-atlassian	## Summary The OAuth 2.0 setup wizard's local callback HTTP server reflects the `error` query parameter directly into an HTML response without any sanitization or encoding. An attacker can craft a malicious callback URL containing JavaScript in the `error` parameter that executes in the victim's browser when the setup wizard is running. The server binds to all network inter...
CVE-2026-77274	New				0.003	PyPI:mcp-atlassian	## Environment - Project: `sooperset/mcp-atlassian` - Affected function: `validate_url_for_ssrp()` - Affected path: header-based Jira/Confluence URL authentication flow - Tested endpoint: `POST /mcp` - Tested version: `2.14.5` ## Description The SSRF protection in `validate_url_for_ssrp()` can be bypassed with a URL containing a backslash before userinfo-like syntax. Aff...
CVE-2026-77281	New				0.005	Go:github.com/caddyserver/caddy/v2	Rewrite placeholder re-expansion, unbounded body buffer DoS, and fileHidden case-sensitivity bypass in github.com/caddyserver/caddy
CVE-2026-77285	New				0.001	Go:github.com/openbao/openbao	OpenBao Agent Writes Secrets to Stdout in github.com/openbao/openbao

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-77322	New				0.005	Go:github.com/emiago/sipgo	SIPGO: DoS via unvalidated WebSocket frame length in github.com/emiago/sipgo
CVE-2026-77401	New				0.005	PyPI:accesscontrol	### Impact Python's string `format` functionality allows someone controlling the format string to "read" objects accessible (recursively) via attribute access and subscription from accessible objects. Those attribute accesses and subscriptions use Python's full blown `getattr` and `getitem`, not the policy restricted `AccessControl` variants `_getattr_` and `_getitem_`. This...
CVE-2026-77403	New				0.005	Go:github.com/rabbitmq/amqp091-go	RabbitMQ amqp091-go: Denial of Service via Sub-Spec Frame Size Negotiation in github.com/rabbitmq/amqp091-go
CVE-2026-77404	New				0.001	Go:github.com/rabbitmq/amqp091-go	RabbitMQ amqp091-go: Connection Configuration Overwrite via Unsanitized TLS Path Parameter Injection in github.com/rabbitmq/amqp091-go
CVE-2026-77405	New				0.003	Go:github.com/rabbitmq/amqp091-go	RabbitMQ amqp091-go: Missing Explicit TLS Minimum Version Configuration In URI Parser in github.com/rabbitmq/amqp091-go
CVE-2026-77406	New				0.004	Go:github.com/rabbitmq/amqp091-go	RabbitMQ amqp091-go: Consumer Message Flooding via Signed-to-Unsigned Integer Casting in Qos Configuration in github.com/rabbitmq/amqp091-go
CVE-2026-77407	New				0.001	Go:github.com/rabbitmq/amqp091-go	RabbitMQ amqp091-go: Plaintext Credential Exposure via Exported PLAIN Authentication Struct Fields in github.com/rabbitmq/amqp091-go
CVE-2026-77408	New				0.005	Go:github.com/rabbitmq/amqp091-go	RabbitMQ amqp091-go: Silent Data Truncation and State Corruption via Shortstr Integer Overflow in github.com/rabbitmq/amqp091-go
CVE-2026-77410	New				0.005	Go:github.com/rabbitmq/amqp091-go	RabbitMQ amqp091-go: Resource Exhaustion (OOM) via Unbounded Body Buffer Allocation in github.com/rabbitmq/amqp091-go
CVE-2026-77411	New				0.005	Go:github.com/rabbitmq/amqp091-go	RabbitMQ amqp091-go: Protocol Desynchronization and Frame Injection via Integer Overflow in readLongstr in github.com/rabbitmq/amqp091-go
CVE-2026-77412	New				0.005	Go:github.com/rabbitmq/amqp091-go	RabbitMQ amqp091-go: Denial of Service via Malicious Field Length in AMQP Client in github.com/rabbitmq/amqp091-go
CVE-2026-77528	New				0.005	PyPI:autobahn	### Summary Autobahn Python enforces `maxMessagePayloadSize` against the compressed WebSocket frame length before permmessage-deflate inflation, then delivers the inflated message to application callbacks without a second size check. A client frame that is only 22 compressed bytes can inflate to 4096 bytes and reach `onMessage` even when the application configured a 128-byte ...
CVE-2026-77560	New				0.006	Go:github.com/tinyauthapp/tinyauth	Tinyauth: forward-auth per-app ACL is matched case-sensitively against the (case-insensitive) hostname, letting an authenticated user reach apps they are not on the allowlist for in github.com/tinyauthapp/tinyauth
CVE-2026-77561	New				0.006	Go:github.com/tinyauthapp/tinyauth	Tinyauth: Unauthenticated login attempts can trigger global login lockdown denial of service in github.com/tinyauthapp/tinyauth
CVE-2026-77582	New				0.005	Go:github.com/tinyauthapp/tinyauth	Tinyauth: User enumeration attack by timing oracle in github.com/tinyauthapp/tinyauth
CVE-2026-77633	New				0.004	Go:github.com/cloudreve/Cloudreve, Go:github.com/cloudreve/Cloudreve/v3, Go:github.com/cloudreve/Cloudreve/v4	Cloudreve: Storage-quota TOCTOU race allows quota bypass and storage-based denial of service in github.com/cloudreve/Cloudreve

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-77637	New				0.003	Go:github.com/cloudreve/Cloudreve, Go:github.com/cloudreve/Cloudreve/v3, Go:github.com/cloudreve/Cloudreve/v4	Cloudreve: Privilege Scope Bypass: State-Mutating Admin Operations Accessible via Read-Only OAuth Scope in github.com/cloudreve/Cloudreve
CVE-2026-79767	New				0.004	Go:github.com/gardener/gardener	Gardener: Authorization Bypass via Group Subject Injection in gardener/gardener. NOTE: The source advisory for this report contains additional versions that could not be automatically mapped to standard Go module versions. (If this is causing false-positive reports from vulnerability scanners, please suggest an edit to the report.) The additional affected modules and vers...
CVE-2026-79913	New				0.004	Go:github.com/cloudreve/Cloudreve, Go:github.com/cloudreve/Cloudreve/v3, Go:github.com/cloudreve/Cloudreve/v4	Cloudreve: SSRF guard bypass: checkIP does not decode IPv6-transition wrappers (NAT64, IPv4-compatible, 6to4) reaching internal and cloud-metadata addresses in github.com/cloudreve/Cloudreve
CVE-2026-80047	New				0.001	PyPI:transformers	A vulnerability in Hugging Face Transformers (versions 4.49.0, <= 5.8.1) allows remote Python files to be written to local disk without user consent when using GenerativePreTrainedModel.load_custom_generate(). The function fetches and caches a remote module file before performing the required trust_remote_code consent check, inverting the security model enforced by other cod...
CVE-2026-81740	New						The Paytm Payment Gateway WordPress plugin before 2.8.9 does not verify that payment callbacks genuinely originate from the payment provider when its secret key has not been configured, which is its state immediately after activation, allowing unauthenticated attackers to change the status of arbitrary orders, including marking unpaid orders as paid and reducing stock.
CVE-2026-81869	New				0.002	Go:go.opentelemetry.io/otel/sdk	OpenTelemetry-Go: UTF-8 replacement rune bypasses attribute length truncation in go.opentelemetry.io/otel/sdk
CVE-2026-81870	New				0.002	Go:go.opentelemetry.io/otel/exporters/otlp/otlptrace, Go:go.opentelemetry.io/otel/exporters/otlp/otlptrace/otlptracegrpc	OpenTelemetry-Go: Exporter config logging may leak endpoint URLs in info logs in go.opentelemetry.io/otel/exporters/otlp/otlptrace
CVE-2026-81872	New				0.004	Go:go.opentelemetry.io/otel/sdk/log	OpenTelemetry-Go: BatchProcessor can busy-spin when export buffer is full in go.opentelemetry.io/otel/sdk/log
CVE-2026-82405	New				0.003	Go:github.com/klever-io/klever-go	Klever-Go Account takeover: `kleverUpdateAccountPermission` authorizes on attacker-controlled `RecipientAddr` instead of the authenticated caller in github.com/klever-io/klever-go
CVE-2026-82406	New				0.003	Go:github.com/klever-io/klever-go	Klever-Go: Zombie-order theft: `Buy` missing `IsClaimed` guard in native marketplace in github.com/klever-io/klever-go
CVE-2026-82407	New				0.004	Go:github.com/klever-io/klever-go	Klever-Go: Validator registration accepts an unvalidated BLS public key → consensus liveness DoS in github.com/klever-io/klever-go
CVE-2026-82409	New				0.003	Go:github.com/klever-io/klever-go	Klever-Go: Elasticsearch bulk / painless injection via on-chain account name -> explorer/indexer data forgery in github.com/klever-io/klever-go

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-83801	New				0.002	PyPI:nautobot	### Impact _What kind of vulnerability is it? Who is impacted?_ It has two related instances that share the same root cause: a user-controlled model field is assigned verbatim to a form field's `help_text`, which is rendered with Django's ` safe` filter (`render_field.html`), bypassing auto-escaping. In both cases the script executes in the browser of any user who opens an...
CVE-2026-83805	New				0.002	PyPI:nautobot	### Impact This is an authorization bypass that escalates into unauthorized server-side job execution. 1. Primary impact - self-approval: The approver checks (approver-group membership, `change` permission on the object under review, one-response-per-user) are enforced only in the `approve`/`deny` actions on `ApprovalWorkflowStage`. The generic `ApprovalWorkflowStageRespons...
CVE-2026-84298	New				0.002	Go:github.com/hatchet-dev/hatchet	Hatchet: Cross-tenant durable callback payload disclosure in Hatchet V1 Dispatcher in github.com/hatchet-dev/hatchet
CVE-2026-84377	New				0.005	PyPI:litellm	### Impact Any authenticated LiteLLM proxy user could redirect an outbound provider call to a destination they control and cause the proxy to send its own configured provider credentials to that destination. The proxy's request-body validation was a denylist that did not cover every sensitive parameter and did not inspect parameters nested inside other request fields, so a ...
CVE-2026-85004	New						The Popup Maker WordPress plugin through 1.4.5 does not perform a capability check on one of its account-connection actions, only verifying a nonce, allowing authenticated users with minimal privileges such as Subscribers to overwrite a site-wide Popup Maker WordPress plugin through 1.4.5 option (the linked service account and API configuration) that should only be modifia...
CVE-2026-85016	New						The Unlimited Elements for Elementor WordPress plugin before 2.0.21 does not escape an icon value before concatenating it into an HTML attribute in its shared widget-parameter processor, allowing users with Contributor access (who do not hold unfiltered_html) to store a payload that executes when the page is rendered.
CVE-2026-85056	New				0.003	Go:github.com/zitadel/zitadel	ZITADEL: MFA bypass via session reuse in Login V2 in github.com/zitadel/zitadel
CVE-2026-85057	New				0.004	Go:github.com/zitadel/zitadel	ZITADEL: Actions V1 sandbox escape: host file read via require() in github.com/zitadel/zitadel
CVE-2026-85078	New				0.005	PyPI:sanic	## Description Sanic's HTTP/1.1 chunked-body handling does not fully consume the `trailer-part` after the terminating `0\r\n` chunk. Because of that, attacker-controlled bytes left in the connection buffer after the first chunked request can be interpreted as the start of a new HTTP request on the same keep-alive connection. In the attached verified proof, a single outer `P...
CVE-2026-85709	New				0.004	PyPI:lightrag-hku	### Summary The LightRAG API server passes raw Python exception messages directly into HTTP error responses across 30+ error handlers in every router. When combined with the default unauthenticated configuration (see companion report on CWE-306), any network-reachable client can trigger exceptions whose raw text discloses internal infrastructure — server filesystem paths, d...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-85725	New				0.004	PyPI:lightrag-hku	### Summary When plaintext passwords are stored in AUTH_ACCOUNTS, the comparison uses Python's == operator which is not constant-time. An attacker with low-latency access can exploit timing differences to recover the password character by character. ### Details ```python # lightrag/api/passwords.py:13-26 def verify_password(plain_password: str, stored_password: str) -> boo...
CVE-2026-85731	New				0.006	Go:oras.land/oras-go/v2	Arbitrary file write outside file.Store root via symlink-chain bypass in tar extraction (pushDir) in oras.land/oras-go
CVE-2026-85732	New				0.003	Go:oras.land/oras-go/v2	Blind SSRF via unvalidated Link header URL in pagination allows internal network probing in oras.land/oras-go
CVE-2026-85734	New				0.004	PyPI:lightrag-hku	### Summary The POST /login endpoint has no rate limiting, account lockout, or delay on failed attempts. An attacker can submit unlimited password guesses at full network speed. ### Details ```python # lightrag/api/lightrag_server.py:2161 @app.post("/login") async def login(form_data: OAuth2PasswordRequestForm = Depends()): if not auth_handler.verify_password(username,...
CVE-2026-85740	New				0.002	PyPI:lightrag-hku	## Summary LightRAG's native markdown parser downloads external images referenced by an uploaded markdown or textpack document. The only SSRF guard, `_validated_addresses()` in `lightrag/parser/markdown/parser.py`, resolves the image host and rejects it when the resolved IP is not `is_global`. That check is evaluated on the raw resolved address and never decodes IPv6 transi...
CVE-2026-85999	New				0.006	PyPI:soupsieve	## Summary Before tokenizing, `selector_iter` trims leading/trailing whitespace and comments by running two regexes over the whole raw selector with `.search()`. The trailing one, `RE_WS_END = re.compile(r'{WSC}*\$')`, is anchored only at the end (`\$`), not the start. Because `.search()` retries the pattern at every offset, a long run of whitespace or CSS comments that is no...
CVE-2026-86000	New				0.006	PyPI:soupsieve	## Summary soupsieve compiles CSS selector strings with a set of hand-written regular expressions. The shared `IDENTIFIER` sub-pattern (also embedded in `VALUE`, and therefore in attribute selectors) places two adjacent quantified groups over overlapping character classes: `(?:[classA] ESC)+(?:[classB] ESC)*`, where both classes match ordinary identifier characters such as ...
CVE-2026-86049	New				0.004	PyPI:jupyter-server	### Summary When a request returns a 500, `jupyter_server/log.py` logs a small JSON block of request headers. The Referer header was copied into it as-is, so a token in the Referer URL ended up in the logs in plain text. ### Impact Anyone who can read the server logs can pick tokens out of these 500 entries. Tokens end up in the Referer during normal token-based login a...
CVE-2026-86062	New				0.002	PyPI:lightrag-hku	### Summary The LightRAG WebUI renders assistant/answer chat content as raw HTML — `react-markdown` is configured with `rehypePlugins=[rehypeRaw]` and `skipHtml={false}` and no HTML sanitizer (`rehype-sanitize`), element allow-list, or custom `urlTransform`. Because answer content is derived from user-ingested documents, an attacker who can add a single document ca...
CVE-2026-86064	New				0.004	Go:github.com/klever-io/klever-go	Klever-Go: /log controls global node logging in github.com/klever-io/klever-go

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-86065	New				0.004	Go:github.com/klever-io/klever-go	Klever-Go: Unauthenticated WebSocket /subscribe: no read-size limit, no connection cap, permissive origin -> remote node memory/goroutine exhaustion (DoS) in github.com/klever-io/klever-go
CVE-2026-87011	New				0.006	PyPI:open-webui	## Summary The OIDC back-channel logout endpoint is unauthenticated by design, because the identity provider calls it without a browser session. Before checking whether the submitted logout token was genuine, the handler fetched the provider's discovery document and its signing keys over the network, and repeated both fetches on every request because nothing was cached. The...
CVE-2026-87012	New				0.005	PyPI:open-webui	# Any authenticated user can suppress calendar alerts instance-wide via a non-numeric alert value ## Summary Calendar events carry a free-form `meta` object that is stored exactly as submitted, with no validation of the values inside it. The scheduler reads the per-event alert offset out of that object in a single pass that covers every user's upcoming events, and compares...
CVE-2026-87013	New				0.005	PyPI:open-webui	## Summary Any authenticated user can move one of their own folders under itself, leaving a loop in their folder tree. The re-parent endpoint performed no check that the new parent was not the folder itself or one of its own subfolders, and the folder tree walks did not track which folders they had already visited. A single request against a folder in a loop therefore never ...
CVE-2026-87014	New				0.005	PyPI:open-webui	## Summary A user who is demoted from admin by an identity provider keeps admin-level read and write access to every user's notes, over any Socket.IO connection that was already open when the demotion happened. Open WebUI caches the user's role on the socket at connection time, and the two SSO role-sync paths, the reverse-proxy trusted role header and OAuth role mapping, ch...
CVE-2026-87015	New				0.005	PyPI:open-webui	## Summary When more than one external tool server is reachable in the same request, a tool call to a server configured for bearer authentication can arrive carrying the calling user's Open WebUI session cookies alongside that server's own key. The cookie jar is built per connection, but the callable that performs the request reads it late instead of per connection, so ever...
CVE-2026-87016	New				0.006	PyPI:open-webui	## Summary On SQLite deployments, the lookup that maps an external identity to a local account does a substring match instead of an exact match. A subject value containing SQL wildcard characters therefore matches accounts the value was never issued for, and the sign-in binds to whichever account the database returns first, which can be an administrator. The same defect aff...
CVE-2026-87017	New				0.004	PyPI:open-webui	## Summary The built-in knowledge search tool returns knowledge bases the calling user has no access to. The tool works out which knowledge bases the caller may read and hands that set to the vector store as a search filter, and that filter is the only access control on the path. Most of the shipped vector backends accept the filter argument on their search method and never ...
CVE-2026-87994	New				0.004	PyPI:open-webui	## Summary Any member of a channel who can post to it could also replace the text of a message written by a different member. The channel branch of the chat completions endpoint checked that the caller may write to the channel, and that the targeted message belongs to that channel, but never checked that the caller actually wrote the message being edited. The message kept it...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-87995	New				0.004	PyPI:open-webui	## Summary Any authenticated user with access to a shared terminal server could get script of their choosing to run in the Open WebUI origin itself. The in-app port preview rendered the content of a previewed port in an iframe whose sandbox always granted `allow-same-origin` alongside `allow-scripts`, and that content is served from a path on the application's own origin, so...
CVE-2026-87996	New				0.004	PyPI:open-webui	## Summary With the Playwright web loader enabled, Open WebUI checks the address behind a user-submitted URL before allowing the request, then handed the request to the browser to perform. The browser resolved the hostname a second time, on its own, and that answer was never checked. An attacker who controls the authoritative DNS for a hostname they submit can answer the fir...
CVE-2026-87997	New				0.004	PyPI:open-webui	## Summary The chat-completions endpoint reads a folder id out of the request body and saves the newly created chat into that folder without checking that the caller is allowed to write there. Any authenticated user who knows a folder's id can put a chat of their own into another user's folder, including a shared folder where they hold read-only access and a folder they have...
CVE-2026-87998	New				0.005	PyPI:open-webui	## Summary External knowledge connections are created and owned by administrators, and are shared by every external knowledge base bound to them. Deleting an external knowledge base also removed that connection from the instance configuration, with no check on the caller's role and no check for other knowledge bases still using it. Any authenticated user holding a write gran...
CVE-2026-87999	New				0.004	PyPI:open-webui	## Summary Open WebUI fetches user-supplied URLs on the server for RAG URL ingestion and web search, and screens the resolved addresses so internal destinations cannot be reached. That screen decided whether a destination was external by asking Python's standard library whether the address is globally routable. Several addresses reserved for internal use answer yes to that ...
CVE-2026-88005	New				0.004	PyPI:open-webui	## Summary Open WebUI's OAuth token exchange endpoint issues a session for a provider access token without applying the email domain allowlist that the normal OAuth login callback enforces. An account whose email domain the login callback would refuse could still obtain a working session through this endpoint. ## Preconditions - `ENABLE_OAUTH_TOKEN_EXCHANGE=True`. It is dis...
CVE-2026-88006	New				0.004	PyPI:open-webui	## Summary Open WebUI's OAuth token exchange endpoint issues a session for a provider access token without running the OAuth role management that the normal OAuth login callback runs. A user whose provider roles the login callback would refuse, or would demote, could still obtain a working session at their existing role through this endpoint. ## Preconditions - `ENABLE_OAUT...
CVE-2026-88010	New				0.007	Go:github.com/traefik/traefik	Traefik: BasicAuth singleflight coalescing reintroduces an unauthenticated username-enumeration timing oracle. NOTE: The source advisory for this report contains additional versions that could not be automatically mapped to standard Go module versions. (If this is causing false-positive reports from vulnerability scanners, please suggest an edit to the report.) The additi...
CVE-2026-8823	New				0.003	Go:github.com/mattermost/mattermost-server, Go:github.com/mattermost/mattermost-server/v5, Go:github.com/mattermost/matt	Mattermost has an Incorrect Authorization issue in github.com/mattermost/mattermost-server

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description							
CVE-2026-88978	New				0.003	Go:github.com/hatchet-dev/hatchet	Hatchet DurableTask WorkerStatus gRPC resolves caller-supplied durable-task UUIDs via ListSatisfiedEntries with no tenant_id filter in github.com/hatchet-dev/hatchet							
CVE-2026-89407	New		HIGH		0.006	Maven:com.fasterxml.jackson.core:jackson-core, Maven:tools.jackson.core:jackson-core	## Status **FULLY REPRODUCED** with a clean, textbook empirical signature: measured runtime grew almost exactly 4x for every doubling of input size across five consecutive doublings (5,000 → 160,000 characters), confirming O(n²) behavior. A single 160,000-character string (smaller than a typical HTTP request body) took **74.4 seconds** for one call to `NumberInput.looksLike...							
CVE-2026-89425	New		HIGH		0.005	Maven:com.fasterxml.jackson.core:jackson-core, Maven:tools.jackson.core:jackson-core	## Status **FULLY REPRODUCED.** A malformed token fed through `createParser(DataInput)` produced a 20,000,109-character exception message from a 20-million-character attacker payload, while the identical payload fed through `createParser(InputStream)` produced a correctly bounded 367-character message. ## Affected Component / Version - **Package:** `com.fasterxml.jackson....							
CVE-2026-9073	New				0.002	PyPI:foreman-mcp-server	A flaw was found in foreman-mcp-server. This component utilizes two distinct logging mechanisms that can expose sensitive session and authentication data. One mechanism logs session identifiers, which are treated as authentication credentials, at an informational level. The other, when debug logging is enabled, incompletely sanitizes HTTP request headers, leading to the clea...							
CVE-2026-90988	New						The Request a Quote WordPress plugin through 2.5.6 does not perform an authorization check on one of its unauthenticated AJAX handlers, allowing unauthenticated users to read the contact records of quote-request submissions, including records the site has not published.							
CVE-2026-91022	New						The Motors WordPress plugin before 1.4.124 does not sanitise and escape a listing badge setting before outputting it inside an HTML attribute, allowing users with a custom, administrator-assigned listing-management role to inject arbitrary web scripts that execute when a listing is viewed by any visitor, including an administrator.							
CVE-2026-91023	New						The Motors WordPress plugin before 1.4.124 does not properly verify that a user is authorised to modify a listing before processing one of its listing management actions, allowing authenticated attackers with subscriber-level access and above to set metadata on posts they do not own, including overwriting product prices. Exploitation is possible only when WooCommerce is act...							
CVE-2026-91129	New				0.002	PyPI:homeassistant	## Summary Home Assistant Green is vulnerable to a Server-Side Request Forgery (SSRF) via the mDNS/Zeroconf IPP integration. An unauthenticated attacker on the local network can send a crafted mDNS response to trick Home Assistant into making HTTP requests to arbitrary hosts, including internal services bound to localhost. The IPP integration automatically processes `_ipp._...							
CVE-2026-91130	New				0.004	PyPI:homeassistant	#### Summary An authenticated party can add a malicious name to any statistics-capable entity, allowing for Cross-Site Scripting attacks against anyone who views a Statistics Graph card containing that entity, when they hover over any data point on the chart. **Payload** CVE-2026-91828	New						The OMGF GDPR/DSGVO Compliant, Faster Google Fonts. Easy. WordPress plugin before 6.3.11 does not require authentication or a valid nonce on an action that issues a slow server-side loopback request, allowing unauthenticated attackers to exhaust the site's PHP worker pool and make the entire site unavailable.
CVE-2026-92164	New				0.003	PyPI:streamlink	## Summary `HTTPSession` mounts a `FileAdapter` for the `file://` scheme and inherits redirect handling unchanged from `requests.Session`. `requests` does not check for scheme downgrades or cross-protocol transitions when it follows a redirect, so any http(s) request Streamlink makes can be redirected by the remote server into `file:///...` and the local file is returned as...							
CVE-2026-92708	New		HIGH		0.007	npm:devalue	### Impact `stringify` and `uneval` serialize a typed array by emitting its backing `ArrayBuffer`, not just the view. In the case of a Node `Buffer` object, the backing buffer is a process-wide shared pool, meaning unrelated memory can be serialized into a response that is then sent to the client. For a Node `Buffer` the backing store is Node's process-wide shared pool ,...							
CVE-2026-92935	New		CRIT		0.007	npm:vm2	## Summary The `NodeVM` constructor computes `hasRealRequireConfig` using `typeof requireOpts === 'object' && requireOpts !== null`, so `require: []` bypasses the guard intended to reject `nesting` without an explicit require configuration. `makeResolverFromLegacyOptions()` then destructures the array to undefined option fields and returns a resolver containing only `NESTIN`...							
CVE-2026-92937	New		CRIT		0.01	npm:vm2	## Summary Untrusted JavaScript run by vm2 can escape the sandbox and execute arbitrary commands in the host Node.js process when an embedder-exposed host Promise rejects. This is an incomplete fix for GHSA-m283-3h24-438v: the advisory's capability-bearing rejection rebuild runs only through this direct Promise-handler path, so call/apply indirection bypasses the protection...							
CVE-2026-92938	New		CRIT		0.006	npm:vm2	### Summary vm2 3.11.6 exposes Node.js's host `node:sqlite` module to `NodeVM` code when that builtin is allowed explicitly or through `builtin: [*]`. The module is wrapped as read-only, but callable methods retain host-process authority. A sandboxed plugin can construct an in-memory database with extension loading enabled and call `DatabaseSync.loadExtension()` on a nati...							
CVE-2026-92939	New		CRIT		0.006	npm:vm2	Summary vm2 3.11.6 exposes the host `crypto` module to a `NodeVM` when that single builtin is allowed. The module is presented through a read-only bridge, but its functions still execute with host-process authority. `crypto.setEngine()` accepts a filesystem path and asks OpenSSL to dynamically load the referenced native library. An attacker whose untrusted plugin package c...							
CVE-2026-92940	New		CRIT		0.005	npm:vm2	Summary vm2 3.11.6 exposes the host process's real `https.globalAgent` when a `NodeVM` is explicitly allowed to require `https`. The module is wrapped as read-only, but calls to methods on the shared agent still mutate the host object. Sandbox code can register a `free` listener and receive host request options and the host TLS socket whenever an unrelated host HTTPS reques...							
CVE-2026-92941	New		CRIT		0.003	npm:vm2	Summary vm2 3.11.6 exposes the host `tls` module to a `NodeVM` when that builtin is explicitly allowed. Although the module object is wrapped as read-only, its functions still execute against process-wide host state. On Node.js versions that provide `tls.setDefaultCACertificates()`, sandbox code can replace the certificate authorities trusted by subsequent host-realm TLS cl...							

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-92944	New		CRIT		0.008	npm:vm2	## Reporter - Name or handle: `[YMsora]` - Report date: 2026-08-14 ## Summary The latest published vm2 release, 3.11.5 , and the current `main` branch are vulnerable to a sandbox escape when used on Node.js 26. An ordinary fulfilled Promise created by an async function can retain an attacker-controlled `constructor[Symbol.species]` across `Promise.prototype finally()`....
CVE-2026-92945	New		MODE		0.003	npm:vm2	## Summary `isPathAllowedForModule` decides whether a resolved path belongs to an allowlisted external module using a raw string prefix test. `node_modules/foo2` starts with `node_modules/foo`, so a package whose name merely shares a prefix with an allowlisted one is treated as being inside it, and a relative require from the allowlisted package reaches it even with transit...
CVE-2026-92948	New		CRIT		0.007	npm:vm2	## Summary On Node.js 24 and newer, `vm2` can expose the host `node:test` module to sandboxed `NodeVM` code when the embedder explicitly allows the `node:test` builtin. Sandbox code can reach that module through `require('node:node:test')` and call `run()` with attacker-controlled `execArgv`. `node:test.run()` starts a separate Node process for process-isolated test execut...
CVE-2026-92949	New		MODE		0.003	npm:vm2	### Summary Untrusted JavaScript running inside `new VM().run()` / `new NodeVM().run()` can bypass `vm.freeze()` / `vm.readonly()` and mutate a host object the embedder explicitly marked read-only - the documented contract is "prevent sandboxed scripts from adding, changing, or deleting properties". If the frozen host object has an accessor (get/set) own-property, the sandbo...
CVE-2026-92950	New		HIGH		0.002	npm:vm2	### Summary The `vm2` command-line tool installed by `npm install -g vm2` and documented in the README's "CLI" section runs the supplied script under `NodeVM` with `require:{external:true}` and no `root` / `context` / `builtin` configured. With these defaults the resolver loads every relative or absolute `require()` target through the host `require()` function, executing...
CVE-2026-92951	New		CRIT		0.005	npm:vm2	### Summary vm2 is a sandbox library for isolating and executing untrusted JavaScript code inside a Node.js process. It can restrict access to built-in modules and external packages. When `NodeVM` enables an `external` allowlist together with a custom `resolve` callback, vm2 checks the requested package name with a non-exact match. For example, if the allowlist only permit...
CVE-2026-92952	New		MODE		0.005	npm:vm2	## Summary vm2 current head (v3.11.5, commit 7a1f5100b96f48d34e0fe104ab37c0acc5944f92) still exposes registered Node.js internal symbols from host WebStream prototypes to sandbox code. The prior `nodejs.*` symbol hardening blocks `Symbol.for('nodejs.<name>')` at the source, but the extraction filters and bridge write traps still enumerate a fixed set of known registre...
CVE-2026-92957	New		CRIT		0.005	npm:vm2	## Summary NodeVM normalizes `node:`-prefixed builtin specifiers during `require()` resolution, but it does not normalize user-provided negative builtin entries in wildcard policy. As a result, this configuration: ``js new NodeVM({ require: { builtin: ['*', '-node:child_process'] } }); `` does not deny the canonical `child_process` builtin. Sandboxed code can r...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-92958	New		HIGH		0.004	npm:vm2	## Summary NodeVM's builtin wildcard policy can allow sandboxed code to access `fs/promises` even when the embedder denies `fs`. With the following configuration: ``js require: { builtin: ['*', '-fs', '-child_process'] } `` `require('fs')` and `require('child_process')` are blocked, but `require('fs/promises')` and `require('node:fs/promises')` are still available. T...
CVE-2026-93421	New				0.004	PyPI:mesop	### Summary The `/_csp__` endpoint accepts unauthenticated JSON reports and logs user-controlled values directly to stdout using `print()` without escaping control characters. A remote attacker can include ANSI/VT100 escape sequences in fields such as `blocked-uri` or `document-uri`. When the logs are viewed in an ANSI-capable terminal, these sequences can manipulate the ...
CVE-2026-94298	New						The BuildKit WordPress plugin before 1.0.29 does not properly sanitise and escape data submitted by contributor-level users before storing it and later using it in a SQL query, allowing a Contributor to inject SQL that runs against the database once the resulting content is published and viewed by any unauthenticated visitor.
CVE-2026-95137	New						Rejected reason: DO NOT USE THIS CANDIDATE NUMBER. ConsultIDs: none. Reason: This candidate was withdrawn by its CNA. Further investigation showed that it was not a security issue. Notes: none.
CVE-2026-97317	New						The Giveaways and Contests by RafflePress WordPress plugin before 1.12.27 does not remove the reCAPTCHA secret key from the giveaway settings it embeds in public giveaway pages, allowing unauthenticated visitors to retrieve the secret key of any active giveaway that has reCAPTCHA configured.
CVE-2026-97318	New						The Giveaways and Contests by RafflePress WordPress plugin before 1.12.27 does not properly validate a giveaway's parent page URL before saving it and later redirecting visitors to it, allowing unauthenticated attackers to make the site's own giveaway confirmation and referral links redirect visitors to an arbitrary external site.
CVE-2026-97687	New				0.002	PyPI:urllib3	## Impact urllib3 supports configuring TLS independently for an HTTPS proxy and the target server. `proxy_ssl_context`, `proxy_assert_hostname`, and `proxy_assert_fingerprint` configure the TLS connection to the proxy. `ssl_context` and the other target-specific TLS parameters configure the connection to the target server. In urllib3 versions 1.26.0 through 2.7.0, these c...
CVE-2026-97688	New				0.003	PyPI:urllib3	### Impact urllib3's streaming API is designed for the efficient handling of large HTTP responses by reading content in chunks instead of loading the entire response body into memory at once. urllib3 can decompress response bodies according to the HTTP `Content-Encoding` header. When streaming a compressed, chunked response, urllib3 first consumes data already buffered by ...
CVE-2026-97689	New				0.003	PyPI:urllib3	## Impact urllib3's [streaming API](https://urllib3.readthedocs.io/en/2.7.0/advanced-usage.html#streaming-and-i-o) is designed for efficiently handling large HTTP responses by reading the content in chunks, rather than loading the entire response body into memory at once. When decoding a [chunked-transfer-encoded response](https://httpwg.org/specs/rfc9112.html#chunked.encod...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
GHSA-27m4-jjxc-69wf	New					npm:kartykgithub-ph-b	--- _-= Per source details. Do not edit below this line.=-_ ## Source: ghsa-malware (b1a43aa1b797b98f578426b682f248b9e54bfd67acf5fc4030455c7d7228bc92) Any computer that has this package installed or running should be considered fully compromised. All secrets and keys stored on that computer should be rotated immediately from a different computer. The package should be remo...
GHSA-4q55-j62x-fr9h	New		MODE			npm:devalue	This is another instance of https://github.com/sveltejs/devalue/security/advisories/GHSA-mwv9-gp5h-frr4 , where some payloads could cause `parse` to create objects with a `__proto__` own property. This on its own is not enough to cause prototype pollution, and indeed this is actually how `JSON.parse` works, but we decided to be a little more defensive here and not allow the c...
GHSA-7hq7-x7ww-7cxr	New					npm:kartykgithub-ph-e	--- _-= Per source details. Do not edit below this line.=-_ ## Source: ghsa-malware (83e406902c3f8a5a3951ce0c776e78b867e679199c683b67d6f2df8059dcdf72) Any computer that has this package installed or running should be considered fully compromised. All secrets and keys stored on that computer should be rotated immediately from a different computer. The package should be remo...
GHSA-834w-x8gq-8rmx	New					npm:illusion-datalab	--- _-= Per source details. Do not edit below this line.=-_ ## Source: ghsa-malware (bc6004785b370b58ab360f70d7959fad47ec55ec609e8556217976fc405a610b) Any computer that has this package installed or running should be considered fully compromised. All secrets and keys stored on that computer should be rotated immediately from a different computer. The package should be remo...
GHSA-9cqf-hhrq-7v45	New		HIGH			Go:github.com/siyuan-note/siyuan/kernel	### Scope note This endpoint does not exist in v3.7.3 or on master. It was introduced on the development branch by commit `9b8e8956f` on 2026-07-27 and is present on the current development head. No released stable version is affected. ### Summary `/api/av/getAttributeViewSearchTarget` is registered with `CheckAuth` only and performs no authorization of any kind. Given a ...
GHSA-hx4r-w6wj-j8fg	New		MODE			npm:devalue	`uneval` performs synchronous work proportional to a sparse array's declared length. An application that passes attacker-influenced sparse values to `uneval` can suffer event-loop blocking. Since attacker-controlled creation of sparse arrays is so difficult, this vulnerability is very difficult to exploit.
GHSA-mcm9-63f2-9j32	New		HIGH			npm:devalue	Under very constrained circumstances, data that was `parse`d and then passed to `uneval` could turn a small payload into a very large serialized string.
GHSA-r9w8-h9r3-54w4	New		HIGH			npm:devalue	Under very specific circumstances, `parse` could create massive ArrayBuffers with very small input. This required a malformed `ArrayBuffer` custom reviver.
GHSA-wf3x-273g-mvxv	New		LOW			npm:devalue	Evaluating legitimate `uneval` output for a sparse array can allocate memory proportional to its declared length. A tiny serialized value can therefore cause large memory allocation in a consuming browser/runtime. This occurs during evaluation of generated code, not in default `parse` sparse-array construction. You would only be affected by this if you were serializing very...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
GHSA-x2m2-w3gv-m5wg	New					npm:kartykgithub-ph-f	--- _-= Per source details. Do not edit below this line.=-_ ## Source: ghsa-malware (1e9463feb27a295ad0b7136837e12908bc8d668e0b7bbd70309c760165f071f9) Any computer that has this package installed or running should be considered fully compromised. All secrets and keys stored on that computer should be rotated immediately from a different computer. The package should be remo...
GHSA-x5rw-q4pp-hg5g	New		HIGH			npm:devalue	When serializing multiple promises, a later promise can reject before an earlier one settles. An internal rejected promise remains unhandled even if the caller catches the returned `stringifyAsync` promise. Under Node's default unhandled-rejection behavior this can terminate the process. Applications whose asynchronous failures/timing can be influenced by requests are potent...
MAL-2026-17351	New					npm:@bottino/baileys	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...
MAL-2026-17362	New					npm:@kelvdra/baileys	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...
MAL-2026-17419	New					PyPI:friendly-tools	friendly-tools 0.2 carries the same Snowflake payload as friendly-greeting-tools. Its --run-demo option, described as a print-only demo, execs a gzip and base64 blob from friendly_greeting/main.py that reads the container session token at /snowflake/session/token, switches to ACCOUNTADMIN and copies a table into s3://pkusinski-external/ through a new storage integration. --...
MAL-2026-17420	New					npm:online-header	--- _-= Per source details. Do not edit below this line.=-_ ## Source: ossf-package-analysis (161e267d603ad6aae77c0c365e895c8e40538da2c09f746c2183124434509fdc) The OpenSSF Package Analysis project identified 'online-header' @ 99.0.0 (npm) as malicious. It is considered malicious because: - The package communicates with a domain associated with malicious activity.
MAL-2026-17421	New					PyPI:spo365-graph	--- _-= Per source details. Do not edit below this line.=-_ ## Source: kam193 (ea8dd7600717964f4ca8f8b1134f867f4bf69f1538243d5c7da752eefed99fe1) During installation, the package deploys a rogue AWS Lambda function to collect credentials from Secret Manager as well as collect other data. Data are then exfiltrated. The malicious code was introduced in version 1.1.2. --- C...
MAL-2026-17422	New					PyPI:shortneer	--- _-= Per source details. Do not edit below this line.=-_ ## Source: kam193 (5e166ae1253c886885381cb5087f67a59a869cad6ece6f3ac40aefc6e463c27f) When used, the package exfiltrates Chrome extension files (likely targeting cryptocurrency wallets) and sensitive Telegram files. --- Category: MALICIOUS - The campaign has clearly malicious intent, like infostealers. Campaign...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
MAL-2026-17438	New					npm:@celestial-community/baileys	This package is a fork of the Baileys WhatsApp Web library (npm) and belongs to the "PhantomSub" family described by OX Security in September 2026: the publisher injected code that, without the installer asking, uses the installer's own authenticated WhatsApp session to subscribe that account to WhatsApp Channels (newsletters) the publisher chose, by sending the WhatsApp `w:...
MAL-2026-17439	New					npm:@developmentyora/baileys	This package is a fork of the Baileys WhatsApp Web library (npm) and belongs to the "PhantomSub" family described by OX Security in September 2026: the publisher injected code that, without the installer asking, uses the installer's own authenticated WhatsApp session to subscribe that account to WhatsApp Channels (newsletters) the publisher chose, by sending the WhatsApp `w:...
MAL-2026-17440	New					npm:@erlanzz/baileys	This package is a fork of the Baileys WhatsApp Web library (npm) and belongs to the "PhantomSub" family described by OX Security in September 2026: the publisher injected code that, without the installer asking, uses the installer's own authenticated WhatsApp session to subscribe that account to WhatsApp Channels (newsletters) the publisher chose, by sending the WhatsApp `w:...
MAL-2026-17441	New					npm:@fazzcodestudio/wa-web	This package is a fork of the Baileys WhatsApp Web library (npm) and belongs to the "PhantomSub" family described by OX Security in September 2026: the publisher injected code that, without the installer asking, uses the installer's own authenticated WhatsApp session to subscribe that account to WhatsApp Channels (newsletters) the publisher chose, by sending the WhatsApp `w:...
MAL-2026-17442	New					npm:@smart-dev-wa/baileys	This package is a fork of the Baileys WhatsApp Web library (npm) and belongs to the "PhantomSub" family described by OX Security in September 2026: the publisher injected code that, without the installer asking, uses the installer's own authenticated WhatsApp session to subscribe that account to WhatsApp Channels (newsletters) the publisher chose, by sending the WhatsApp `w:...
MAL-2026-17443	New					npm:@zanta/baileys	This package is a fork of the Baileys WhatsApp Web library (npm) and belongs to the "PhantomSub" family described by OX Security in September 2026: the publisher injected code that, without the installer asking, uses the installer's own authenticated WhatsApp session to subscribe that account to WhatsApp Channels (newsletters) the publisher chose, by sending the WhatsApp `w:...
MAL-2026-17444	New					npm:danz-bails	This package is a fork of the Baileys WhatsApp Web library (npm) and belongs to the "PhantomSub" family described by OX Security in September 2026: the publisher injected code that, without the installer asking, uses the installer's own authenticated WhatsApp session to subscribe that account to WhatsApp Channels (newsletters) the publisher chose, by sending the WhatsApp `w:...
MAL-2026-17445	New					npm:ichigo-baileys	This package is a fork of the Baileys WhatsApp Web library (npm) and belongs to the "PhantomSub" family described by OX Security in September 2026: the publisher injected code that, without the installer asking, uses the installer's own authenticated WhatsApp session to subscribe that account to WhatsApp Channels (newsletters) the publisher chose, by sending the WhatsApp `w:...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
MAL-2026-17446	New					npm:luoxy-baileys	This package is a fork of the Baileys WhatsApp Web library (npm) and belongs to the "PhantomSub" family described by OX Security in September 2026: the publisher injected code that, without the installer asking, uses the installer's own authenticated WhatsApp session to subscribe that account to WhatsApp Channels (newsletters) the publisher chose, by sending the WhatsApp `w:...`
MAL-2026-17447	New					npm:mikuhostt-baileys	This package is a fork of the Baileys WhatsApp Web library (npm) and belongs to the "PhantomSub" family described by OX Security in September 2026: the publisher injected code that, without the installer asking, uses the installer's own authenticated WhatsApp session to subscribe that account to WhatsApp Channels (newsletters) the publisher chose, by sending the WhatsApp `w:...`
MAL-2026-17448	New					npm:prastzy	This package is a fork of the Baileys WhatsApp Web library (npm) and belongs to the "PhantomSub" family described by OX Security in September 2026: the publisher injected code that, without the installer asking, uses the installer's own authenticated WhatsApp session to subscribe that account to WhatsApp Channels (newsletters) the publisher chose, by sending the WhatsApp `w:...`
MAL-2026-17449	New					npm:prastzyy	This package is a fork of the Baileys WhatsApp Web library (npm) and belongs to the "PhantomSub" family described by OX Security in September 2026: the publisher injected code that, without the installer asking, uses the installer's own authenticated WhatsApp session to subscribe that account to WhatsApp Channels (newsletters) the publisher chose, by sending the WhatsApp `w:...`
MAL-2026-17450	New					npm:rubbydev-crash-baileys	This package is a fork of the Baileys WhatsApp Web library (npm) and belongs to the "PhantomSub" family described by OX Security in September 2026: the publisher injected code that, without the installer asking, uses the installer's own authenticated WhatsApp session to subscribe that account to WhatsApp Channels (newsletters) the publisher chose, by sending the WhatsApp `w:...`
MAL-2026-17451	New					npm:wailib	This package is a fork of the Baileys WhatsApp Web library (npm) and belongs to the "PhantomSub" family described by OX Security in September 2026: the publisher injected code that, without the installer asking, uses the installer's own authenticated WhatsApp session to subscribe that account to WhatsApp Channels (newsletters) the publisher chose, by sending the WhatsApp `w:...`
MAL-2026-17452	New					npm:xcvrenzcompany	This package is a fork of the Baileys WhatsApp Web library (npm) and belongs to the "PhantomSub" family described by OX Security in September 2026: the publisher injected code that, without the installer asking, uses the installer's own authenticated WhatsApp session to subscribe that account to WhatsApp Channels (newsletters) the publisher chose, by sending the WhatsApp `w:...`
MAL-2026-17453	New					Go:gocommunity.io/orderedbtree	Part of the Graphalgo campaign. The module, first published around 2026-08-11, contains a second-stage remote access trojan in plaintext that runs automatically. The RAT collects system information, executes decrypted Go or JavaScript payloads, and polls two command-and-control channels every 3-10 seconds: an Ethereum smart contract used as a dead drop (Arbitrum Sepolia) and...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
MAL-2026-17454	New					Go:gogets.dev/btreex	Part of the Graphalgo campaign. The module, first published around 2026-09-08, hides its payload in a ZIP archive disguised as a SQL file (btreesql). The payload is triggered when a specific price integer value is passed, and drops the same dual-channel RAT (Ethereum smart contract dead drop plus Slack bot token) used by gocommunity.io/orderedbtrees.

Significant updates today - original Published Date retained

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-101148	Updated - CVSS added	10.0	CRIT				The BackupSheep WordPress Backup Plugin WordPress plugin through 1.8 does not properly validate its integration key, treating an unset or blank key as valid, which allows unauthenticated attackers to create and download full site backups, including the database with user password hashes, and to delete arbitrary files on the server, leading to sensitive data disclosure and si...
CVE-2026-102427	Updated - CVSS vector changed	10.0	CRIT		0.008	ordasoft:joomla_cck	Joomla Extension - ordasoft.com - Unauthenticated Remote Code Execution in OrdaSoft Joomla CCK < 8.3.16 - site/uploader.php is reached through the component's normal frontend routing (task=getContent), a task with no authentication or ACL check anywhere in the dispatch chain. The handler validates the uploaded file's content with a real magic-byte MIME check, but the extensi...
CVE-2026-51856	Updated - CVSS added	9.8	CRIT		0.002		In agentscope 1.0.18, 1.0.19, and 1.0.19 when the RealtimeAgent session exposes execute_python_code as an available tool, a remote WebSocket user can prompt the agent to call that tool and run Python code in the service environment. In the validated path, RealtimeAgent._acting forwards the model-produced tool call to Toolkit.call_tool_function, which invokes execute_python_c...
CVE-2026-51866	Updated - CVSS added	9.8	CRIT		0.002		In DB-GPT 0.7.5 and 0.8.0, a skill uploaded through the real /api/v1/skills/upload route can later be executed through the real /api/v1/chat/react-agent flow.
CVE-2026-51870	Updated - CVSS added	9.8	CRIT		0.002		DeepTutor v1.4.0 is vulnerable to command execution in /tutorbot/agent/tools/shell.py:ExecTool.execute.
CVE-2026-51871	Updated - CVSS added	9.8	CRIT		0.002		Devika v1.0 is vulnerable to Code Injection in the Runner.execute function in src/agents/runner/runner.py which allows an attacker to achieve arbitrary code execution by exploiting the direct execution of LLM-generated content.
CVE-2026-102992	Updated - Fix/version updated	9.2	CRIT		0.006	npm:piscina	### Summary A prototype-pollution gadget in `ThreadPool.options` allows an attacker who can pollute `Object.prototype` to execute arbitrary code in Piscina worker threads, invoke arbitrary functions during task scheduling, or inject environment variables into workers. The root cause is that `ThreadPool.options` is created as a plain object inheriting from `Object.prototype`...
CVE-2026-51859	Updated - CVSS added	9.1	CRIT		0.003		bisheng 2.3.0, 2.4.0, and 2.4.0-beta1 is vulnerable to directory traversal in save_download_file (src/backend/bisheng/core/cache/utils.py:290).

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-51864	Updated - CVSS added	9.1	CRIT		0.005		DB-GPT v0.7.5 and v0.8.0 contains directory traversal in python_file_upload (packages/dbgpt-app/src/dbgpt_app/openapi/api_v1/python_upload_api.py:42). A remote attacker can use the validated exploitation path to write files outside the intended workspace or storage boundary.
CVE-2026-92173	Updated - CVSS added	9.1	CRIT		0.002		Prior to v74.0.0.878.1682 of Meta Horizon OS, MediaSyncJobReceiver could be induced to send a privileged PendingIntent including a com.oculus.vrshell CallerIdentity to an arbitrary application listening via NotificationListenerService. That would allow the application to impersonate the com.oculus.vrshell package, as well as packages signed with the same key, towards any end...
CVE-2026-101147	Updated - CVSS added	8.8	HIGH				The Featured Image from URL (FIFU) WordPress plugin before 6.0.8, Featured Image from URL (FIFU) Premium WordPress plugin before 8.2.8 do not correctly enforce the REST API nonce, disabling the check for the whole request when a crafted URL is used, which could allow attackers to make a logged-in administrator perform any REST API action, such as creating a new administrator...
CVE-2026-102578	Updated - CVSS changed (5.5 → 8.8)	8.8	HIGH		0.002	moodle:moodle	A flaw was found in Moodle. An authenticated attacker with access to the question bank web service can submit unsanitized input directly into database queries, resulting in a SQL (Structured Query Language) injection vulnerability. This issue could allow an attacker to view, alter, or delete sensitive data stored in the underlying database.
CVE-2026-92172	Updated - CVSS added	8.8	HIGH		0.002		Prior to v66.0.0.733.524 of Meta Horizon OS, OVRMediaService could be induced to send a privileged PendingIntent including a com.oculus.horizon CallerIdentity to an arbitrary application registering for com.oculus.systemactivities.SCREENSHOT via a broadcast receiver. That would allow the application to impersonate the com.oculus.horizon package towards any endpoint within th...
CVE-2024-58387	Updated - CVSS changed (7.5 → 8.7)	8.7	HIGH		0.007		Inspur Haiyue HCM Cloud contains an arbitrary file read vulnerability in the /api/model_report/file/download endpoint that allows unauthenticated remote attackers to read arbitrary files by supplying unvalidated path parameters index and ext. Attackers can craft requests such as /api/model_report/file/download?index=/{path} to traverse the filesystem and disclose sensit...
CVE-2026-101882	Updated - CVSS changed (8.8 → 8.7)	8.7	HIGH		0.008		OpenClaw Windows Node before 2026.7.1 contains an incomplete validation vulnerability in system.execApprovals.set that accepts wildcard-executable rules and abusable system binaries like mshta, rundll32, and certutil. Remote callers can add broad allow rules to execute arbitrary commands on the Windows host through system.run without operator checks or user prompts.
CVE-2026-102993	Updated - Fix/version updated	8.7	HIGH		0.005	pip:pypdf	#### Impact An attacker who uses this vulnerability can craft a PDF which leads to large memory consumption. This requires accessing the page labels of a document with large Roman numerals. #### Patches This has been fixed in [pypdf==6.17.0](https://github.com/py-pdf/pypdf/releases/tag/6.17.0). #### Workarounds If you cannot upgrade yet, consider applying the changes from ...
CVE-2026-102994	Updated - Fix/version updated	8.7	HIGH		0.005	pip:pypdf	#### Impact An attacker who uses this vulnerability can craft a PDF which leads to long runtimes. This requires reading a PDF document with long indirect object headers, not terminated by whitespace. #### Patches This has been fixed in [pypdf==6.18.0](https://github.com/py-pdf/pypdf/releases/tag/6.18.0). #### Workarounds If you cannot upgrade yet, consider applying the cha...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-102995	Updated - Fix/version updated	8.7	HIGH		0.005	pip:pypdf	### Impact An attacker who uses this vulnerability can craft a PDF which leads to large memory consumption. This requires parsing the `ToUnicode` entry of a font with unusually large values, for example during text extraction. ### Patches This has been fixed in [pypdf==6.18.1](https://github.com/py-pdf/pypdf/releases/tag/6.18.1). ### Workarounds If you cannot upgrade y...
CVE-2026-102996	Updated - Fix/version updated	8.7	HIGH		0.005	pip:pypdf	### Impact An attacker who uses this vulnerability can craft a PDF which leads to large memory consumption. This requires parsing the `Widths` entry of a TrueType or Type1 fonts with unusually large values, for example during text extraction. ### Patches This has been fixed in [pypdf==6.18.1](https://github.com/py-pdf/pypdf/releases/tag/6.18.1). ### Workarounds If you ...
CVE-2026-102997	Updated - Fix/version updated	8.7	HIGH		0.005	pip:pypdf	### Impact An attacker who uses this vulnerability can craft a PDF which leads to long runtimes. This requires a partially malformed `FlateDecode` stream, where the byte-by-byte decompression is used. ### Patches This has been fixed in [pypdf==6.18.1](https://github.com/py-pdf/pypdf/releases/tag/6.18.1). ### Workarounds If you cannot upgrade yet, consider applying the ...
CVE-2026-102998	Updated - Fix/version updated	8.7	HIGH		0.005	pip:pypdf	### Impact An attacker who uses this vulnerability can craft a PDF which leads to long runtimes. This requires updating form field values with flattening enabled, which triggers appearance stream generation. ### Patches This has been fixed in [pypdf==6.19.0](https://github.com/py-pdf/pypdf/releases/tag/6.19.0). ### Workarounds If you cannot upgrade yet, consider applyin...
CVE-2026-102999	Updated - Fix/version updated	8.7	HIGH		0.005	pip:pypdf	### Impact An attacker who uses this vulnerability can craft a PDF which leads to long runtimes. This requires accessing the embedded files through the dictionary-based API. ### Patches This has been fixed in [pypdf==6.19.0](https://github.com/py-pdf/pypdf/releases/tag/6.19.0). ### Workarounds If you cannot upgrade yet, consider applying the changes from PR [#4081](http...
CVE-2026-103000	Updated - Fix/version updated	8.7	HIGH		0.005	pip:pypdf	### Impact An attacker who uses this vulnerability can craft a PDF which leads to large memory consumption. This requires accessing the page labels of a document with large alphabetical labels. ### Patches This has been fixed in [pypdf==6.19.0](https://github.com/py-pdf/pypdf/releases/tag/6.19.0). ### Workarounds If you cannot upgrade yet, consider applying the changes ...
CVE-2026-103472	Updated - CVSS changed (7.5 → 8.7)	8.7	HIGH		0.008		restbed through 5.0.0 accepts WebSocket frames with declared payload lengths up to 2^63 bytes and buffers the payload without size limits in an unbounded stream buffer. Remote unauthenticated attackers can declare large frame sizes and stream payload data to exhaust server memory, causing denial of service through process crash.
CVE-2026-19253	Updated - CVSS added	8.7	HIGH				The Cache Enabler WordPress plugin before 1.8.17 does not validate a URL before using it to build a filesystem path in its cache purge routine, and does not confine the resulting deletion to the cache directory, allowing unauthenticated users to delete arbitrary files and directories on sites where another installed Cache Enabler WordPress plugin before 1.8.17 or passes a r...
CVE-2026-89296	Updated - CVSS added	8.6	HIGH				The Pro Like Button WordPress plugin before 2.0 does not properly sanitize and escape a parameter before using it in a SQL query, allowing unauthenticated users to perform SQL injection attacks.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-101909	Updated - CVSS added	8.3	HIGH		0.004		Axios is a promise-based HTTP client for the browser and Node.js. From 0.28.0 until 0.34.0 and 1.15.1 until 1.20.0, ToFormData processes inherited serialization options and visitor properties supplied through prototype pollution. A separate same-process prototype-pollution flaw supplies inherited dots, indexes, metaTokens, maxDepth, visitor, or Blob values before object seri...
CVE-2026-101901	Updated - CVSS added	8.2	HIGH		0.004		Axios is a promise-based HTTP client for the browser and Node.js. From 1.13.0 until 1.20.0, Http2Sessions does not install adequate error handling for a ClientHttp2Session during Axios HTTP/2 session initialization or reuse. A request uses httpVersion: 2 and the ClientHttp2Session emits an error during session initialization or reuse. The unhandled session error escapes norm...
CVE-2026-102990	Updated - Fix/version updated	8.2	HIGH		0.005	npm:basic-ftp	## Summary `Client.list()` parses the server's directory listing with the Unix-style parser in `parseListUnix.js`. Its `RE_LINE` regex has two adjacent `(S+(?:\s\S+))*` groups (owner name, then group name) followed by a required numeric size group. When a line starts with a valid listing prefix but the tokens after it never satisfy the size and date fields, the engine back...
CVE-2026-101905	Updated - CVSS added	7.6	HIGH		0.003		Axios is a promise-based HTTP client for the browser and Node.js. From 1.15.2 until 1.20.0, the Node HTTP adapter in lib/adapters/http.js supplies request options without an own createConnection value. A separate same-process prototype-pollution flaw places a function on Object.prototype.createConnection. Node resolves and invokes the inherited createConnection socket factor...
CVE-2026-51853	Updated - CVSS added	7.5	HIGH		0.003		agent-zero 1.7, 1.8, 1.9, and 1.10 is vulnerable to Directory Traversal in python/helpers/file_browser.py:FileBrowser.__init__. The FileBrowser class initializes with the host root directory as the workspace, allowing the agent to access any file on the system without restriction.
CVE-2026-51860	Updated - CVSS added	7.5	HIGH		0.003		bisheng 2.3.0, 2.4.0, and 2.4.0-beta1 is vulnerable to Directory Traversal in src/backend/bisheng/linsight/domain/task_exec.py.
CVE-2026-81739	Updated - CVSS added	7.5	HIGH				The Paytm Payment Gateway WordPress plugin before 2.8.9 does not sanitize and escape data it stores from payment callbacks before outputting it in an admin page, and the integrity check on those callbacks can be forged when the gateway is enabled without credentials, allowing unauthenticated users to store scripts that will run in the session of a store administrator.
CVE-2026-81809	Updated - CVSS added	7.5	HIGH				The Paytm Payment Gateway WordPress plugin before 2.8.9 does not properly escape data taken from payment callbacks before using it in a SQL statement, and the integrity check on those callbacks can be forged when the gateway is enabled without credentials, allowing unauthenticated users to perform SQL injection attacks.
CVE-2026-96255	Updated - CVSS added	7.5	HIGH				The Payments for Hubtel WordPress plugin before 1.0.2 does not prevent public access to a debug log in which it records payment requests, including the store's payment gateway API credentials in plain text, allowing unauthenticated attackers to obtain those credentials.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-101916	Updated - CVSS added	7.4	HIGH		0.002		@grpc/grpc-js implements the core functionality of gRPC purely in JavaScript, without a C++ addon. Prior to 1.13.6 and 1.14.5, getContext does not distinguish authorized from unauthorized peer certificates when server credentials set requireClientCertificate to false. When applications use the returned authentication context, they can treat an unauthorized certificate as...
CVE-2026-92412	Updated - CVSS added	7.1	HIGH				The Five Star Restaurant Reviews WordPress plugin before 2.3.14 does not properly escape a user-supplied value before outputting it into an HTML tag, allowing unauthenticated attackers to inject arbitrary web script that runs in the browser of anyone tricked into submitting a crafted request, including a logged-in administrator.
CVE-2026-103476	Updated - CVSS changed (5.3 → 6.9)	6.9	MEDI		0.005		yii2-starter-kit through 4.2.0 fails to validate article publication status in the attachment-download endpoint, allowing unauthenticated attackers to download files from draft articles. Attackers can enumerate sequential attachment identifiers to retrieve files from unpublished articles without authentication or authorization checks.
CVE-2026-103530	Updated - CVSS changed (7.3 → 6.9)	6.9	MEDI				A vulnerability was detected in decolua 9Router up to 0.5.55. The affected element is the function fetch of the file src/shared/utls/ssrfGuard.js of the component Search Endpoint. Performing a manipulation of the argument provider_options.baseUrl results in server-side request forgery. The attack can be initiated remotely. Applying a patch is the recommended action to fix t...
CVE-2026-103532	Updated - CVSS changed (5.3 → 6.9)	6.9	MEDI				A vulnerability has been found in immich-app Immich up to 2.7.5. This affects the function checkSharedLinkAccess of the file server/src/utls/access.ts of the component Shared Link Preview Handler. The manipulation of the argument Password leads to improper authorization. The attack may be initiated remotely. The reported GitHub issue was closed with the label "duplicate".
CVE-2026-90974	Updated - CVSS added	6.5	MEDI				The WP Fusion Lite WordPress plugin before 3.48.0 does not require authentication on a settings handler that runs during admin initialization, allowing unauthenticated users to overwrite the site's CRM integration endpoint and credentials, after which synced user data is delivered to an attacker-chosen host.
CVE-2026-86610	Updated - CVSS added	6.4	MEDI				The Download Manager WordPress plugin before 3.3.71 does not sufficiently sanitise and escape a package setting before outputting it back in a page, which could allow users with the Author role and above to perform Stored Cross-Site Scripting attacks against any visitor who opens the package's download dialogue, including administrators. Only sites running PHP below 8.1 are ...
CVE-2026-102586	Updated - CVSS changed (4.3 → 6.1)	6.1	MEDI		0.003	moodle:moodle	A flaw was found in Moodle. Insufficient sanitization of username input on the password reset page allows a remote attacker to conduct a cross-site scripting (XSS) attack. By convincing an unauthenticated user to access a specially crafted password reset link, an attacker could execute arbitrary script in the victim's browser.
CVE-2026-103536	Updated - CVSS changed (7.3 → 5.5)	5.5	MEDI				A vulnerability was identified in ZongXR Supermarket 1.0.0.0. Affected by this vulnerability is the function OrderController.addOrder of the file order/src/main/java/com/supermarket/order/controller/OrderController.java of the component save Endpoint. Such manipulation of the argument userId leads to missing authentication. The attack can be executed remotely. The exploit is...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-103538	Updated - CVSS changed (6.5 → 5.5)	5.5	MEDI				A security flaw has been discovered in ZongXR SuperMarket 1.0.0.0. Affected by this issue is the function OrderController.deleteOrder of the file order/src/main/java/com/supermarket/order/controller/OrderController.java of the component Order Deletion Endpoint. Performing a manipulation of the argument orderId results in missing authentication. The attack is possible to be c...
CVE-2026-102581	Updated - CVSS changed (4.6 → 5.4)	5.4	MEDI		0.002	moodle:moodle	A flaw was found in Moodle. Insufficient output escaping in templates used to display forum posts enables a stored cross-site scripting (XSS) vulnerability. An attacker can inject malicious content into a forum post, which then executes arbitrary script code in the browser of another user viewing the affected post.
CVE-2026-90972	Updated - CVSS added	5.4	MEDI				The WP Fusion Lite WordPress plugin before 3.48.0 does not perform a capability check on two of its admin AJAX handlers, allowing any authenticated subscriber to read other users' email addresses and to trigger a cross-user CRM re-sync.
CVE-2026-47096	Updated - CVSS changed (6.1 → 5.3)	5.3	MEDI		0.004		AJA HELO Plus firmware before 2.1.7 contains a stored cross-site scripting vulnerability that allows unauthenticated attackers with network access to inject malicious JavaScript by setting an unsanitized eParamID_SystemName value through the /config?action=set web configuration API. Attackers can exploit this flaw when device authentication is disabled to persistently execut...
CVE-2026-96173	Updated - CVSS added	5.3	MEDI				The Payments for Hubtel WordPress plugin before 1.0.2 does not verify that the requester is authorized to view an order before redirecting a public payment-callback request, allowing unauthenticated attackers to obtain the order key of an arbitrary order and view its contents.
CVE-2026-96200	Updated - CVSS added	5.3	MEDI				The Payments for Hubtel WordPress plugin before 1.0.2 does not verify that payment notifications received by its payment callback come from the payment provider, allowing unauthenticated attackers to mark arbitrary orders as paid without payment.
CVE-2026-103587	Updated - CVSS changed (5.4 → 5.1)	5.1	MEDI				QloApps through 1.7.0 contains a reflected cross-site scripting vulnerability in the back-office Hotel Reservation System Book Now search, where date_to and id_room_type parameters are copied into template variables without validation. Attackers can craft a malicious link containing JavaScript payload in these parameters that executes in an authenticated administrator's sess...
CVE-2026-103589	Updated - CVSS changed (5.4 → 5.1)	5.1	MEDI				QloApps through 1.7.0 contains a reflected cross-site scripting vulnerability in the back-office room type editor that fails to escape room_num, floor, and comment field values in input attributes. Attackers can induce authenticated back-office users to submit crafted POST requests with malicious payloads to execute arbitrary JavaScript in the victim's administrative session.
CVE-2026-103590	Updated - CVSS changed (5.4 → 5.1)	5.1	MEDI				QloApps through 1.7.0 contains a reflected cross-site scripting vulnerability in the back-office room type editor's length of stay fields. Attackers can induce authenticated administrators to submit crafted POST requests with malicious payloads in restriction_min_los and restriction_max_los parameters, executing arbitrary JavaScript in the victim's administrative session.
CVE-2026-87970	Updated - CVSS added	4.7	MEDI				The If-So Dynamic Content WordPress plugin before 1.10.2 does not escape a request-supplied value before reflecting it in an unauthenticated AJAX response that is served as HTML, allowing attackers to execute arbitrary JavaScript in the browser of a visitor who opens a crafted link.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-102580	Updated - CVSS changed (2.2 → 4.3)	4.3	MEDI		0.002	moodle:moodle	A flaw was found in Moodle. An authenticated attacker can supply an improperly validated audience class name to the Report Builder component, allowing arbitrary class instantiation. This vulnerability enables the unauthorized creation of internal program objects, which may result in unexpected application behavior.
CVE-2026-102582	Updated - CVSS changed (2.2 → 4.3)	4.3	MEDI		0.002	moodle:moodle	A flaw was found in Moodle. The manual enrolment management page did not properly check whether the manual enrolment plugin was disabled, allowing users with enrolment permissions to access the page directly by navigating to its URL. Consequently, an authorized user could manage manual enrolments even after an administrator disabled the feature in the user interface.
CVE-2026-101915	Updated - CVSS added	3.7	LOW		0.003		@grpc/grpc-js implements the core functionality of gRPC purely in JavaScript, without a C++ addon. Prior to 1.13.6 and 1.14.5, when an application method handler throws an uncaught error, the server includes its error message in the status message sent to the client. The thrown error message is transmitted to the client, causing sensitive information disclosure when the mess...
CVE-2026-87973	Updated - CVSS added	3.1	LOW				The If-So Dynamic Content WordPress plugin before 1.10.2 does not sanitize a conversion name before storing it, nor escape it when rendering the analytics page, allowing users with editor-level access to store JavaScript that executes in the session of a higher-privileged user who views that page.
CVE-2026-100268	Updated - CVSS changed (7.7 → 2.7)	2.7	LOW		0.003	jetbrains:youtrack	In JetBrains YouTrack before 2026.2.19197 project administrators could read comments from other projects via notification templates
CVE-2026-101887	Updated - CVSS changed (3.5 → 2.1)	2.1	LOW				BlueALSA (bluez-alsa/bluealsad) contains a division-by-zero vulnerability in the LC3plus sink decoder (a2dp_lc3plus.c, a2dp_lc3plus_dec_thread) that allows a Bluetooth-adjacent attacker to crash the daemon by sending a crafted RTP media header with an attacker-controlled frame count field set to zero. Attackers can establish an A2DP source connection with an LC3plus session ...
CVE-2026-103540	Updated - CVSS changed (6.3 → 2.1)	2.1	LOW				A security vulnerability has been detected in formtools.org Form Tools up to 3.1.1. This vulnerability affects the function Clients::updateClientSettingsTab of the file global/code/Clients.class.php of the component Client Settings. The manipulation of the argument page_titles leads to improper neutralization of special elements used in a template engine. It is possible to i...
CVE-2026-103541	Updated - CVSS changed (6.3 → 2.1)	2.1	LOW				A vulnerability was detected in formtools.org Form Tools up to 3.1.1. This issue affects the function Files::uploadFile of the file global/code/actions.php of the component Ajax Handler. The manipulation results in unrestricted upload. It is possible to launch the attack remotely. The exploit is now public and may be used. The project was informed of the problem early through...
CVE-2026-103543	Updated - CVSS changed (6.3 → 2.1)	2.1	LOW				A vulnerability has been found in itsourcecode Leave Management System 1.0. The affected element is an unknown function of the file /module/leavetype/controller.php. Such manipulation of the argument LEAVTID leads to sql injection. The attack can be launched remotely. The exploit has been disclosed to the public and may be used.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-103533	Updated - CVSS changed (4.1 → 1.2)	1.2	LOW				A vulnerability was found in David-Crty databasement up to 1.7.1. This impacts the function https://github.com/David-Crty/databasement/pull/511 of the file <code>app/Http/Requests/Api/V1/RestoreRequest.php</code> of the component database-servers API Endpoint. The manipulation of the argument <code>schema_name</code> results in path traversal. The attack may be launched remotely. A high complexity lev...

Added to CISA KEV today

None in this window.

P1 new today

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-104286	New	9.8	CRIT	Yes		fortinet:fortimail	An improper limitation of a pathname to a restricted directory ('path traversal') vulnerability in Fortinet FortiMail 8.0.0 through 8.0.1, FortiMail 7.6.0 through 7.6.6, FortiMail 7.4.0 through 7.4.8, FortiMail 7.2.0 through 7.2.9 may allow an unauthenticated attacker to write arbitrary files on the underlying system via crafted HTTP or HTTPS requests.

P2 new today

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-55393	New	10.0	CRIT				Unvalidated pathnames in the web interface in Teledyne FLIR Aware2 versions through 6.9.0.2 (PackBot) and 1.7.9 (FirstLook) allows remote unauthenticated attackers to read configuration and security parameters on Teledyne FLIR PackBot and FirstLook robots running this software via path traversal.
CVE-2026-79901	New	9.9	CRIT				In deployments using BoKS keytab management, affected versions of boks_keytabmd generate Active Directory service-account passwords from a predictable pseudo-random sequence seeded with the current Unix timestamp. An attacker who knows the service principal and can estimate the password-change time can reproduce a limited candidate set and verify candidates offline.
CVE-2026-93698	New	9.9	CRIT				Insufficient validation allows arbitrary commands to be executed via the Multilang adminbin.
CVE-2026-96658	New	9.9	CRIT				A flaw was found in Foreman. An authenticated attacker with low-level permissions can achieve remote code execution (RCE) by bypassing the safemode sandbox within the templating engine. Due to improper handling of delegated methods, an attacker can append unauthorized functions to the allowed execution list, enabling them to run arbitrary commands on the hosting server.
CVE-2026-103752	New	9.8	CRIT				Unauthenticated Privilege Escalation in Authorizer <= 3.15.3 versions.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-103764	New	9.8	CRIT				Mooncake transfer engine before 0.3.13 contains an untrusted pointer dereference in ServerSession::readHeader that allows unauthenticated attackers to read and write arbitrary process memory via the TCP transport data port. Attackers can send a crafted SessionHeader with arbitrary addr and size values using READ or WRITE opcodes to disclose KV cache contents, prompts and sec...
CVE-2026-12627	New	9.8	CRIT				Fortra's Core Privileged Access Manager (BoKS) contains a stack-based buffer overflow vulnerability in boks_autoregisterd. A remote attacker with network access to the autoregistration service may be able to trigger memory corruption during client response processing.
CVE-2026-14378	New	9.8	CRIT				The DevKit Pro plugin for WordPress is vulnerable to Authentication Bypass Leading to Administrator Account Takeover in all versions up to, and including, 2.3.0 This is due to the `revert_switch` handler trusting the attacker-controlled `original_user_id` cookie as the privileged identity: `verify_nonce_and_capability()` incorrectly checks the `manage_options` capability on ...
CVE-2026-15989	New	9.8	CRIT				The Super Forms – Drag & Drop Form Builder plugin for WordPress is vulnerable to Privilege Escalation in all versions up to, and including, 6.3.316. This is due to the Register & Login add-on's before_email_success_msg() function whitelisting the client-submitted `role` key and copying it into the user-data array that is passed directly to wp_insert_user(), without validatin...
CVE-2026-19660	New	9.8	CRIT				The Divi Membership plugin for WordPress is vulnerable to Authentication Bypass in all versions up to, and including, 2.3.0. The `process_paypal_callback` function, hooked to the `init` action, accepts a base64-encoded `paypal_param` GET parameter with no IPN validation, no cryptographic signature check, no ownership verification, and no nonce, allowing it to trust an entire...
CVE-2026-56154	New	9.8	CRIT				Use After Free vulnerability in Apache HTTP Server's mod_rewrite when using lookahead (%{LA-U:HTTP:...}) This issue affects Apache HTTP Server: from 2.4.0 through 2.4.68.
CVE-2026-57941	New	9.8	CRIT				Use After Free vulnerability in Apache HTTP Server's mod_http2 via shared session->btmp re-entrancy This issue affects Apache HTTP Server: from 2.4.0 through 2.4.68.
CVE-2026-59797	New	9.8	CRIT				Improper Privilege Management vulnerability in Apache HTTP Server's mod_ssl via SSLRequire and file-related expressions. This issue affects Apache HTTP Server: from 2.4.0 through 2.4.68.
CVE-2026-75957	New	9.8	CRIT				The Ultimate Multisite – WordPress Multisite SaaS & WaaS Platform plugin for WordPress is vulnerable to Authentication Bypass in all versions up to, and including, 2.15.0 via the `checkout_form` parameter of the `login_customer_after_checkout` function. This is due to the publicly accessible `wu_ajax_nopriv_wu_validate_form` AJAX handler accepting a freely obtainable checkou...
CVE-2026-56662	New	9.6	CRIT				GetSimple CMS is a content management system (CMS), and GetSimple CMS CE is the community edition of that CMS. Prior to version 1.5, the UpdateCE update form contained no anti-CSRF token, and the POST handler performed no token or request-origin verification. A remote attacker can host a page that auto-submits a forged POST to the update endpoint; when an authenticated admin...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-103765	New	9.4	CRIT				Mooncake through 0.3.13.post1 contains a missing authentication vulnerability in the HTTP metadata server /metadata handler that allows unauthenticated attackers to read, overwrite, and delete transfer engine metadata keys. Attackers can poison segment descriptors such as tcp_data_port or re-create rpc_meta entries to redirect KV cache transfers to attacker-controlled listen...
CVE-2026-104480	New	9.4	CRIT				Discord libdave before 1.2.0 did not reject an MLS Welcome message when the resulting group roster contained an unrecognized participant. An attacker in control of the DAVE signaling path (the voice gateway, or an equivalent position able to add, alter, or withhold signaling messages to a client) could cause affected clients to accept an unauthorized member into the end-to-e...
CVE-2026-14984	New	9.4	CRIT				Cleartext transmission in the primary control endpoints of Teledyne FLIR Aware2 versions through 6.9.0.2 allows remote unauthenticated attackers to intercept, hijack, or modify session traffic against Teledyne FLIR PackBot robots running this software via sniffing or hijacking network traffic.
CVE-2026-18397	New	9.4	CRIT				This vulnerability enables unauthenticated remote code execution (RCE) on a victim's machine by exploiting a combination of cryptographic weaknesses and memory management issues in the SConnect native host component. The attack leverages an unrestricted messaging interface between an attacker-controlled web page and the native host, allowing malicious input to bypass securi...
CVE-2026-55395	New	9.4	CRIT				Hardcoded passwords in the access control in Teledyne FLIR Aware2 versions through 6.9.0.2 (PackBot) and 1.7.9 (FirstLook) allows remote unauthenticated attackers to access and reconfigure Teledyne FLIR PackBot and FirstLook robots running this software via reading the passwords from the firmware or documentation.
CVE-2026-94620	New	9.4	CRIT				Classroom 50 is a free and open-source tool for managing and grading programming assignments via GitHub. Prior to version 1.11.0, `gh teacher download` clones each student's assignment repository and then writes autograde artifacts (`result.json` and `results.json`) into the just-cloned working tree. The write followed symlinks, so a student who committed `result.json` or `r...
CVE-2026-103244	New	9.3	CRIT				ground-station versions before 0.8.0 contain an authentication bypass vulnerability in the setup.restore command that allows unauthenticated attackers to execute arbitrary SQL during first-run setup mode. Attackers can invoke setup.restore via Socket.IO to plant admin users and forged session tokens, then authenticate as administrator without credentials for complete applica...
CVE-2026-103264	New	9.3	CRIT				Fleet versions before 4.87.0 contain an authentication bypass vulnerability in the device API that accepts hostnames and hardware serials as authentication tokens in addition to device UUIDs. Unauthenticated attackers who know or guess these non-secret identifiers can authenticate as iOS/iPadOS hosts to read device data and trigger device-scoped actions including software in...
CVE-2026-103655	New	9.3	CRIT				MISP contains a vulnerability in its two-factor authentication (TOTP) verification process that permits a valid one-time code to be accepted more than once within its time-based validity window. The issue exists in the user login flow where a TOTP code is verified as a second authentication factor. Because the system did not record whether a given TOTP period had already be...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-103922	New	9.3	CRIT				Capacitor is a cross-platform native runtime for web applications. From 6.0.0 until 6.2.2, 7.6.9, 8.3.5, 8.4.3, and 8.5.1, the Android and iOS WebView navigation guard validates a target URL's host and scheme but not its path, allowing a victim who activates an untrusted link to navigate a frame to <code>/_capacitor_http_interceptor_</code> . The native proxy can fetch an attacker-selecte...
CVE-2026-13043	New	9.3	CRIT				A missing authentication vulnerability in the Kernel Memory Access Driver (PSKMAD) used by WatchGuard endpoint security products allows a local, authenticated attacker to bypass the driver's access-control handshake and issue arbitrary privileged commands to the driver, resulting in disclosure of kernel and process memory.
CVE-2026-62071	New	9.3	CRIT				Unauthenticated SQL Injection in WordPress File Upload <= 5.1.10 versions.
CVE-2026-71449	New	9.3	CRIT				: Use of Hard-coded Cryptographic Key vulnerability in Johnson Controls EasyIO FS32 allows : Retrieve Embedded Sensitive Data. This issue affects EasyIO FS32: before 3.0b63.
CVE-2026-102628	New	9.2	CRIT				The Cadmos LTI application hosted at cadmos.eummena.io had Laravel debug mode enabled (<code>APP_DEBUG=true</code> , <code>APP_ENV=local</code>) in a publicly accessible environment. An unauthenticated attacker could send a GET request and trigger an unhandled exception, causing Laravel to expose the entire server environment, including all <code>.env</code> configuration variables, in plaintext. Fixed on or befor...
CVE-2026-15896	New	9.1	CRIT				The Super Forms – Drag & Drop Form Builder plugin for WordPress is vulnerable to Directory Traversal in all versions up to, and including, 6.3.316 via the <code>parse_request</code> function. This makes it possible for unauthenticated attackers to read the contents of arbitrary files on the server, which can contain sensitive information. The optional <code>'file_upload_auth'</code> setting defaults ...
CVE-2026-53953	New	9.1	CRIT				GetSimple CMS is a content management system (CMS), and GetSimple CMS CE is the community edition of that CMS. In version 3.3.22, the password reset endpoint can be accessed without authentication. When a reset request is submitted for an existing user, the application generates a new temporary password and immediately stores its hash as the user's new password. The temporar...
CVE-2026-55083	New	9.1	CRIT				DHIS2 is a flexible information system for data capture, management, validation, analytics and visualization. From versions 2.42.0 to before 2.42.5.1, and from versions 2.43.0 to before 2.43.0.1, DHIS2 is vulnerable to remote code execution (RCE) via unsafe Java deserialization. This issue has been patched in versions 2.42.5.1, 2.43.0.1, and 2.44.
CVE-2026-56660	New	9.1	CRIT				GetSimple CMS is a content management system (CMS), and GetSimple CMS CE is the community edition of that CMS. Prior to version 1.5, the update handler in <code>UpdateCE.php</code> downloads a ZIP archive and extracts its contents into the web root without validating file types or extraction paths. Because PHP files are written into a web-accessible directory, an attacker who can cause a...
CVE-2026-63569	New	9.1	CRIT				Improper input validation in <code>DHAgreement.CalculateAgreement</code> (MTI/A0 two-pass Diffie-Hellman) in Legion of the Bouncy Castle Inc. <code>bc-csharp</code> before 2.7.0 allows an on-path attacker to make the local party compute an agreed value the attacker already knows, defeating the key authentication MTI/A0 is meant to provide. It also allows a malicious peer to learn the local static pri...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-79898	New	9.1	CRIT				Fortra BoKS Manager contains a command injection vulnerability in crlserver. An authenticated user authorized to add CRL URLs through BCC, the WSI REST or SOAP API, or the cacrl command-line interface could cause shell command substitution to be processed by crlserver as root on the BoKS Master. BCC and WSI provide network-accessible administration paths and do not require a...
CVE-2026-96659	New	9.1	CRIT				A flaw was found in Foreman. This vulnerability allows an authenticated user with low-level Viewer permissions to cause unauthorized information disclosure by submitting requests to template preview endpoints. By exploiting this issue, the user can access sensitive data, such as host root passwords. Furthermore, under insecure system configurations where Safemode protections...
CVE-2026-102667	New	9.0	CRIT				Joyland AI app allows an attacker with shared network access to inject JavaScript into content loaded in WebView. Without user-granted permissions, an attacker could access the clipboard, make arbitrary HTTP requests via the Weex 'stream' module, or access app-internal storage. If the installed app has been granted permissions previously, the attacker can access the entire ...
CVE-2026-86345	New	9.0	CRIT				A flaw was found in 389-ds-base. The server does not discard plaintext bytes already buffered from a client connection when negotiating StartTLS, allowing an on-path attacker to inject a crafted LDAP message that is processed after the TLS upgrade and whose response is delivered to the client in place of the client's own pending operation's response, due to messageID collisi...
CVE-2026-93029	New	9.0	CRIT				There is a stored XSS vulnerability allowing arbitrary code execution in the WHM Manage SSL Hosts interface.
CVE-2026-93697	New	9.0	CRIT				There is a stored XSS vulnerability allowing arbitrary code execution in the WHM Mass Modify Accounts interface.

Historical reports are not rewritten when an older CVE changes. A CVE published on an earlier date remains in that earlier daily report; a meaningful change is shown separately in the update section for the date on which the change was detected.